NON-WSQ · COURSE SLIDES

AI for Cyber Security

Course Code: C434

Two days · 15 instructional hours

Version v1.0 · 4 October 2026

Tertiary Infotech Academy Pte Ltd · UEN 201200696W

© 2026 Tertiary Infotech Academy Pte Ltd. All rights reserved.



COURSE ADMINISTRATION

Welcome to AI for Cyber Security

Two days · 15 hours · theory and hands-on practice



TRAINER PROFILE CARD

About the Trainer - General Template

Name

Trainer:
_____

Qualifications

Relevant cyber and AI credentials

Experience

Industry and training experience

Contact

Approved support channel

THE DECISION RULE

Complete before delivery; retain this as a visual profile card.

NAMED TRAINER PROFILE

About the Trainer - Dr Alfred Ang

Role

Principal trainer and courseware developer

Focus

AI, cybersecurity, cloud and secure software

Approach

Mechanism-led teaching with evidence

Provider

Tertiary Infotech Academy Pte Ltd

THE DECISION RULE

Architecture choices must connect to practical evidence and business outcomes.

CONTEXT SETTING

Learner Introductions

Role

Your current role and organisation context

Experience

Security, data or AI exposure

Outcome

One decision you want to improve

Boundary

A constraint or risk in your environment

THE DECISION RULE

Use learner context without sharing confidential incidents, credentials or personal data.

SAFE PRACTICE

Ground Rules

Authorised

Use only the synthetic data and supplied lab assets.

Evidence

Explain conclusions from observed fields.

Privacy

Do not paste secrets or production logs into AI tools.

Human review

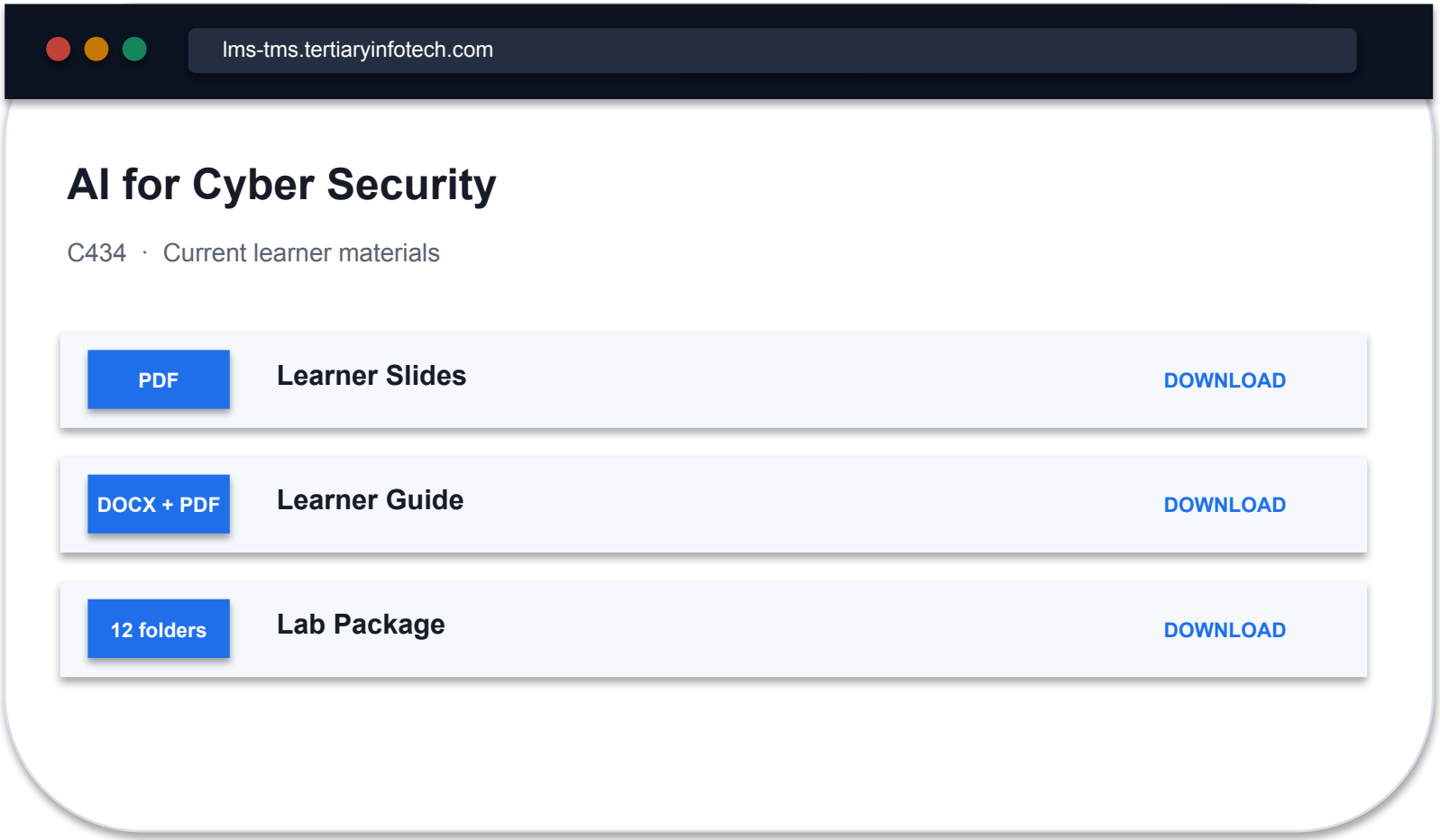
Treat AI output as a hypothesis until verified.

THE DECISION RULE

Practice stays lawful, scoped, privacy-aware and reproducible.

ANNOTATED LMS/TMS SURFACE · NO CLICK-BY-CLICK PROCEDURE

Course Materials



Learner set

Slides, guide and labs

Version

Match the cover filename

Privacy

No credentials or production data

Procedure

Detailed retrieval is in the LG

DELIVERY MODEL

Course Contract

Duration

2 days · 15 hours

Daily

9:30am – 5:30pm

Practice

8 hours hands-on

Format

Instructor-led classroom

THE DECISION RULE

Seven classroom hours + eight hands-on practical hours across two days.

15-HOUR LEARNING JOURNEY

Lesson Plan - Two-Day Through-Line

Day 1 · T1

Risk, telemetry and AI-assisted detection

Day 1 · T2

Control gaps and AI security programme design

Day 2 · T3

SOC architecture, grounded assistance and guarded response

Day 2 · T4

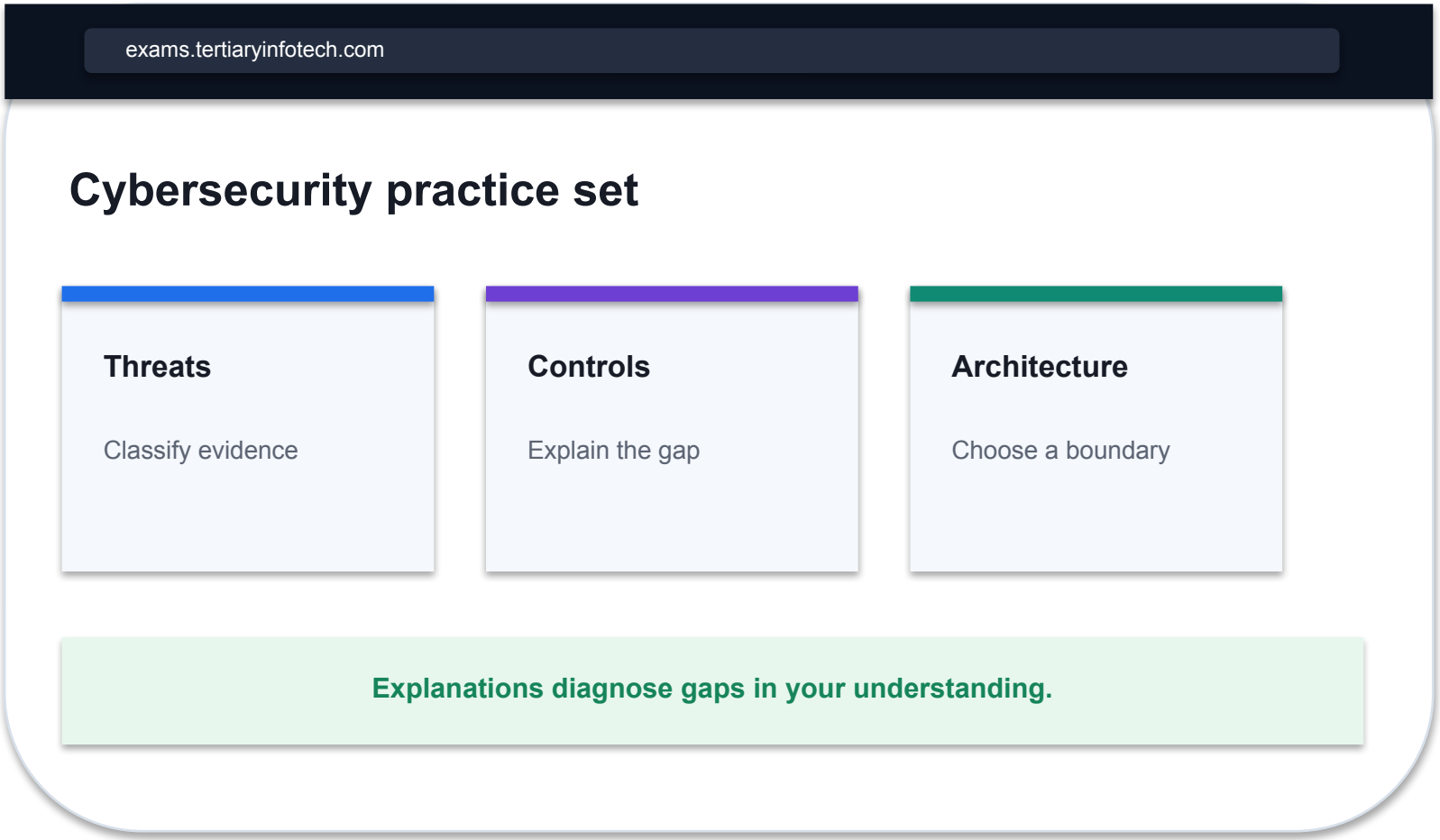
Monitoring, governance and advice

THE DECISION RULE

Theory and practice alternate; detailed lab procedure remains in the Learner Guide.

SUPPLEMENTARY PRACTICE · VISUAL PORTAL SURFACE

Practice Exam Portal



SCOPE NOTE

No dedicated C434 practice set is listed. Use the cybersecurity set only as supplementary practice.

Detailed navigation stays in the Learner Guide.

MECHANISM → CONTRACT → FAILURE → EVIDENCE

Technical Roadmap

Topic 1

AI-Assisted Security Risk, Threat and Control-Gap Analysis

Topic 2

Designing AI-Powered Cybersecurity Programmes

Topic 3

Developing AI-Driven Security Architecture and Action Plans

Topic 4

Monitoring, Evaluating and Governing AI Security Solutions

THE DECISION RULE

Each concept ends with a lab bridge and observable acceptance criteria.

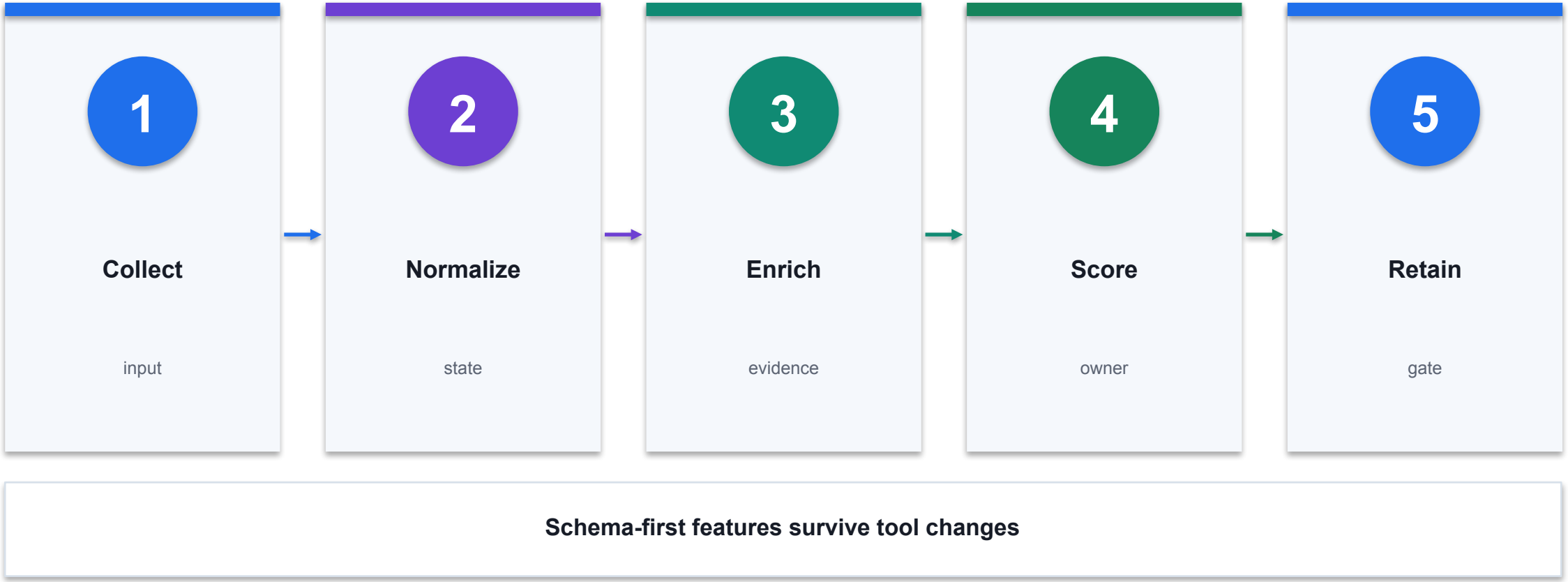
TOPIC 1 · LO1

AI-Assisted Security Risk, Threat and Control-Gap Analysis

Telemetry contracts · detection models · business impact · analyst evidence



Security telemetry is a governed evidence pipeline



FIELDS · FORMULAS · THRESHOLDS

Security telemetry is a governed evidence pipeline: concrete contract

```
CONTRACT
01  event_time: UTC timestamp
02  principal.id: stable identity
03  asset.criticality: 1-5
04  action/outcome: attempted result
```

1. Schema-first features survive tool changes
2. Late events need event-time windows
3. Asset context changes the same alert's risk
4. Raw evidence remains immutable

ANALYSIS · TRADE-OFF · DECISION

Security telemetry is a governed evidence pipeline: decision model

Signal 1

Schema-first features survive tool changes

Signal 2

Late events need event-time windows

Signal 3

Asset context changes the same alert's risk

Signal 4

Raw evidence remains immutable

THE DECISION RULE

Raw evidence remains immutable

Security telemetry is a governed evidence pipeline: failure and control

FAILURE MODES

- ! Clock skew creates false sequences
- ! Missing identity joins hide lateral movement
- ! PII copied into prompts
- ! Silent parser failures

CONTROL & EVIDENCE

- ✓ Parse success >= 99%
- ✓ Field null rates tracked
- ✓ Lineage links score to raw event
- ✓ Retention matches policy

Security telemetry is a governed evidence pipeline: verification evidence

Acceptance

Parse success >= 99%

Trace

Field null rates tracked

Review

Lineage links score to raw event

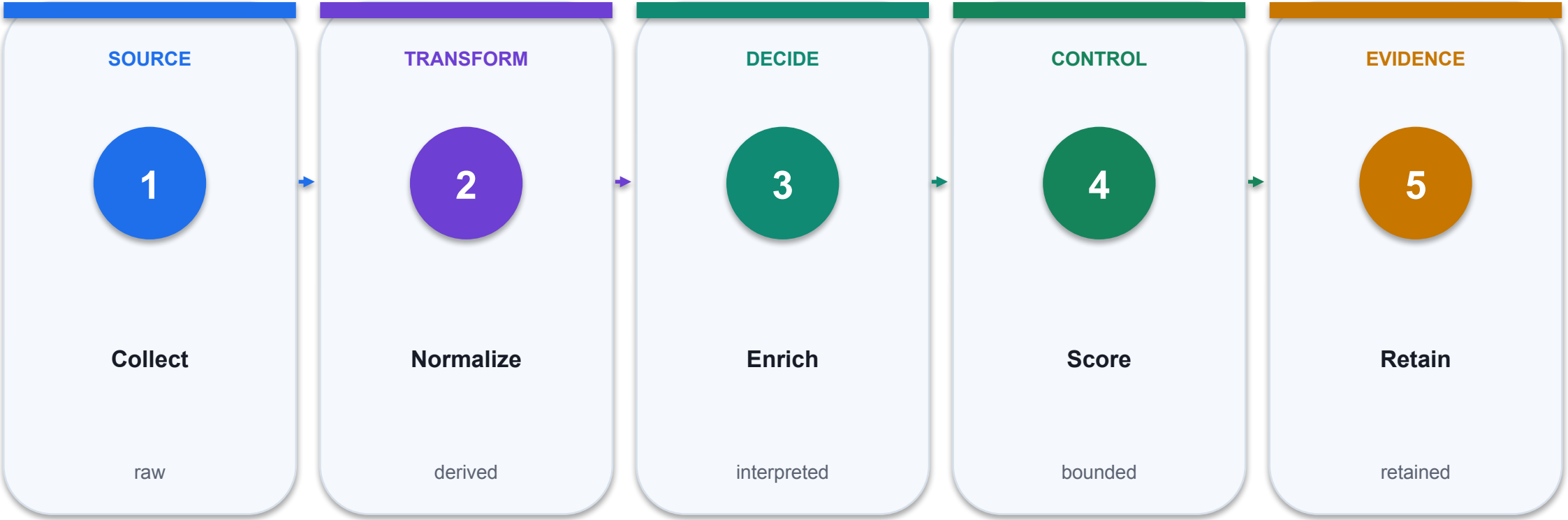
Operate

Retention matches policy

THE DECISION RULE

Lab 1 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Security telemetry is a governed evidence pipeline: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Security telemetry is a governed evidence pipeline: evidence artifact anatomy

```
ARTIFACT RECORD

01    event_time: UTC timestamp

02    principal.id: stable identity

03    asset.criticality: 1-5

04    action/outcome: attempted result

Immutable input reference · model/rule version · timestamp · named
reviewer
```

FIELD 1 — **Schema-first features survive tool changes**

Retain: Parse success >= 99%

FIELD 2 — **Late events need event-time windows**

Retain: Field null rates tracked

FIELD 3 — **Asset context changes the same alert's risk**

Retain: Lineage links score to raw event

FIELD 4 — **Raw evidence remains immutable**

Retain: Retention matches policy

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Security telemetry is a governed evidence pipeline: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
event_time: UTC timestamp	Schema-first features survive tool changes	Clock skew creates false sequences	Parse success >= 99%
principal.id: stable identity	Late events need event-time windows	Missing identity joins hide lateral movement	Field null rates tracked
asset.criticality: 1-5	Asset context changes the same alert's risk	PII copied into prompts	Lineage links score to raw event
action/outcome: attempted result	Raw evidence remains immutable	Silent parser failures	Retention matches policy

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Security telemetry is a governed evidence pipeline: control test design

T1

Clock skew creates false sequences

Condition: event_time: UTC timestamp

Pass evidence: Parse success >= 99%

T2

Missing identity joins hide lateral movement

Condition: principal.id: stable identity

Pass evidence: Field null rates tracked

T3

PII copied into prompts

Condition: asset.criticality: 1-5

Pass evidence: Lineage links score to raw event

T4

Silent parser failures

Condition: action/outcome: attempted result

Pass evidence: Retention matches policy

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Security telemetry is a governed evidence pipeline: operating trade-offs

CHOICE 1 **Schema-first features survive tool changes**

Trade-off: Clock skew creates false sequences

Guardrail: Parse success >= 99%

CHOICE 2 **Late events need event-time windows**

Trade-off: Missing identity joins hide lateral movement

rdrail: Field null rates tracked

REVIEWED OPERATING POINT

CHOICE 3 **Asset context changes the same alert's risk**

Trade-off: PII copied into prompts

Guardrail: Lineage links score to raw event

CHOICE 4 **Raw evidence remains immutable**

Trade-off: Silent parser failures

Guardrail: Retention matches policy

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Security telemetry is a governed evidence pipeline: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
event_time: UTC timestamp	Clock skew creates false sequences	**Schema-first features survive tool changes**	**Parse success >= 99%**
principal.id: stable identity	Missing identity joins hide lateral movement	**Late events need event-time windows**	**Field null rates tracked**
asset.criticality: 1-5	PII copied into prompts	**Asset context changes the same alert's risk**	**Lineage links score to raw event**
action/outcome: attempted result	Silent parser failures	**Raw evidence remains immutable**	**Retention matches policy**

Risk scoring joins threat likelihood to business impact



FIELDS · FORMULAS · THRESHOLDS

Risk scoring joins threat likelihood to business impact: concrete contract

```
CONTRACT

01   risk = likelihood x impact

02   likelihood = exploitability x exposure

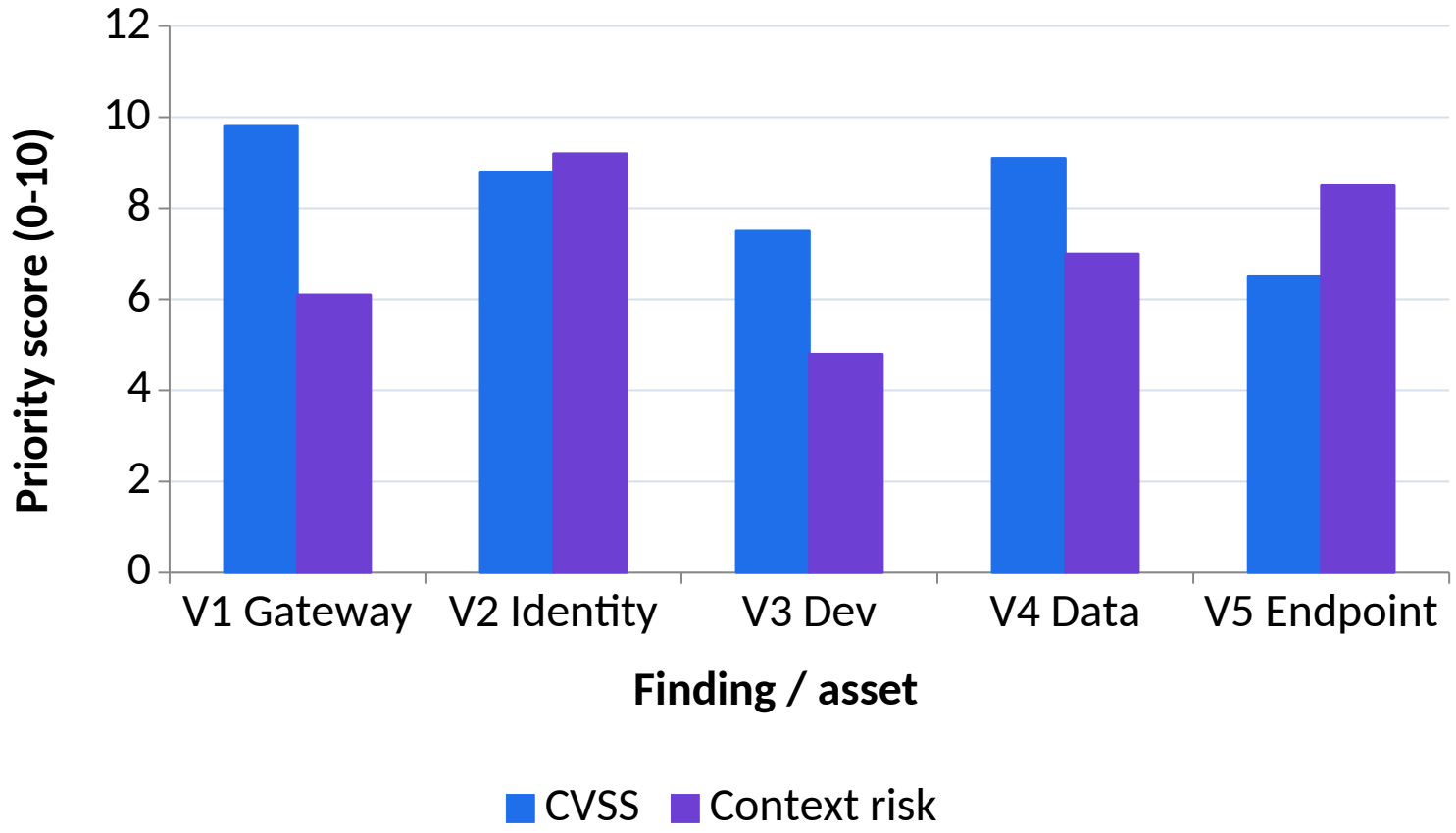
03   residual = inherent x (1-control_effectiveness)

04   owner + due_date + evidence
```

1. CVSS measures severity, not organisational priority
2. EPSS estimates exploitation probability
3. Criticality weights business consequence
4. Confidence must travel with the score

EDITABLE POWERPOINT CHART · INDICATIVE DATA

Risk scoring joins threat likelihood to business impact: evidence chart



WHAT THE DATA SHOWS

Technical severity and business-context priority diverge; remediation queues need both.

Indicative figures - validate on local data.

Risk scoring joins threat likelihood to business impact: failure and control

FAILURE MODES

- ! Single-number theatre
- ! Unbounded AI-generated severity
- ! No risk owner
- ! No exception expiry

CONTROL & EVIDENCE

- ✓ Top risks trace to assets
- ✓ Sensitivity analysis recorded
- ✓ Human approves priority band
- ✓ Exceptions expire automatically

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Risk scoring joins threat likelihood to business impact: verification evidence

Acceptance

Top risks trace to assets

Trace

Sensitivity analysis recorded

Review

Human approves priority band

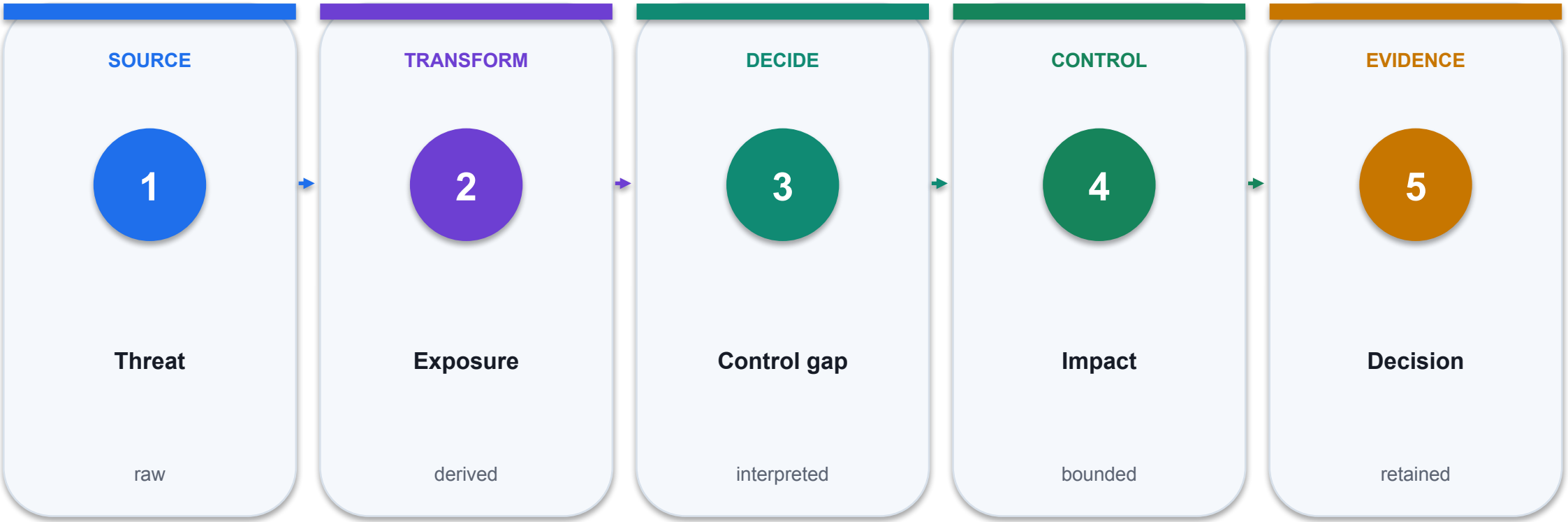
Operate

Exceptions expire automatically

THE DECISION RULE

Lab 1 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Risk scoring joins threat likelihood to business impact: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

Risk scoring joins threat likelihood to business impact: evidence artifact anatomy

ARTIFACT RECORD

```
01    risk = likelihood x impact

02    likelihood = exploitability x exposure

03    residual = inherent x (1-control_effectiveness)

04    owner + due_date + evidence
```

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **CVSS measures severity, not organisational priority**

Retain: Top risks trace to assets

FIELD 2 — **EPSS estimates exploitation probability**

Retain: Sensitivity analysis recorded

FIELD 3 — **Criticality weights business consequence**

Retain: Human approves priority band

FIELD 4 — **Confidence must travel with the score**

Retain: Exceptions expire automatically

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Risk scoring joins threat likelihood to business impact: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
risk = likelihood x impact	CVSS measures severity, not organisational priority	Single-number theatre	Top risks trace to assets
likelihood = exploitability x exposure	EPSS estimates exploitation probability	Unbounded AI-generated severity	Sensitivity analysis recorded
residual = inherent x (1-control_effectiveness)	Criticality weights business consequence	No risk owner	Human approves priority band
owner + due_date + evidence	Confidence must travel with the score	No exception expiry	Exceptions expire automatically

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Risk scoring joins threat likelihood to business impact: control test design

T1

Single-number theatre

Condition: risk = likelihood x impact

Pass evidence: Top risks trace to assets

T2

Unbounded AI-generated severity

Condition: likelihood = exploitability x exposure

Pass evidence: Sensitivity analysis recorded

T3

No risk owner

Condition: residual = inherent x (1-control_effectiveness)

Pass evidence: Human approves priority band

T4

No exception expiry

Condition: owner + due_date + evidence

Pass evidence: Exceptions expire automatically

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Risk scoring joins threat likelihood to business impact: operating trade-offs

CHOICE 1 CVSS measures severity, not organisational priority

Trade-off: Single-number theatre

Guardrail: Top risks trace to assets

CHOICE 2 EPSS estimates exploitation probability

Trade-off: Unbounded AI-generated severity

rdrail: Sensitivity analysis recorded

REVIEWED OPERATING POINT

CHOICE 3 Criticality weights business consequence

Trade-off: No risk owner

Guardrail: Human approves priority band

CHOICE 4 Confidence must travel with the score

Trade-off: No exception expiry

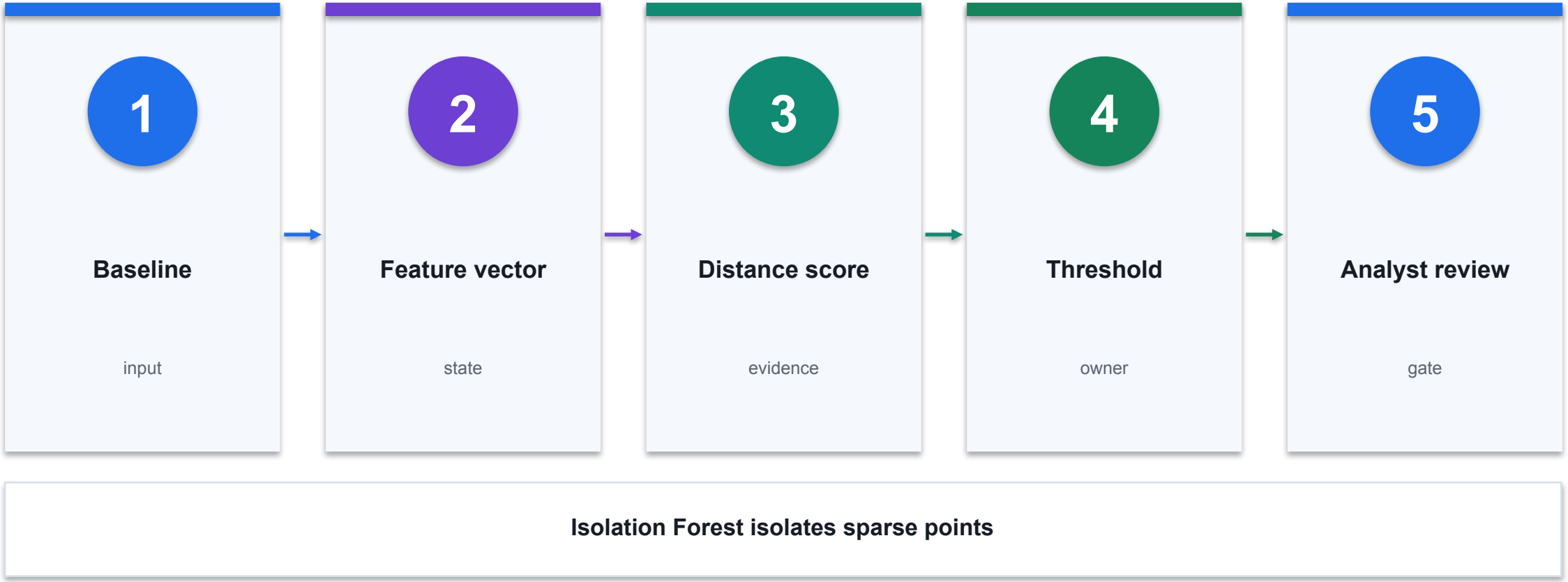
Guardrail: Exceptions expire automatically

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Risk scoring joins threat likelihood to business impact: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
risk = likelihood x impact	Single-number theatre	**CVSS measures severity, not organisational priority**	**Top risks trace to assets**
likelihood = exploitability x exposure	Unbounded AI-generated severity	**EPSS estimates exploitation probability**	**Sensitivity analysis recorded**
residual = inherent x (1-control_effectiveness)	No risk owner	**Criticality weights business consequence**	**Human approves priority band**
owner + due_date + evidence	No exception expiry	**Confidence must travel with the score**	**Exceptions expire automatically**

Anomaly detection models normal behaviour, not malicious intent



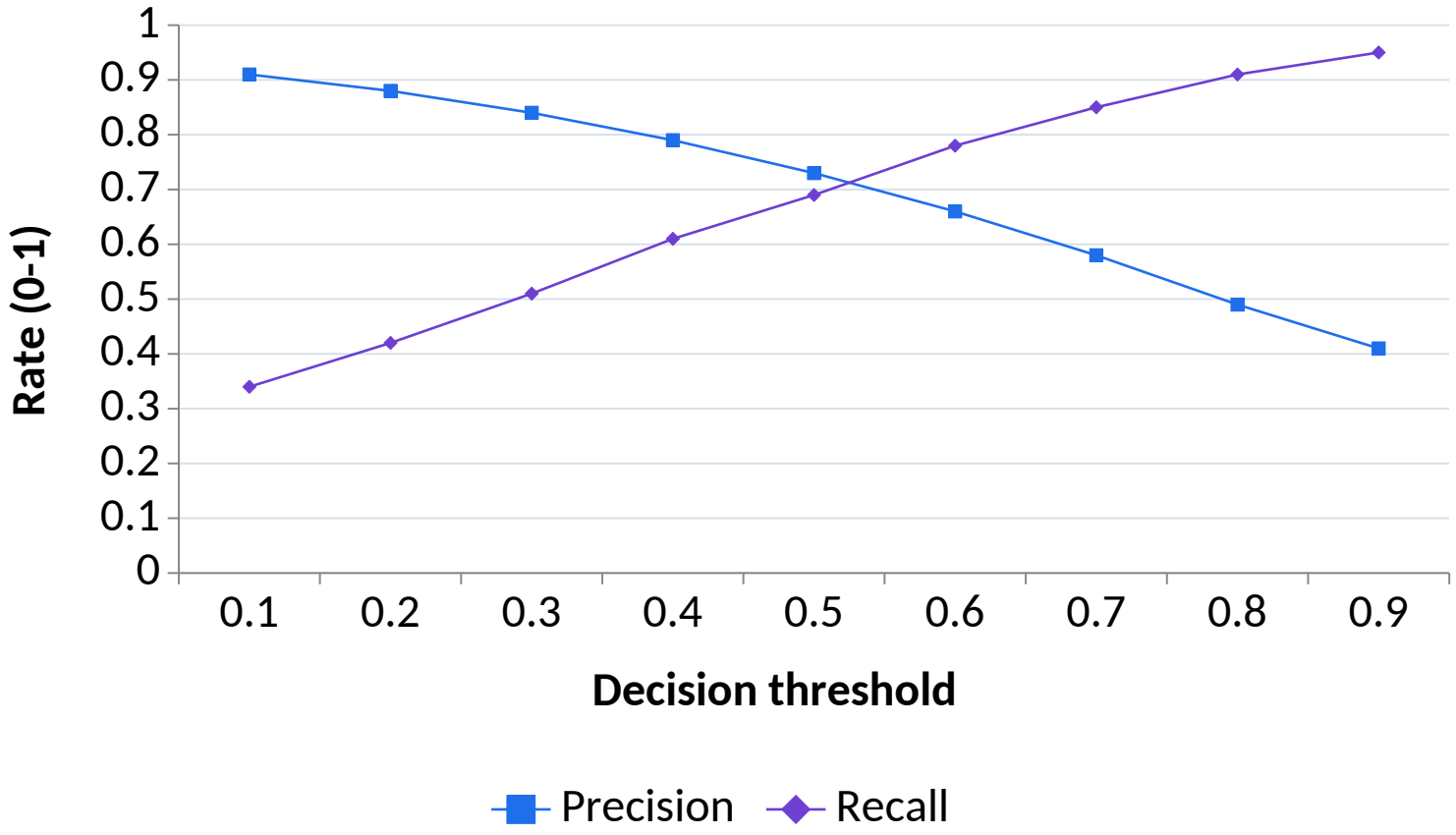
Anomaly detection models normal behaviour, not malicious intent: concrete contract

```
CONTRACT
01  window=15m
02  features=[failures,new_device,bytes_out]
03  score = model.decision_function(x)
04  alert if score < threshold
```

1. Isolation Forest isolates sparse points
2. Z-score assumes a stable distribution
3. Seasonality needs peer/time baselines
4. Threshold controls workload and misses

EDITABLE POWERPOINT CHART · INDICATIVE DATA

Anomaly detection models normal behaviour, not malicious intent: evidence chart



WHAT THE DATA SHOWS

Lower thresholds catch more events but increase analyst workload; tune against a stated operating point.

Indicative figures - validate on local data.

Anomaly detection models normal behaviour, not malicious intent: failure and control

FAILURE MODES

- ! Novel but benign deployment
- ! Poisoned baseline
- ! Feature drift
- ! Rare user treated as hostile

CONTROL & EVIDENCE

- ✓ Backtest on labelled window
- ✓ Report precision and recall
- ✓ Analyst disposition captured
- ✓ Threshold reviewed monthly

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Anomaly detection models normal behaviour, not malicious intent: verification evidence

Acceptance

Backtest on labelled window

Trace

Report precision and recall

Review

Analyst disposition captured

Operate

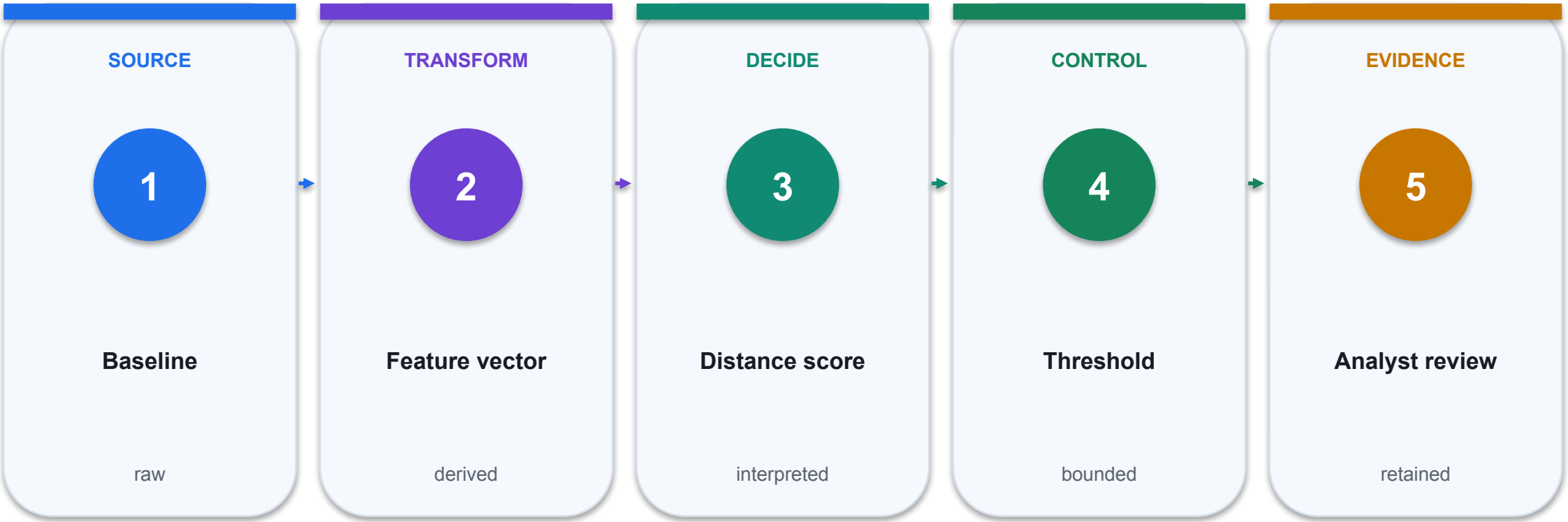
Threshold reviewed monthly

THE DECISION RULE

Lab 2 creates a reproducible artifact; detailed steps stay in the Learner Guide.

TRUST BOUNDARY · DATA FLOW · CONTROL OWNER

Anomaly detection models normal behaviour, not malicious intent: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Anomaly detection models normal behaviour, not malicious intent: evidence artifact anatomy

ARTIFACT RECORD

```
01    window=15m

02    features=[failures,new_device,bytes_out]

03    score = model.decision_function(x)

04    alert if score < threshold
```

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Isolation Forest isolates sparse points**

Retain: Backtest on labelled window

FIELD 2 — **Z-score assumes a stable distribution**

Retain: Report precision and recall

FIELD 3 — **Seasonality needs peer/time baselines**

Retain: Analyst disposition captured

FIELD 4 — **Threshold controls workload and misses**

Retain: Threshold reviewed monthly

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Anomaly detection models normal behaviour, not malicious intent: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
window=15m	Isolation Forest isolates sparse points	Novel but benign deployment	Backtest on labelled window
features=[failures,new_device,bytes_out]	Z-score assumes a stable distribution	Poisoned baseline	Report precision and recall
score = model.decision_function(x)	Seasonality needs peer/time baselines	Feature drift	Analyst disposition captured
alert if score < threshold	Threshold controls workload and misses	Rare user treated as hostile	Threshold reviewed monthly

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Anomaly detection models normal behaviour, not malicious intent: control test design

T1

Novel but benign deployment

Condition: window=15m

Pass evidence: Backtest on labelled window

T2

Poisoned baseline

Condition: features=[failures,new_device,bytes_out]

Pass evidence: Report precision and recall

T3

Feature drift

Condition: score = model.decision_function(x)

Pass evidence: Analyst disposition captured

T4

Rare user treated as hostile

Condition: alert if score < threshold

Pass evidence: Threshold reviewed monthly

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Anomaly detection models normal behaviour, not malicious intent: operating trade-offs

CHOICE 1 **Isolation Forest isolates sparse points**

Trade-off: Novel but benign deployment

Guardrail: Backtest on labelled window

CHOICE 2 **Z-score assumes a stable distribution**

Trade-off: Poisoned baseline

Guardrail: Report precision and recall

REVIEWED OPERATING POINT

CHOICE 3 **Seasonality needs peer/time baselines**

Trade-off: Feature drift

Guardrail: Analyst disposition captured

CHOICE 4 **Threshold controls workload and misses**

Trade-off: Rare user treated as hostile

Guardrail: Threshold reviewed monthly

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Anomaly detection models normal behaviour, not malicious intent: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
window=15m	Novel but benign deployment	**Isolation Forest isolates sparse points**	**Backtest on labelled window**
features=[failures,new_device,bytes_out]	Poisoned baseline	**Z-score assumes a stable distribution**	**Report precision and recall**
score = model.decision_function(x)	Feature drift	**Seasonality needs peer/time baselines**	**Analyst disposition captured**
alert if score < threshold	Rare user treated as hostile	**Threshold controls workload and misses**	**Threshold reviewed monthly**

IMAGEGEN VISUAL · EDITABLE ANNOTATIONS

Anomaly score is a review trigger, not a verdict



1 **Baseline**

Normal behaviour is a measured window.

2 **Divergence**

A score marks distance, not intent.

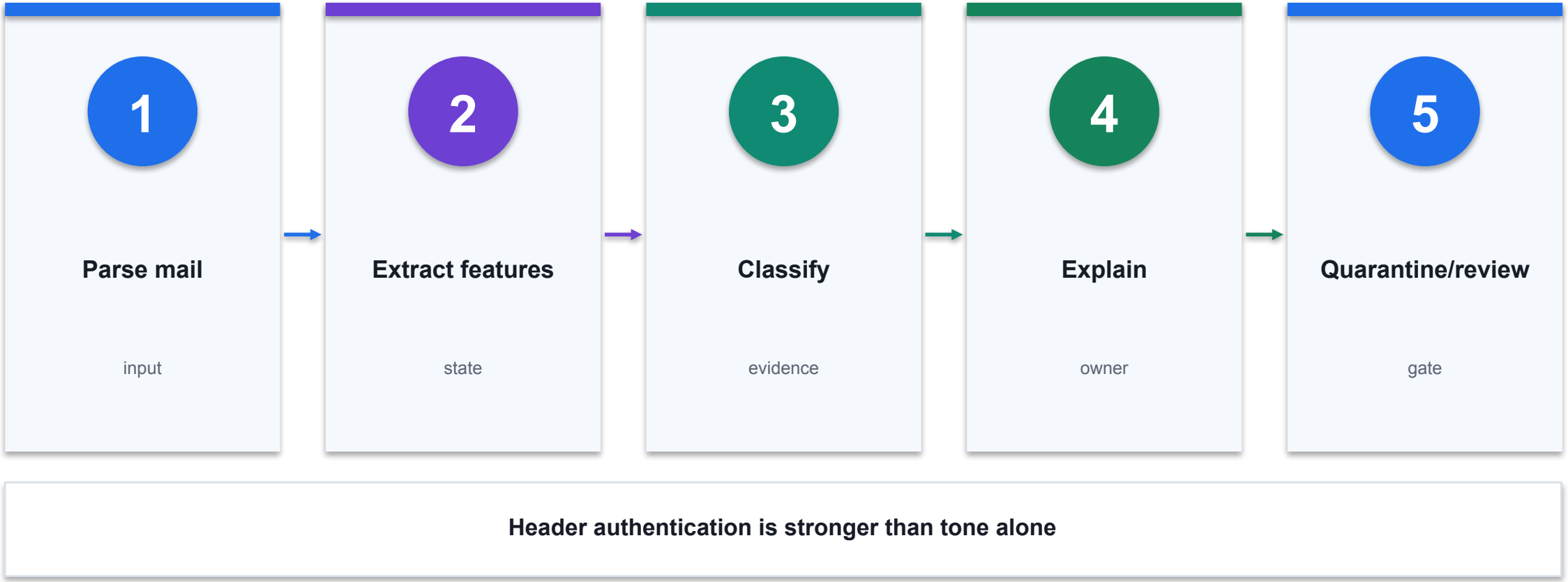
3 **Threshold**

Capacity and miss cost set the operating point.

4 **Review**

An analyst validates context and evidence.

Phishing detection combines header, URL and language evidence



FIELDS · FORMULAS · THRESHOLDS

Phishing detection combines header, URL and language evidence: concrete contract

```
CONTRACT

01   spf/dkim/dmarc result

02   reply_to mismatch

03   url_domain_age_days

04   language urgency score
```

1. Header authentication is stronger than tone alone
2. URL structure adds campaign signal
3. Text models require multilingual evaluation
4. Explanations should cite observed fields

ANALYSIS · TRADE-OFF · DECISION

Phishing detection combines header, URL and language evidence: decision model

Signal 1

Header authentication is stronger than tone alone

Signal 2

URL structure adds campaign signal

Signal 3

Text models require multilingual evaluation

Signal 4

Explanations should cite observed fields

THE DECISION RULE

Explanations should cite observed fields

Phishing detection combines header, URL and language evidence: failure and control

FAILURE MODES

- ! Attacker prompt text manipulates an LLM
- ! Legitimate urgent mail
- ! Image-only lure
- ! Domain reputation delay

CONTROL & EVIDENCE

- ✓ Evidence cites exact header/URL
- ✓ No auto-delete at low confidence
- ✓ False positives sampled weekly
- ✓ Protected sandbox for links

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Phishing detection combines header, URL and language evidence: verification evidence

Acceptance

Evidence cites exact header/URL

Trace

No auto-delete at low confidence

Review

False positives sampled weekly

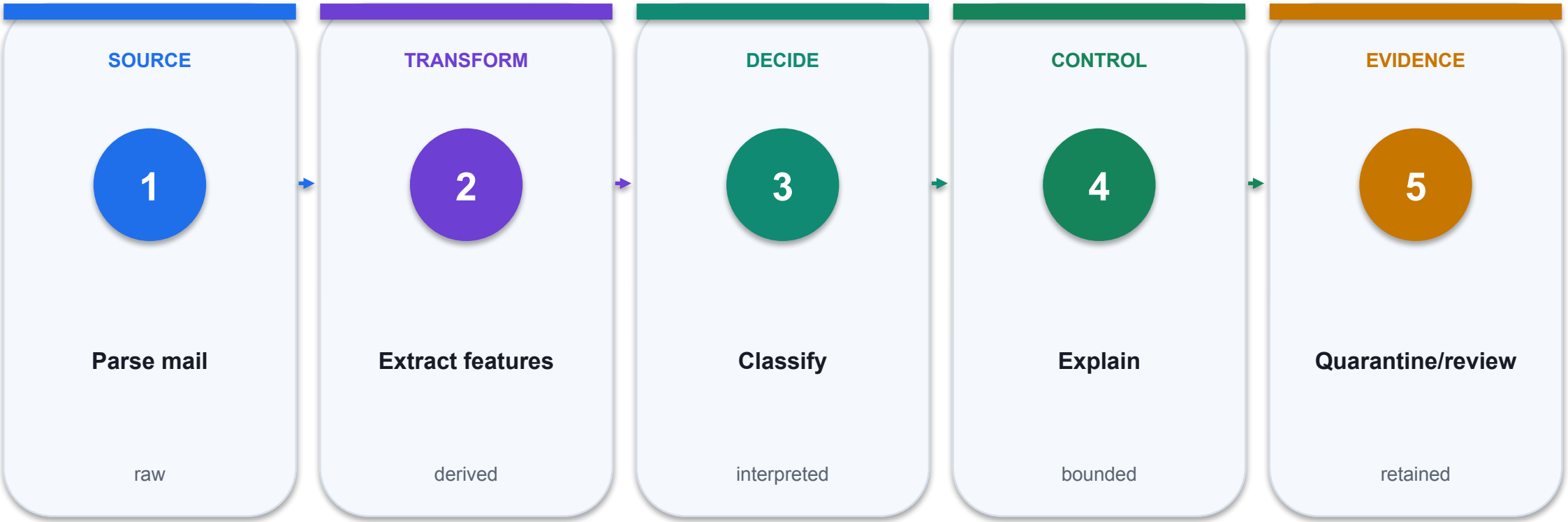
Operate

Protected sandbox for links

THE DECISION RULE

Lab 3 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Phishing detection combines header, URL and language evidence: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Phishing detection combines header, URL and language evidence: evidence artifact anatomy

ARTIFACT RECORD

01 spf/dkim/dmarc result

02 reply_to mismatch

03 url_domain_age_days

04 language urgency score

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Header authentication is stronger than tone alone**

Retain: Evidence cites exact header/URL

FIELD 2 — **URL structure adds campaign signal**

Retain: No auto-delete at low confidence

FIELD 3 — **Text models require multilingual evaluation**

Retain: False positives sampled weekly

FIELD 4 — **Explanations should cite observed fields**

Retain: Protected sandbox for links

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Phishing detection combines header, URL and language evidence: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
spf/dkim/dmarc result	Header authentication is stronger than tone alone	Attacker prompt text manipulates an LLM	Evidence cites exact header/URL
reply_to mismatch	URL structure adds campaign signal	Legitimate urgent mail	No auto-delete at low confidence
url_domain_age_days	Text models require multilingual evaluation	Image-only lure	False positives sampled weekly
language urgency score	Explanations should cite observed fields	Domain reputation delay	Protected sandbox for links

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Phishing detection combines header, URL and language evidence: control test design

T1

Attacker prompt text manipulates an LLM

Condition: spf/dkim/dmarc result

Pass evidence: Evidence cites exact header/URL

T2

Legitimate urgent mail

Condition: reply_to mismatch

Pass evidence: No auto-delete at low confidence

T3

Image-only lure

Condition: url_domain_age_days

Pass evidence: False positives sampled weekly

T4

Domain reputation delay

Condition: language urgency score

Pass evidence: Protected sandbox for links

Phishing detection combines header, URL and language evidence: operating trade-offs

CHOICE 1 **Header authentication is stronger than tone alone**

Trade-off: Attacker prompt text manipulates an LLM

Guardrail: Evidence cites exact header/URL

CHOICE 2 **URL structure adds campaign signal**

Trade-off: Legitimate urgent mail

rdrail: No auto-delete at low confidence

REVIEWED OPERATING POINT

CHOICE 3 **Text models require multilingual evaluation**

Trade-off: Image-only lure

Guardrail: False positives sampled weekly

CHOICE 4 **Explanations should cite observed fields**

Trade-off: Domain reputation delay

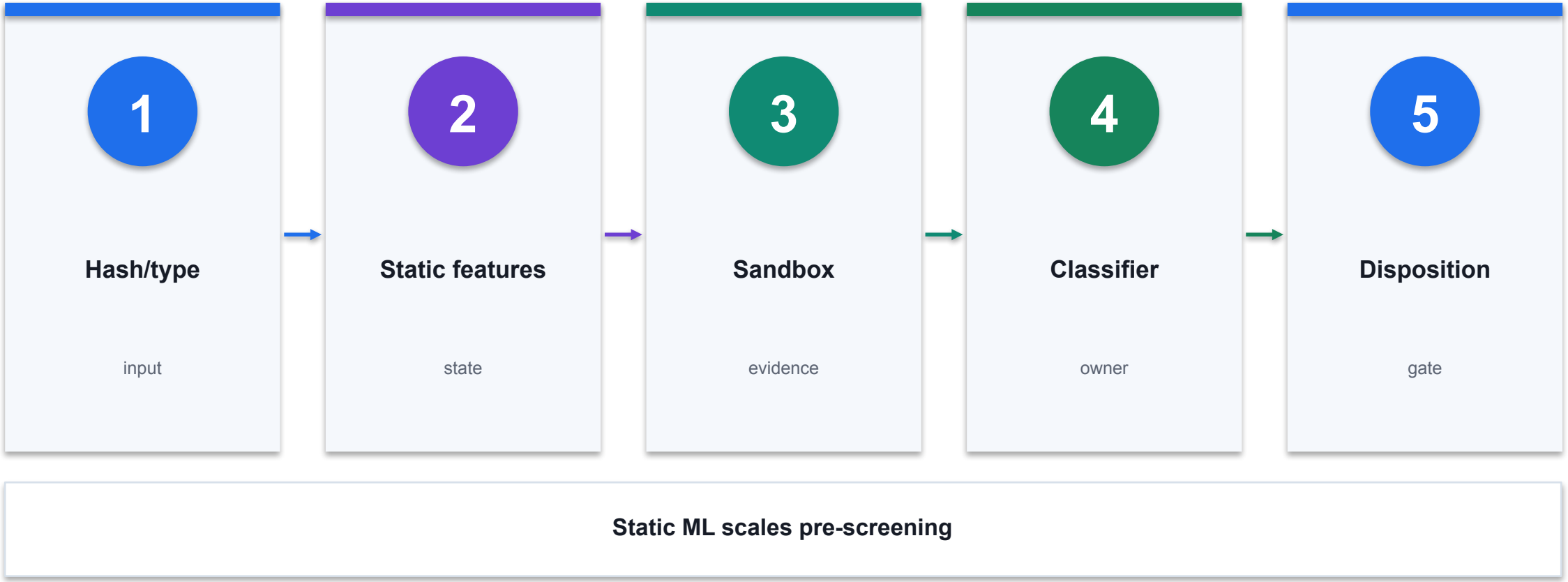
Guardrail: Protected sandbox for links

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Phishing detection combines header, URL and language evidence: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
spf/dkim/dmarc result	Attacker prompt text manipulates an LLM	**Header authentication is stronger than tone alone**	**Evidence cites exact header/URL**
reply_to mismatch	Legitimate urgent mail	**URL structure adds campaign signal**	**No auto-delete at low confidence**
url_domain_age_days	Image-only lure	**Text models require multilingual evaluation**	**False positives sampled weekly**
language urgency score	Domain reputation delay	**Explanations should cite observed fields**	**Protected sandbox for links**

Malware triage separates static signals from behavioural proof



FIELDS · FORMULAS · THRESHOLDS

Malware triage separates static signals from behavioural proof: concrete contract

```
CONTRACT

01   sha256 + file_type

02   imports/entropy/sections

03   process/network/file behaviours

04   family confidence + evidence
```

1. Static ML scales pre-screening
2. Behaviour reveals packed samples
3. Family labels are noisy
4. Unknown stays unknown

ANALYSIS · TRADE-OFF · DECISION

Malware triage separates static signals from behavioural proof: decision model

Signal 1

Static ML scales pre-screening

Signal 2

Behaviour reveals packed samples

Signal 3

Family labels are noisy

Signal 4

Unknown stays unknown

THE DECISION RULE

Unknown stays unknown

Malware triage separates static signals from behavioural proof: failure and control

FAILURE MODES

- ! Adversarial packing
- ! Sandbox evasion
- ! Training labels from one vendor
- ! Executing samples outside isolation

CONTROL & EVIDENCE

- ✓ No live malware in training
- ✓ Hash and provenance recorded
- ✓ Confidence threshold documented
- ✓ Analyst confirms containment

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Malware triage separates static signals from behavioural proof: verification evidence

Acceptance

No live malware in training

Trace

Hash and provenance recorded

Review

Confidence threshold documented

Operate

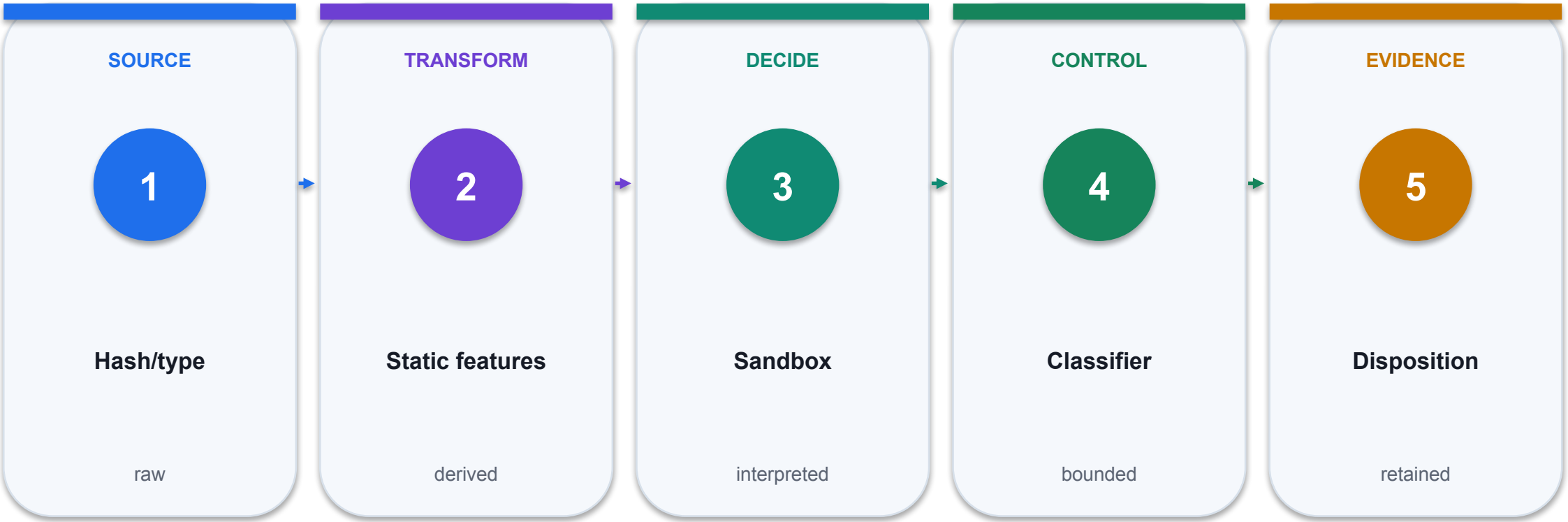
Analyst confirms containment

THE DECISION RULE

Lab 4 creates a reproducible artifact; detailed steps stay in the Learner Guide.

TRUST BOUNDARY · DATA FLOW · CONTROL OWNER

Malware triage separates static signals from behavioural proof: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Malware triage separates static signals from behavioural proof: evidence artifact anatomy

```
ARTIFACT RECORD

01    sha256 + file_type

02    imports/entropy/sections

03    process/network/file behaviours

04    family confidence + evidence

Immutable input reference · model/rule version · timestamp · named
reviewer
```

FIELD 1 — **Static ML scales pre-screening**

Retain: No live malware in training

FIELD 2 — **Behaviour reveals packed samples**

Retain: Hash and provenance recorded

FIELD 3 — **Family labels are noisy**

Retain: Confidence threshold documented

FIELD 4 — **Unknown stays unknown**

Retain: Analyst confirms containment

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Malware triage separates static signals from behavioural proof: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
sha256 + file_type	Static ML scales pre-screening	Adversarial packing	No live malware in training
imports/entropy/sections	Behaviour reveals packed samples	Sandbox evasion	Hash and provenance recorded
process/network/file behaviours	Family labels are noisy	Training labels from one vendor	Confidence threshold documented
family confidence + evidence	Unknown stays unknown	Executing samples outside isolation	Analyst confirms containment

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Malware triage separates static signals from behavioural proof: control test design

T1

Adversarial packing

Condition: sha256 + file_type

Pass evidence: No live malware in training

T2

Sandbox evasion

Condition: imports/entropy/sections

Pass evidence: Hash and provenance recorded

T3

Training labels from one vendor

Condition: process/network/file behaviours

Pass evidence: Confidence threshold documented

T4

Executing samples outside isolation

Condition: family confidence + evidence

Pass evidence: Analyst confirms containment

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Malware triage separates static signals from behavioural proof: operating trade-offs

CHOICE 1 **Static ML scales pre-screening**

Trade-off: Adversarial packing

Guardrail: No live malware in training

CHOICE 2 **Behaviour reveals packed samples**

Trade-off: Sandbox evasion

rdrail: Hash and provenance recorded

REVIEWED OPERATING POINT

CHOICE 3 **Family labels are noisy**

Trade-off: Training labels from one vendor

Guardrail: Confidence threshold documented

CHOICE 4 **Unknown stays unknown**

Trade-off: Executing samples outside isolation

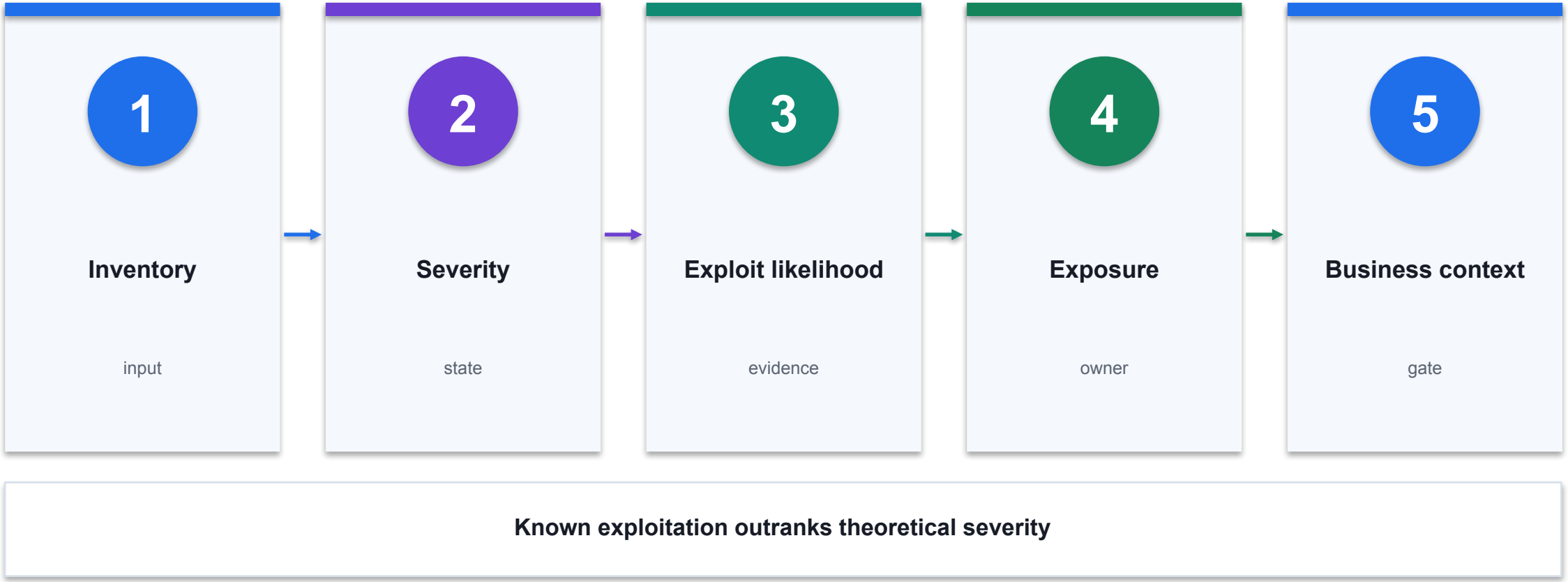
Guardrail: Analyst confirms containment

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Malware triage separates static signals from behavioural proof: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
sha256 + file_type	Adversarial packing	**Static ML scales pre-screening**	**No live malware in training**
imports/entropy/sections	Sandbox evasion	**Behaviour reveals packed samples**	**Hash and provenance recorded**
process/network/file behaviours	Training labels from one vendor	**Family labels are noisy**	**Confidence threshold documented**
family confidence + evidence	Executing samples outside isolation	**Unknown stays unknown**	**Analyst confirms containment**

Vulnerability prioritisation is a multi-signal ranking problem



FIELDS · FORMULAS · THRESHOLDS

Vulnerability prioritisation is a multi-signal ranking problem: concrete contract

```
CONTRACT

01   asset_id + owner

02   CVSS base/vector

03   EPSS probability

04   internet_exposed + compensating_control
```

1. Known exploitation outranks theoretical severity
2. Exposure time affects urgency
3. Compensating controls lower residual risk
4. AI summarises evidence; policy sets SLA

ANALYSIS · TRADE-OFF · DECISION

Vulnerability prioritisation is a multi-signal ranking problem: decision model

Signal 1

Known exploitation outranks theoretical severity

Signal 2

Exposure time affects urgency

Signal 3

Compensating controls lower residual risk

Signal 4

AI summarises evidence; policy sets SLA

THE DECISION RULE

AI summarises evidence; policy sets SLA

Vulnerability prioritisation is a multi-signal ranking problem: failure and control

FAILURE MODES

- ! Hallucinated CVE details
- ! Stale inventory
- ! Dependency not reachable
- ! SLA ignores business owner

CONTROL & EVIDENCE

- ✓ Source URL and retrieval date
- ✓ Reachability evidence
- ✓ Priority rationale stored
- ✓ SLA breach dashboard

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Vulnerability prioritisation is a multi-signal ranking problem: verification evidence

Acceptance

Source URL and retrieval date

Trace

Reachability evidence

Review

Priority rationale stored

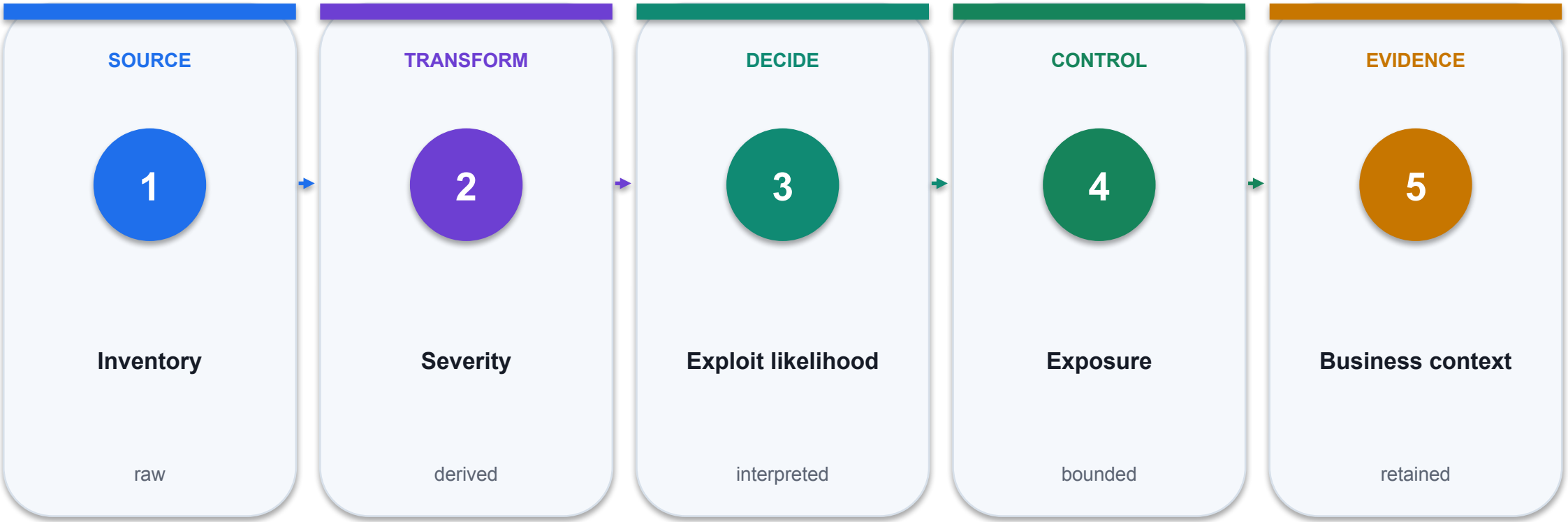
Operate

SLA breach dashboard

THE DECISION RULE

Lab 5 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Vulnerability prioritisation is a multi-signal ranking problem: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Vulnerability prioritisation is a multi-signal ranking problem: evidence artifact anatomy

ARTIFACT RECORD

01 asset_id + owner

02 CVSS base/vector

03 EPSS probability

04 internet_exposed + compensating_control

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Known exploitation outranks theoretical severity**

Retain: Source URL and retrieval date

FIELD 2 — **Exposure time affects urgency**

Retain: Reachability evidence

FIELD 3 — **Compensating controls lower residual risk**

Retain: Priority rationale stored

FIELD 4 — **AI summarises evidence; policy sets SLA**

Retain: SLA breach dashboard

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Vulnerability prioritisation is a multi-signal ranking problem: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
asset_id + owner	Known exploitation outranks theoretical severity	Hallucinated CVE details	Source URL and retrieval date
CVSS base/vector	Exposure time affects urgency	Stale inventory	Reachability evidence
EPSS probability	Compensating controls lower residual risk	Dependency not reachable	Priority rationale stored
internet_exposed + compensating_control	AI summarises evidence; policy sets SLA	SLA ignores business owner	SLA breach dashboard

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Vulnerability prioritisation is a multi-signal ranking problem: control test design

T1

Hallucinated CVE details

Condition: asset_id + owner

Pass evidence: Source URL and retrieval date

T2

Stale inventory

Condition: CVSS base/vector

Pass evidence: Reachability evidence

T3

Dependency not reachable

Condition: EPSS probability

Pass evidence: Priority rationale stored

T4

SLA ignores business owner

Condition: internet_exposed + compensating_control

Pass evidence: SLA breach dashboard

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Vulnerability prioritisation is a multi-signal ranking problem: operating trade-offs

CHOICE 1 **Known exploitation outranks theoretical severity**

Trade-off: Hallucinated CVE details

Guardrail: Source URL and retrieval date

CHOICE 2 **Exposure time affects urgency**

Trade-off: Stale inventory

rdrail: Reachability evidence

REVIEWED OPERATING POINT

CHOICE 3 **Compensating controls lower residual risk**

Trade-off: Dependency not reachable

Guardrail: Priority rationale stored

CHOICE 4 **AI summarises evidence; policy sets SLA**

Trade-off: SLA ignores business owner

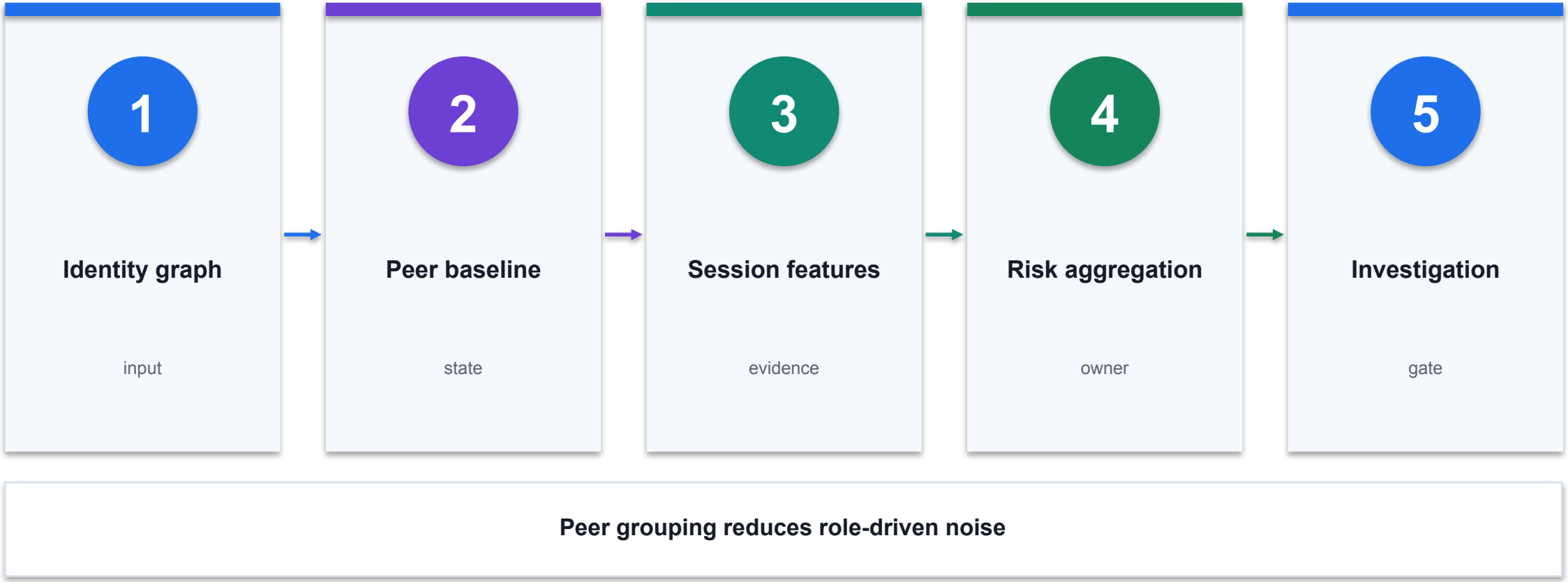
Guardrail: SLA breach dashboard

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Vulnerability prioritisation is a multi-signal ranking problem: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
asset_id + owner	Hallucinated CVE details	**Known exploitation outranks theoretical severity**	**Source URL and retrieval date**
CVSS base/vector	Stale inventory	**Exposure time affects urgency**	**Reachability evidence**
EPSS probability	Dependency not reachable	**Compensating controls lower residual risk**	**Priority rationale stored**
internet_exposed + compensating_control	SLA ignores business owner	**AI summarises evidence; policy sets SLA**	**SLA breach dashboard**

UEBA needs peer groups, identity joins and privacy controls



FIELDS · FORMULAS · THRESHOLDS

UEBA needs peer groups, identity joins and privacy controls: concrete contract

```
CONTRACT

01   principal.id + role

02   device.id + managed

03   geo_velocity_kmh

04   privilege_change + data_access
```

1. Peer grouping reduces role-driven noise
2. Risk accumulates across weak signals
3. Identity resolution precedes analytics
4. Privacy purpose limits remain

ANALYSIS · TRADE-OFF · DECISION

UEBA needs peer groups, identity joins and privacy controls: decision model

Signal 1

Peer grouping reduces role-driven noise

Signal 2

Risk accumulates across weak signals

Signal 3

Identity resolution precedes analytics

Signal 4

Privacy purpose limits remain

THE DECISION RULE

Privacy purpose limits remain

UEBA needs peer groups, identity joins and privacy controls: failure and control

FAILURE MODES

- ! Shared accounts
- ! Role change not reflected
- ! Bias against remote workers
- ! Excessive employee surveillance

CONTROL & EVIDENCE

- ✓ Purpose documented
- ✓ Access restricted
- ✓ Appeal/correction route
- ✓ Alert evidence reproducible

EVIDENCE · ACCEPTANCE · LAB BRIDGE

UEBA needs peer groups, identity joins and privacy controls: verification evidence

Acceptance

Purpose documented

Trace

Access restricted

Review

Appeal/correction route

Operate

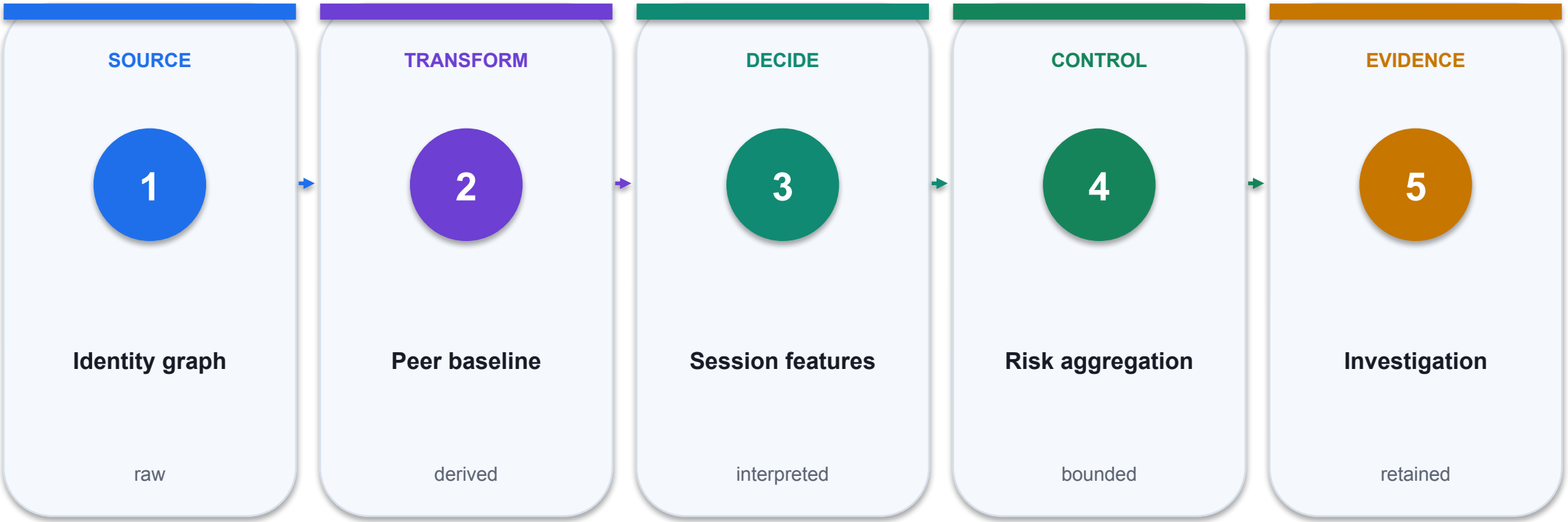
Alert evidence reproducible

THE DECISION RULE

Lab 2 creates a reproducible artifact; detailed steps stay in the Learner Guide.

TRUST BOUNDARY · DATA FLOW · CONTROL OWNER

UEBA needs peer groups, identity joins and privacy controls: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

UEBA needs peer groups, identity joins and privacy controls: evidence artifact anatomy

```
ARTIFACT RECORD

01    principal.id + role

02    device.id + managed

03    geo_velocity_kmh

04    privilege_change + data_access

Immutable input reference · model/rule version · timestamp · named
reviewer
```

FIELD 1 — **Peer grouping reduces role-driven noise**

Retain: Purpose documented

FIELD 2 — **Risk accumulates across weak signals**

Retain: Access restricted

FIELD 3 — **Identity resolution precedes analytics**

Retain: Appeal/correction route

FIELD 4 — **Privacy purpose limits remain**

Retain: Alert evidence reproducible

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

UEBA needs peer groups, identity joins and privacy controls: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
principal.id + role	Peer grouping reduces role-driven noise	Shared accounts	Purpose documented
device.id + managed	Risk accumulates across weak signals	Role change not reflected	Access restricted
geo_velocity_kmh	Identity resolution precedes analytics	Bias against remote workers	Appeal/correction route
privilege_change + data_access	Privacy purpose limits remain	Excessive employee surveillance	Alert evidence reproducible

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

UEBA needs peer groups, identity joins and privacy controls: control test design

T1

Shared accounts

Condition: principal.id + role

Pass evidence: Purpose documented

T2

Role change not reflected

Condition: device.id + managed

Pass evidence: Access restricted

T3

Bias against remote workers

Condition: geo_velocity_kmh

Pass evidence: Appeal/correction route

T4

Excessive employee surveillance

Condition: privilege_change + data_access

Pass evidence: Alert evidence reproducible

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

UEBA needs peer groups, identity joins and privacy controls: operating trade-offs

CHOICE 1 **Peer grouping reduces role-driven noise**

Trade-off: Shared accounts

Guardrail: Purpose documented

CHOICE 2 **Risk accumulates across weak signals**

Trade-off: Role change not reflected

rdrail: Access restricted

REVIEWED OPERATING POINT

CHOICE 3 **Identity resolution precedes analytics**

Trade-off: Bias against remote workers

Guardrail: Appeal/correction route

CHOICE 4 **Privacy purpose limits remain**

Trade-off: Excessive employee surveillance

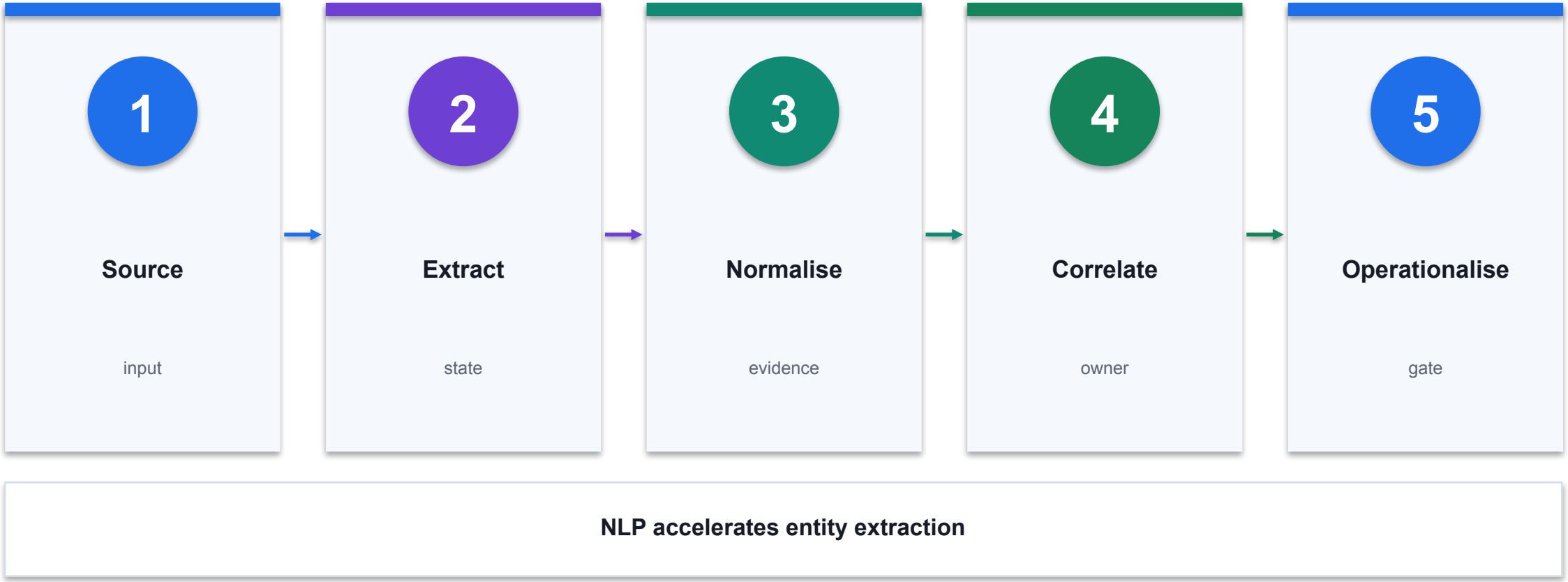
Guardrail: Alert evidence reproducible

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

UEBA needs peer groups, identity joins and privacy controls: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
principal.id + role	Shared accounts	**Peer grouping reduces role-driven noise**	**Purpose documented**
device.id + managed	Role change not reflected	**Risk accumulates across weak signals**	**Access restricted**
geo_velocity_kmh	Bias against remote workers	**Identity resolution precedes analytics**	**Appeal/correction route**
privilege_change + data_access	Excessive employee surveillance	**Privacy purpose limits remain**	**Alert evidence reproducible**

Threat-intelligence extraction produces structured, confidence-scored objects



FIELDS · FORMULAS · THRESHOLDS

Threat-intelligence extraction produces structured, confidence-scored objects: concrete contract

```
CONTRACT

01  indicator.type/value

02  valid_from/valid_until

03  confidence 0-100

04  source + relationship
```

1. NLP accelerates entity extraction
2. STIX-like structure enables joins
3. Confidence depends on source and corroboration
4. Expiry prevents permanent blocks

ANALYSIS · TRADE-OFF · DECISION

Threat-intelligence extraction produces structured, confidence-scored objects: decision model

Signal 1

NLP accelerates entity extraction

Signal 2

STIX-like structure enables joins

Signal 3

Confidence depends on source and corroboration

Signal 4

Expiry prevents permanent blocks

THE DECISION RULE

Expiry prevents permanent blocks

Threat-intelligence extraction produces structured, confidence-scored objects: failure and control

FAILURE MODES

- ! Defanged indicators parsed wrongly
- ! Duplicate aliases
- ! Untrusted report instructions
- ! IOC without context

CONTROL & EVIDENCE

- ✓ Schema validation
- ✓ Provenance retained
- ✓ Human approves blocking
- ✓ Expired indicators removed

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Threat-intelligence extraction produces structured, confidence-scored objects: verification evidence

Acceptance

Schema validation

Trace

Provenance retained

Review

Human approves blocking

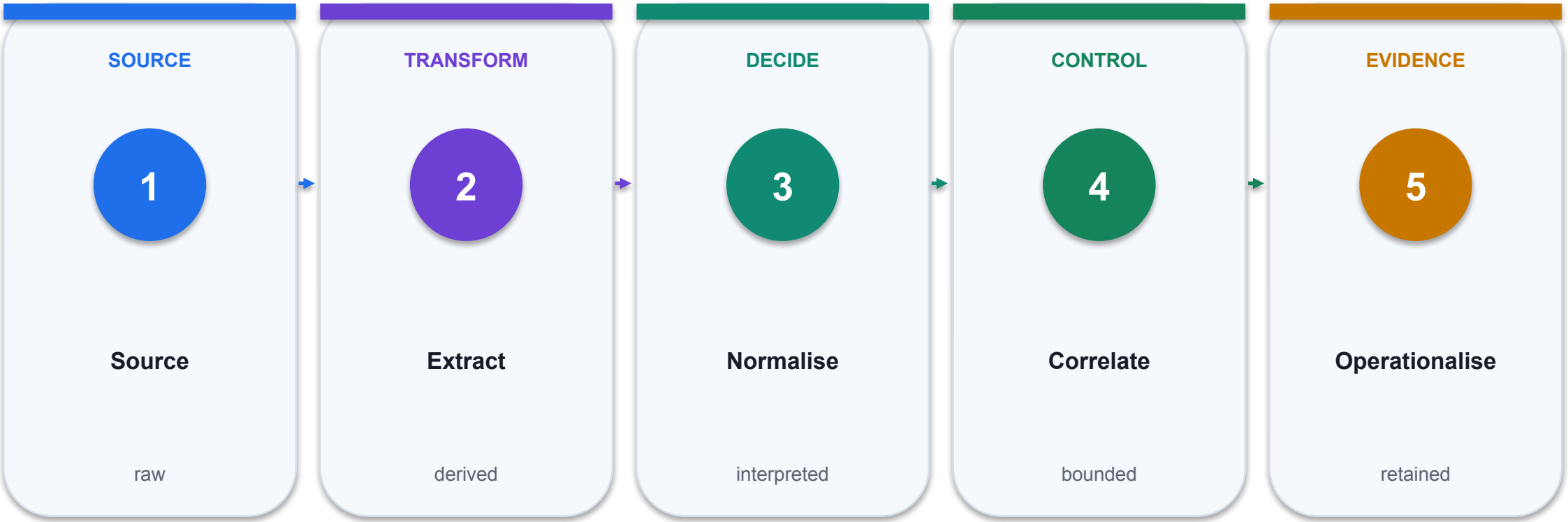
Operate

Expired indicators removed

THE DECISION RULE

Lab 6 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Threat-intelligence extraction produces structured, confidence-scored objects: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Threat-intelligence extraction produces structured, confidence-scored objects: evidence artifact anatomy

ARTIFACT RECORD

01 indicator.type/value

02 valid_from/valid_until

03 confidence 0-100

04 source + relationship

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **NLP accelerates entity extraction**

Retain: Schema validation

FIELD 2 — **STIX-like structure enables joins**

Retain: Provenance retained

FIELD 3 — **Confidence depends on source and corroboration**

Retain: Human approves blocking

FIELD 4 — **Expiry prevents permanent blocks**

Retain: Expired indicators removed

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Threat-intelligence extraction produces structured, confidence-scored objects: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
indicator.type/value	NLP accelerates entity extraction	Defanged indicators parsed wrongly	Schema validation
valid_from/valid_until	STIX-like structure enables joins	Duplicate aliases	Provenance retained
confidence 0-100	Confidence depends on source and corroboration	Untrusted report instructions	Human approves blocking
source + relationship	Expiry prevents permanent blocks	IOC without context	Expired indicators removed

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Threat-intelligence extraction produces structured, confidence-scored objects: control test design

T1

Defanged indicators parsed wrongly

Condition: indicator.type/value

Pass evidence: Schema validation

T2

Duplicate aliases

Condition: valid_from/valid_until

Pass evidence: Provenance retained

T3

Untrusted report instructions

Condition: confidence 0-100

Pass evidence: Human approves blocking

T4

IOC without context

Condition: source + relationship

Pass evidence: Expired indicators removed

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Threat-intelligence extraction produces structured, confidence-scored objects: operating trade-offs

CHOICE 1 NLP accelerates entity extraction

Trade-off: Defanged indicators parsed wrongly

Guardrail: Schema validation

CHOICE 2 STIX-like structure enables joins

Trade-off: Duplicate aliases

rdrail: Provenance retained

REVIEWED OPERATING POINT

CHOICE 3 Confidence depends on source and corroboration

Trade-off: Untrusted report instructions

Guardrail: Human approves blocking

CHOICE 4 Expiry prevents permanent blocks

Trade-off: IOC without context

Guardrail: Expired indicators removed

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Threat-intelligence extraction produces structured, confidence-scored objects: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
indicator.type/value	Defanged indicators parsed wrongly	**NLP accelerates entity extraction**	**Schema validation**
valid_from/valid_until	Duplicate aliases	**STIX-like structure enables joins**	**Provenance retained**
confidence 0-100	Untrusted report instructions	**Confidence depends on source and corroboration**	**Human approves blocking**
source + relationship	IOC without context	**Expiry prevents permanent blocks**	**Expired indicators removed**

Lab 1: Build an AI-Assisted Cyber Risk Register

Join asset criticality, threat likelihood, control effectiveness and evidence into a transparent residual-risk ranking.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 1

risk_register.csv and risk_summary.json with traceable scoring rationale.

Python 3 · CSV · JSON · Cybersecurity Threat Simulation Lab · steps in Learner Guide and individual lab folder

ACCEPTANCE CRITERIA · FAILURE DIAGNOSIS

Lab 1 verification: prove the control works

- ✓ All rows have owner and evidence_ref
- ✓ Residual scores are 0-25
- ✓ Ranking changes when asset criticality changes
- ✓ Output JSON records the scoring formula

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

Lab 2: Detect Authentication Anomalies

Create a peer-aware anomaly score from failed logins, new-device state and impossible-travel indicators.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 2

anomalies.csv and threshold-decision.md.

Python 3 · pandas · scikit-learn · FauxBank Cybersecurity Training Simulation · steps in Learner Guide and individual lab folder

Lab 2 verification: prove the control works

- ✓ Model trained only on baseline rows
- ✓ Output includes anomaly_score and reason fields
- ✓ Queue has at most three alerts
- ✓ Threshold and model random_state are recorded

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

Lab 3: Explain a Phishing Risk Score

Combine email authentication, reply-to mismatch, URL and language features into an explainable phishing triage score.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 3

phishing_triage.csv with evidence-based reason codes.

Python 3 · pandas · Cybersecurity Threat Simulation Lab · steps in Learner Guide and individual lab folder

Lab 3 verification: prove the control works

- ✓ **No raw email body leaves the lab**
- ✓ **Every score has at least one reason code**
- ✓ **Low-confidence mail is review-only**
- ✓ **Thresholds are documented**

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

HANDS-ON · LO1

Lab 4: Prioritise Vulnerabilities with Context

Rank vulnerabilities using severity, exploit likelihood, exposure, asset criticality and compensating controls.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 4

prioritised_vulnerabilities.csv and sla-rationale.md.

Python 3 · pandas · Hacklab: Ethical Hacking Lab Simulator · steps in Learner Guide and individual lab folder

ACCEPTANCE CRITERIA · FAILURE DIAGNOSIS

Lab 4 verification: prove the control works

- ✓ CVSS and EPSS remain separate fields
- ✓ Internet exposure changes priority
- ✓ Every row keeps source and retrieval_date
- ✓ SLA is policy-derived

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

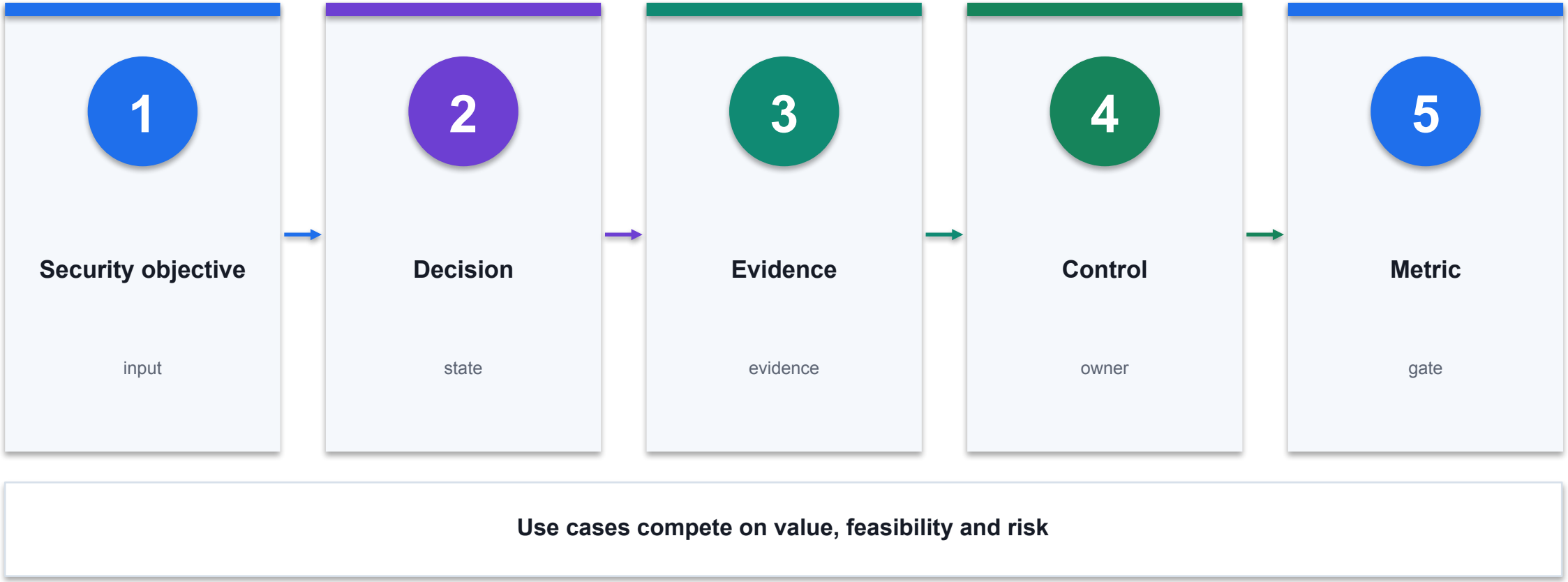
TOPIC 2 · LO2

Designing AI-Powered Cybersecurity Programmes

Objectives · use-case selection · governance · human oversight · operating model



Programme design starts with an outcome, not an AI product



FIELDS · FORMULAS · THRESHOLDS

Programme design starts with an outcome, not an AI product: concrete contract

```
CONTRACT

01   problem statement

02   decision owner

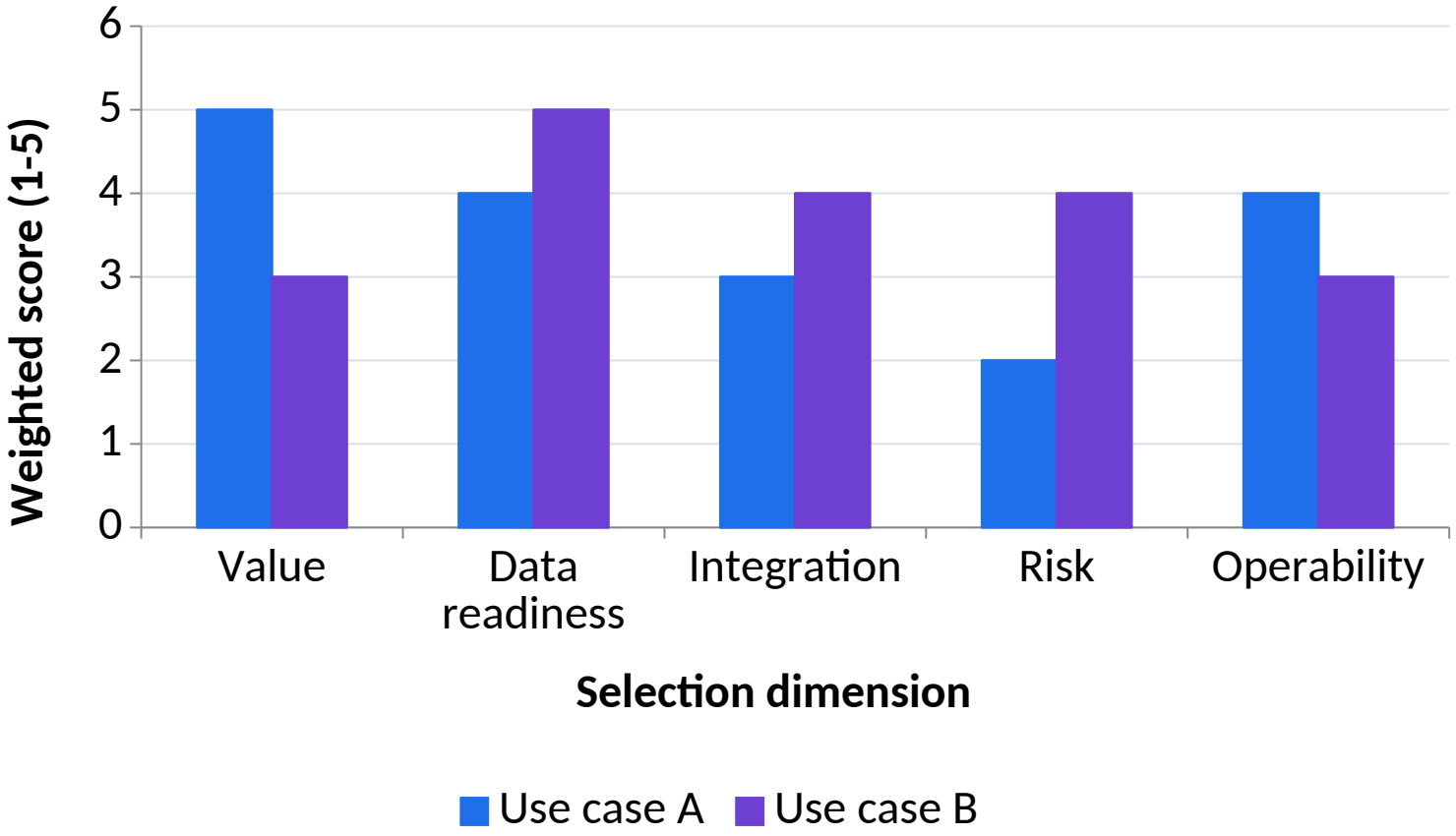
03   baseline + target

04   automation ceiling
```

1. Use cases compete on value, feasibility and risk
2. Baseline defines improvement
3. Decision rights prevent shadow automation
4. Kill criteria stop sunk-cost escalation

EDITABLE POWERPOINT CHART · INDICATIVE DATA

Programme design starts with an outcome, not an AI product: evidence chart



WHAT THE DATA SHOWS

A high-value idea can still rank second when data, integration, and operating risk are included.

Indicative figures - validate on local data.

Programme design starts with an outcome, not an AI product: failure and control

FAILURE MODES

- ! Technology-first purchase
- ! No measurable baseline
- ! Unowned alerts
- ! Pilot becomes production silently

CONTROL & EVIDENCE

- ✓ Named owner
- ✓ Baseline frozen
- ✓ Success/stop thresholds
- ✓ Review date

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Programme design starts with an outcome, not an AI product: verification evidence

Acceptance

Named owner

Trace

Baseline frozen

Review

Success/stop thresholds

Operate

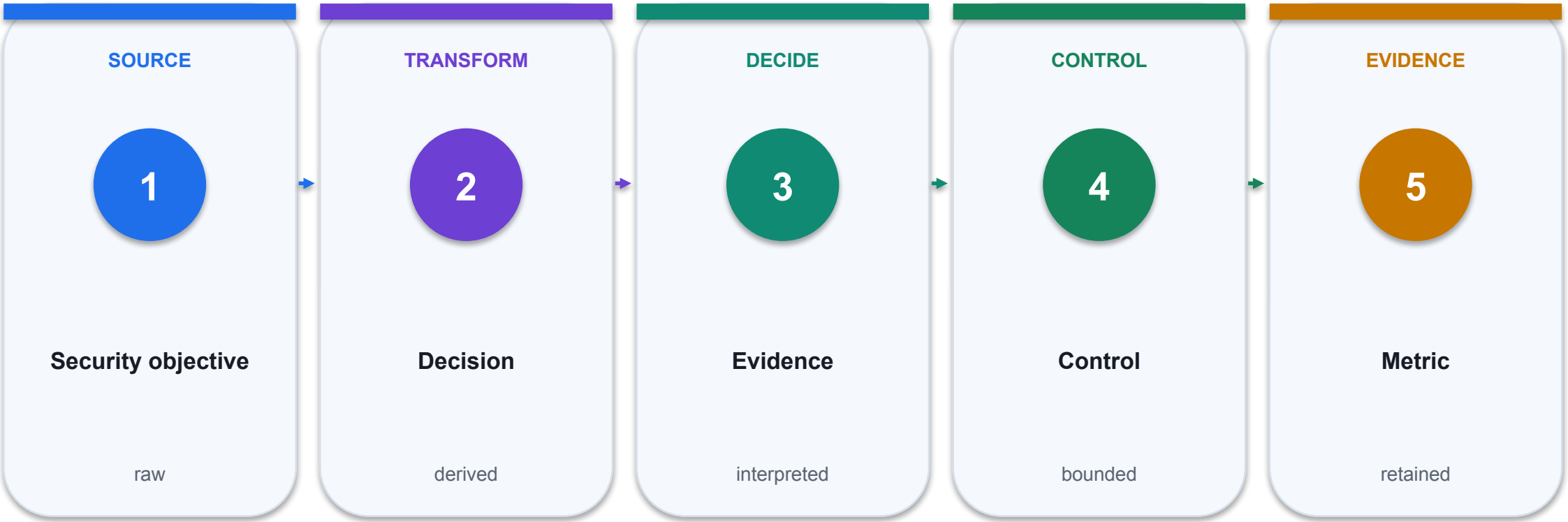
Review date

THE DECISION RULE

Lab 7 creates a reproducible artifact; detailed steps stay in the Learner Guide.

TRUST BOUNDARY · DATA FLOW · CONTROL OWNER

Programme design starts with an outcome, not an AI product: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Programme design starts with an outcome, not an AI product: evidence artifact anatomy

ARTIFACT RECORD

01 problem statement

02 decision owner

03 baseline + target

04 automation ceiling

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Use cases compete on value, feasibility and risk**

Retain: Named owner

FIELD 2 — **Baseline defines improvement**

Retain: Baseline frozen

FIELD 3 — **Decision rights prevent shadow automation**

Retain: Success/stop thresholds

FIELD 4 — **Kill criteria stop sunk-cost escalation**

Retain: Review date

Programme design starts with an outcome, not an AI product: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
problem statement	Use cases compete on value, feasibility and risk	Technology-first purchase	Named owner
decision owner	Baseline defines improvement	No measurable baseline	Baseline frozen
baseline + target	Decision rights prevent shadow automation	Unowned alerts	Success/stop thresholds
automation ceiling	Kill criteria stop sunk-cost escalation	Pilot becomes production silently	Review date

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Programme design starts with an outcome, not an AI product: control test design

T1

Technology-first purchase

Condition: problem statement

Pass evidence: Named owner

T2

No measurable baseline

Condition: decision owner

Pass evidence: Baseline frozen

T3

Unowned alerts

Condition: baseline + target

Pass evidence: Success/stop thresholds

T4

Pilot becomes production silently

Condition: automation ceiling

Pass evidence: Review date

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Programme design starts with an outcome, not an AI product: operating trade-offs

CHOICE 1 **Use cases compete on value, feasibility and risk**

Trade-off: Technology-first purchase

Guardrail: Named owner

CHOICE 2 **Baseline defines improvement**

Trade-off: No measurable baseline

Guardrail: Baseline frozen

REVIEWED OPERATING POINT

CHOICE 3 **Decision rights prevent shadow automation**

Trade-off: Unowned alerts

Guardrail: Success/stop thresholds

CHOICE 4 **Kill criteria stop sunk-cost escalation**

Trade-off: Pilot becomes production silently

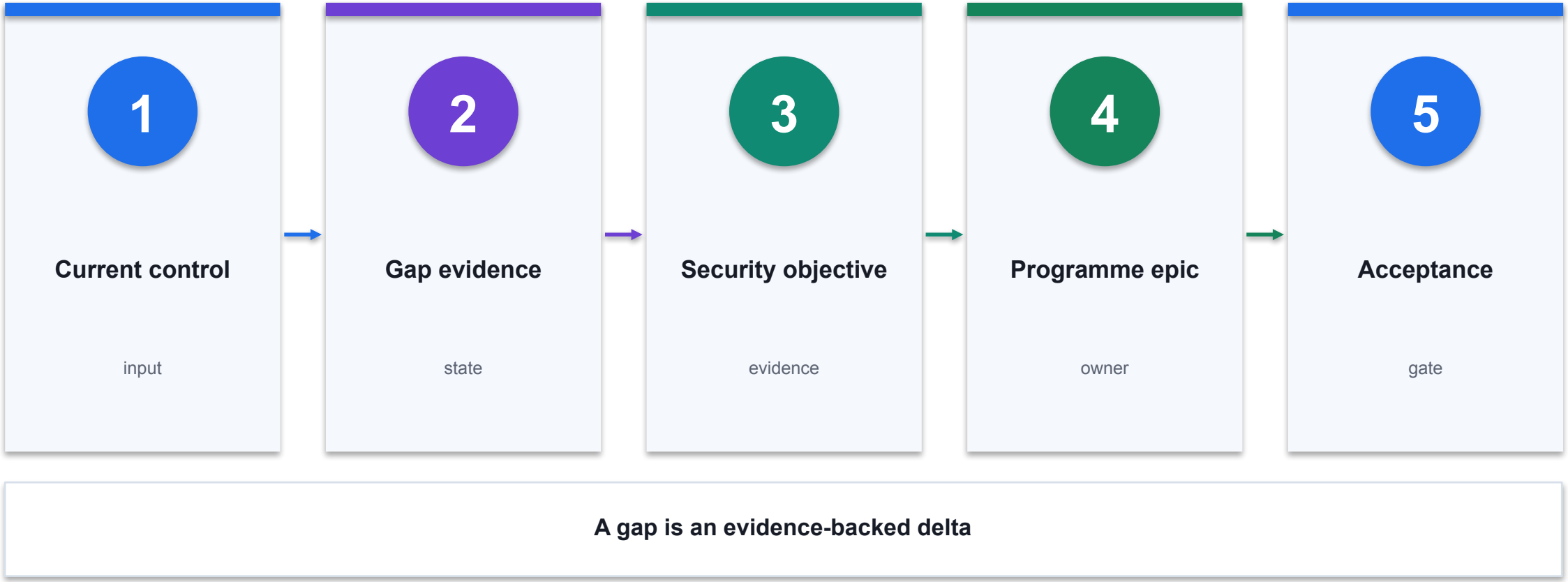
Guardrail: Review date

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Programme design starts with an outcome, not an AI product: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
problem statement	Technology-first purchase	**Use cases compete on value, feasibility and risk**	**Named owner**
decision owner	No measurable baseline	**Baseline defines improvement**	**Baseline frozen**
baseline + target	Unowned alerts	**Decision rights prevent shadow automation**	**Success/stop thresholds**
automation ceiling	Pilot becomes production silently	**Kill criteria stop sunk-cost escalation**	**Review date**

Control gaps translate into programme epics and guardrails



Control gaps translate into programme epics and guardrails: concrete contract

```
CONTRACT

01  control_id

02  current_state/evidence

03  target_state

04  owner/milestone/dependency
```

1. A gap is an evidence-backed delta
2. Objectives state the desired security outcome
3. Epics group related controls
4. Acceptance criteria remain testable

ANALYSIS · TRADE-OFF · DECISION

Control gaps translate into programme epics and guardrails: decision model

Signal 1

A gap is an evidence-backed delta

Signal 2

Objectives state the desired security outcome

Signal 3

Epics group related controls

Signal 4

Acceptance criteria remain testable

THE DECISION RULE

Acceptance criteria remain testable

Control gaps translate into programme epics and guardrails: failure and control

FAILURE MODES

- ! Vague 'improve security' objective
- ! AI invents missing evidence
- ! Control owner excluded
- ! No dependency map

CONTROL & EVIDENCE

- ✓ Gap references audit/log
- ✓ Target has date
- ✓ Owner accepts scope
- ✓ Test plan exists

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Control gaps translate into programme epics and guardrails: verification evidence

Acceptance

Gap references audit/log

Trace

Target has date

Review

Owner accepts scope

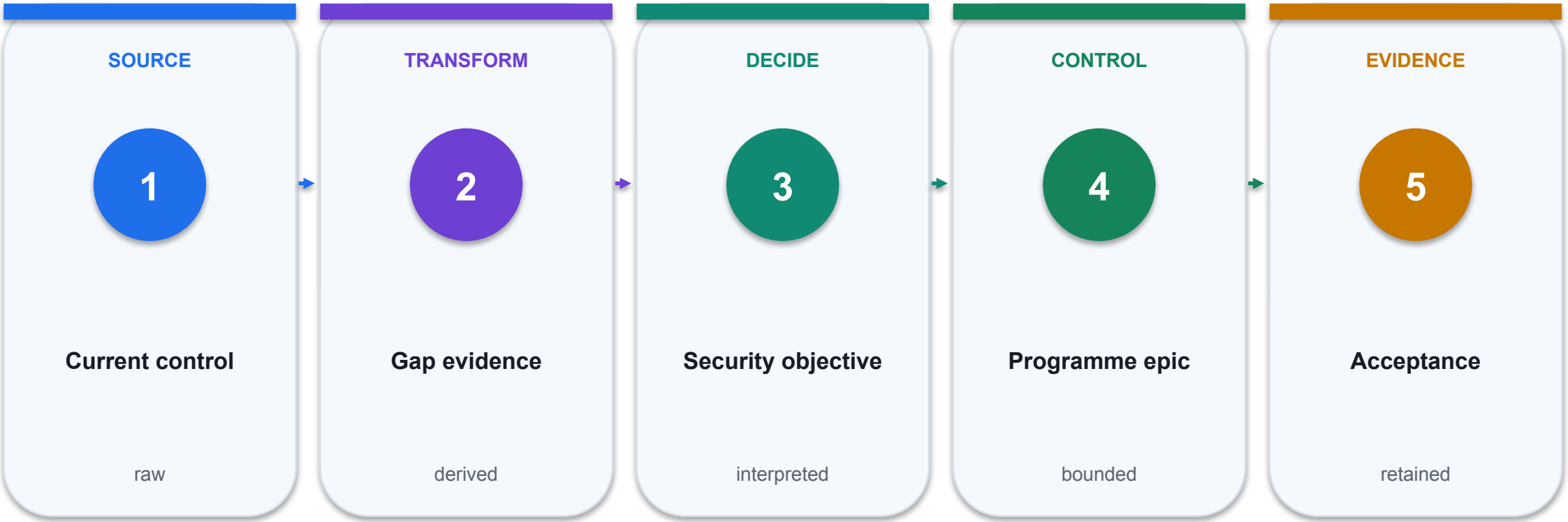
Operate

Test plan exists

THE DECISION RULE

Lab 7 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Control gaps translate into programme epics and guardrails: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Control gaps translate into programme epics and guardrails: evidence artifact anatomy

ARTIFACT RECORD

01 control_id

02 current_state/evidence

03 target_state

04 owner/milestone/dependency

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **A gap is an evidence-backed delta**

Retain: Gap references audit/log

FIELD 2 — **Objectives state the desired security outcome**

Retain: Target has date

FIELD 3 — **Epics group related controls**

Retain: Owner accepts scope

FIELD 4 — **Acceptance criteria remain testable**

Retain: Test plan exists

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Control gaps translate into programme epics and guardrails: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
control_id	A gap is an evidence-backed delta	Vague 'improve security' objective	Gap references audit/log
current_state/evidence	Objectives state the desired security outcome	AI invents missing evidence	Target has date
target_state	Epics group related controls	Control owner excluded	Owner accepts scope
owner/milestone/dependency	Acceptance criteria remain testable	No dependency map	Test plan exists

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Control gaps translate into programme epics and guardrails: control test design

T1

Vague 'improve security' objective

Condition: control_id

Pass evidence: Gap references audit/log

T2

AI invents missing evidence

Condition: current_state/evidence

Pass evidence: Target has date

T3

Control owner excluded

Condition: target_state

Pass evidence: Owner accepts scope

T4

No dependency map

Condition: owner/milestone/dependency

Pass evidence: Test plan exists

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Control gaps translate into programme epics and guardrails: operating trade-offs

CHOICE 1 **A gap is an evidence-backed delta**

Trade-off: Vague 'improve security' objective

Guardrail: Gap references audit/log

CHOICE 2 **Objectives state the desired security outcome**

Trade-off: AI invents missing evidence

rdrail: Target has date

REVIEWED OPERATING POINT

CHOICE 3 **Epics group related controls**

Trade-off: Control owner excluded

Guardrail: Owner accepts scope

CHOICE 4 **Acceptance criteria remain testable**

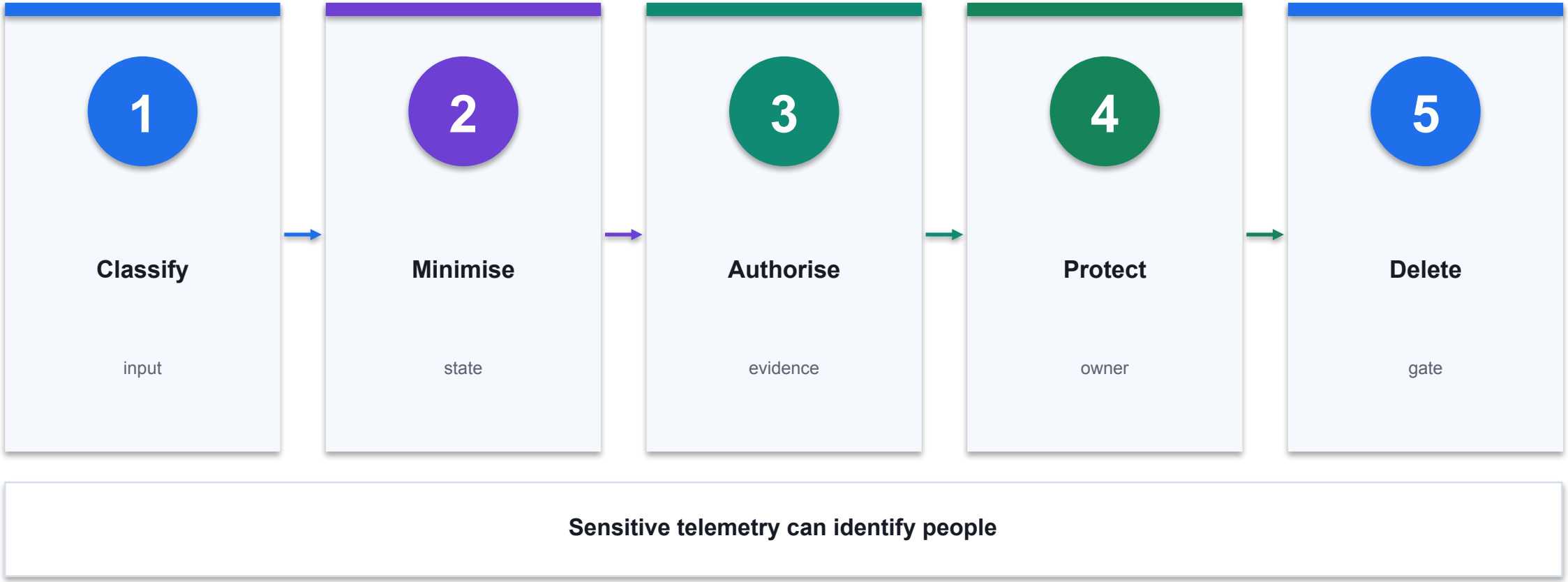
Trade-off: No dependency map

Guardrail: Test plan exists

Control gaps translate into programme epics and guardrails: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
control_id	Vague 'improve security' objective	**A gap is an evidence-backed delta**	**Gap references audit/log**
current_state/evidence	AI invents missing evidence	**Objectives state the desired security outcome**	**Target has date**
target_state	Control owner excluded	**Epics group related controls**	**Owner accepts scope**
owner/milestone/dependency	No dependency map	**Acceptance criteria remain testable**	**Test plan exists**

Data governance is part of the security control plane



FIELDS · FORMULAS · THRESHOLDS

Data governance is part of the security control plane: concrete contract

```
CONTRACT

01  data class

02  allowed purpose

03  retention

04  region

05  model/provider use
```

1. Sensitive telemetry can identify people
2. Prompts are data transfers
3. Training use must be explicit
4. Deletion must cover caches and indexes

ANALYSIS · TRADE-OFF · DECISION

Data governance is part of the security control plane: decision model

Signal 1

Sensitive telemetry can identify people

Signal 2

Prompts are data transfers

Signal 3

Training use must be explicit

Signal 4

Deletion must cover caches and indexes

THE DECISION RULE

Deletion must cover caches and indexes

Data governance is part of the security control plane: failure and control

FAILURE MODES

- ! Secrets in prompts
- ! Unbounded retention
- ! Cross-border transfer
- ! Vendor trains on customer data

CONTROL & EVIDENCE

- ✓ DLP test
- ✓ Access log
- ✓ Deletion evidence
- ✓ Vendor contract control

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Data governance is part of the security control plane: verification evidence

Acceptance

DLP test

Trace

Access log

Review

Deletion evidence

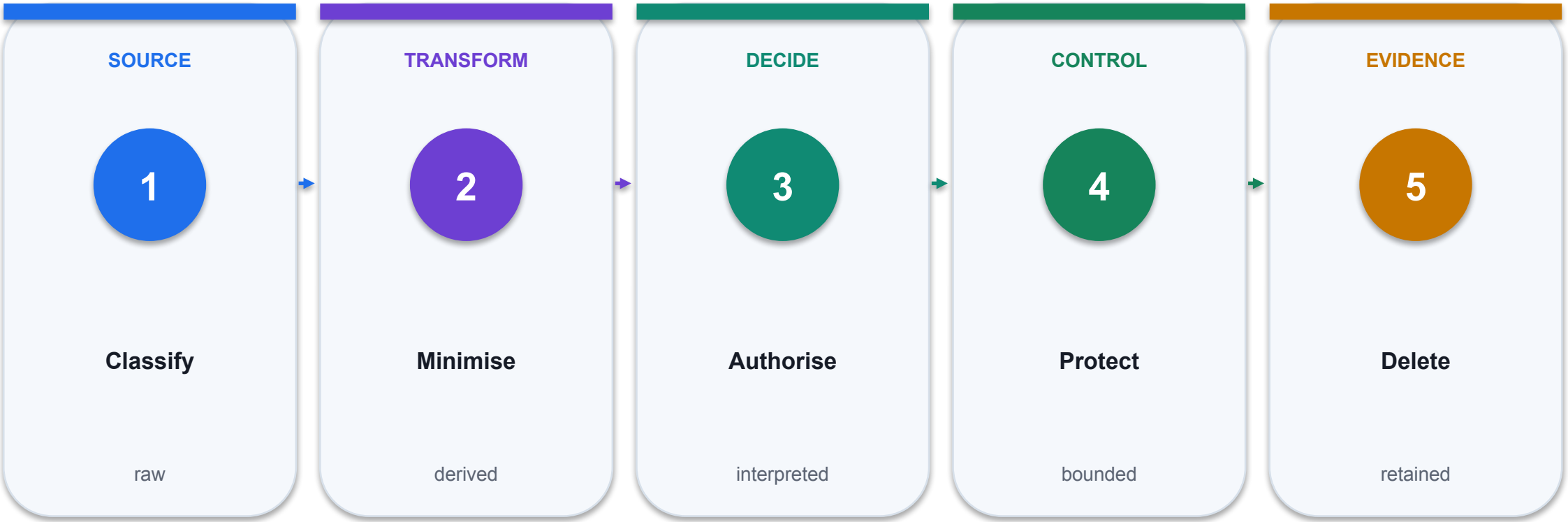
Operate

Vendor contract control

THE DECISION RULE

Lab 8 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Data governance is part of the security control plane: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Data governance is part of the security control plane: evidence artifact anatomy



FIELD 1 — **Sensitive telemetry can identify people**

Retain: DLP test

FIELD 2 — **Prompts are data transfers**

Retain: Access log

FIELD 3 — **Training use must be explicit**

Retain: Deletion evidence

FIELD 4 — **Deletion must cover caches and indexes**

Retain: Vendor contract control

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Data governance is part of the security control plane: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
data class	Sensitive telemetry can identify people	Secrets in prompts	DLP test
allowed purpose	Prompts are data transfers	Unbounded retention	Access log
retention	Training use must be explicit	Cross-border transfer	Deletion evidence
region	Deletion must cover caches and indexes	Vendor trains on customer data	Vendor contract control

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Data governance is part of the security control plane: control test design

T1

Secrets in prompts

Condition: data class

Pass evidence: DLP test

T2

Unbounded retention

Condition: allowed purpose

Pass evidence: Access log

T3

Cross-border transfer

Condition: retention

Pass evidence: Deletion evidence

T4

Vendor trains on customer data

Condition: region

Pass evidence: Vendor contract control

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Data governance is part of the security control plane: operating trade-offs

CHOICE 1 **Sensitive telemetry can identify people**

Trade-off: Secrets in prompts

Guardrail: DLP test

CHOICE 2 **Prompts are data transfers**

Trade-off: Unbounded retention

rdrail: Access log

REVIEWED OPERATING POINT

CHOICE 3 **Training use must be explicit**

Trade-off: Cross-border transfer

Guardrail: Deletion evidence

CHOICE 4 **Deletion must cover caches and indexes**

Trade-off: Vendor trains on customer data

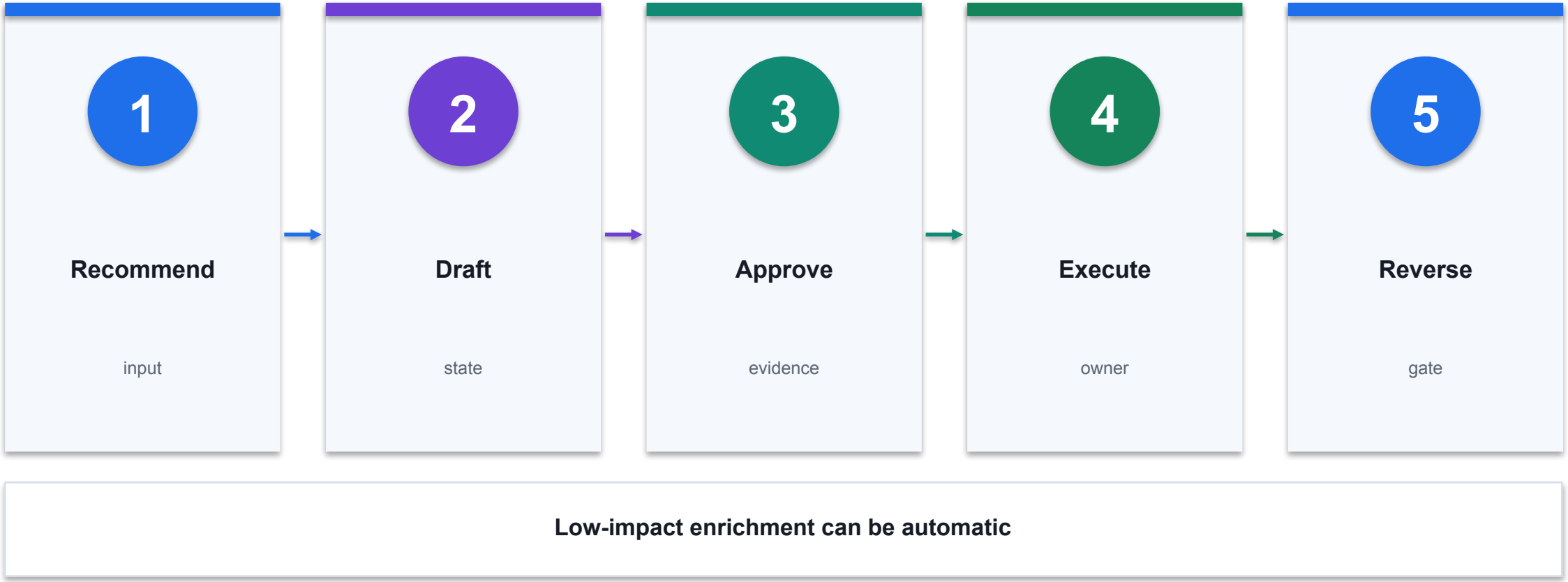
Guardrail: Vendor contract control

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Data governance is part of the security control plane: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
data class	Secrets in prompts	**Sensitive telemetry can identify people**	**DLP test**
allowed purpose	Unbounded retention	**Prompts are data transfers**	**Access log**
retention	Cross-border transfer	**Training use must be explicit**	**Deletion evidence**
region	Vendor trains on customer data	**Deletion must cover caches and indexes**	**Vendor contract control**

Automation levels define where humans must decide



Automation levels define where humans must decide: concrete contract

```
CONTRACT

01   confidence threshold

02   action allow-list

03   approval role

04   rollback command
```

1. Low-impact enrichment can be automatic
2. Containment needs bounded targets
3. High-impact identity actions need approval
4. Reversibility lowers operational risk

ANALYSIS · TRADE-OFF · DECISION

Automation levels define where humans must decide: decision model

Signal 1

Low-impact enrichment can be automatic

Signal 2

Containment needs bounded targets

Signal 3

High-impact identity actions need approval

Signal 4

Reversibility lowers operational risk

THE DECISION RULE

Reversibility lowers operational risk

Automation levels define where humans must decide: failure and control

FAILURE MODES

- ! Model blocks a critical account
- ! Approval fatigue
- ! No rollback
- ! Action scope expands via tool permissions

CONTROL & EVIDENCE

- ✓ Dry-run default
- ✓ Two-person approval for destructive action
- ✓ Full audit trail
- ✓ Quarterly access review

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Automation levels define where humans must decide: verification evidence

Acceptance

Dry-run default

Trace

Two-person approval for destructive action

Review

Full audit trail

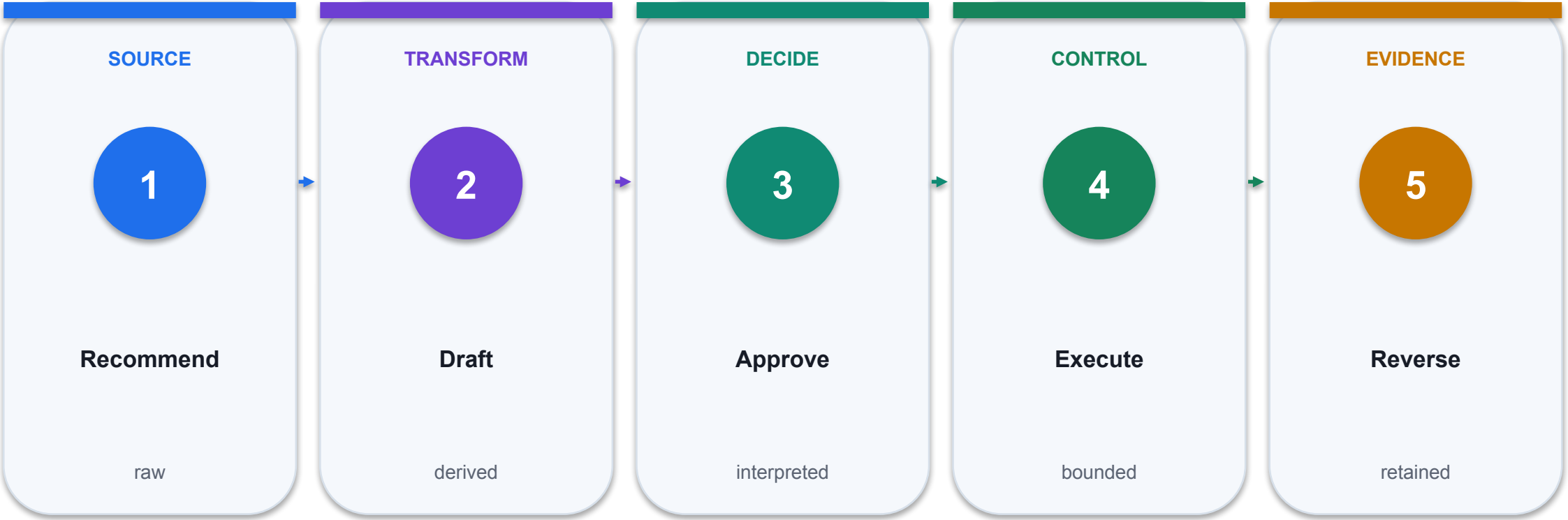
Operate

Quarterly access review

THE DECISION RULE

Lab 9 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Automation levels define where humans must decide: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

Automation levels define where humans must decide: evidence artifact anatomy

ARTIFACT RECORD

01 confidence threshold

02 action allow-list

03 approval role

04 rollback command

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Low-impact enrichment can be automatic**

Retain: Dry-run default

FIELD 2 — **Containment needs bounded targets**

Retain: Two-person approval for destructive action

FIELD 3 — **High-impact identity actions need approval**

Retain: Full audit trail

FIELD 4 — **Reversibility lowers operational risk**

Retain: Quarterly access review

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Automation levels define where humans must decide: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
confidence threshold	Low-impact enrichment can be automatic	Model blocks a critical account	Dry-run default
action allow-list	Containment needs bounded targets	Approval fatigue	Two-person approval for destructive action
approval role	High-impact identity actions need approval	No rollback	Full audit trail
rollback command	Reversibility lowers operational risk	Action scope expands via tool permissions	Quarterly access review

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Automation levels define where humans must decide: control test design

T1

Model blocks a critical account

Condition: confidence threshold

Pass evidence: Dry-run default

T2

Approval fatigue

Condition: action allow-list

Pass evidence: Two-person approval for destructive action

T3

No rollback

Condition: approval role

Pass evidence: Full audit trail

T4

Action scope expands via tool permissions

Condition: rollback command

Pass evidence: Quarterly access review

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Automation levels define where humans must decide: operating trade-offs

CHOICE 1 **Low-impact enrichment can be automatic**

Trade-off: Model blocks a critical account

Guardrail: Dry-run default

CHOICE 2 **Containment needs bounded targets**

Trade-off: Approval fatigue

Guardrail: Two-person approval for destructive action

REVIEWED OPERATING POINT

CHOICE 3 **High-impact identity actions need approval**

Trade-off: No rollback

Guardrail: Full audit trail

CHOICE 4 **Reversibility lowers operational risk**

Trade-off: Action scope expands via tool permissions

Guardrail: Quarterly access review

Automation levels define where humans must decide: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
confidence threshold	Model blocks a critical account	**Low-impact enrichment can be automatic**	**Dry-run default**
action allow-list	Approval fatigue	**Containment needs bounded targets**	**Two-person approval for destructive action**
approval role	No rollback	**High-impact identity actions need approval**	**Full audit trail**
rollback command	Action scope expands via tool permissions	**Reversibility lowers operational risk**	**Quarterly access review**

IMAGEGEN VISUAL · EDITABLE ANNOTATIONS

Human approval gates high-impact AI actions



1 **Input**

Classified, minimised evidence.

2 **Inference**

Versioned score and reasons.

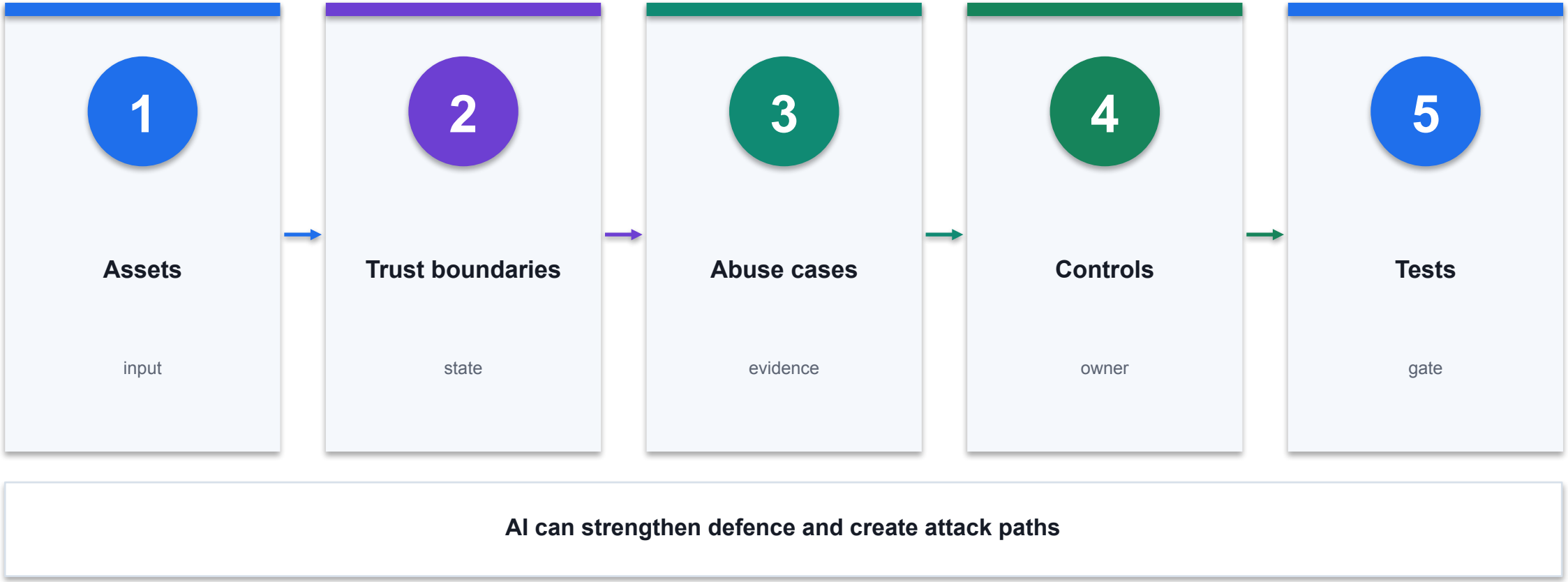
3 **Approval**

Named role reviews scope and impact.

4 **Action**

Bounded execution with rollback.

Threat modelling covers both AI use and the AI system



FIELDS · FORMULAS · THRESHOLDS

Threat modelling covers both AI use and the AI system: concrete contract

```
CONTRACT

01  model/data/tool identities

02  prompt/retrieval/tool boundaries

03  STRIDE + ATLAS techniques

04  security test case
```

1. AI can strengthen defence and create attack paths
2. Tool permissions are a primary boundary
3. Indirect prompt injection travels through content
4. Model supply chain needs provenance

ANALYSIS · TRADE-OFF · DECISION

Threat modelling covers both AI use and the AI system: decision model

Signal 1

AI can strengthen defence and create attack paths

Signal 2

Tool permissions are a primary boundary

Signal 3

Indirect prompt injection travels through content

Signal 4

Model supply chain needs provenance

THE DECISION RULE

Model supply chain needs provenance

Threat modelling covers both AI use and the AI system: failure and control

FAILURE MODES

- ! Prompt injection
- ! Training-data poisoning
- ! Model theft
- ! Unsafe tool invocation

CONTROL & EVIDENCE

- ✓ Abuse case mapped
- ✓ Control owner
- ✓ Test evidence
- ✓ Residual risk accepted

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Threat modelling covers both AI use and the AI system: verification evidence

Acceptance

Abuse case mapped

Trace

Control owner

Review

Test evidence

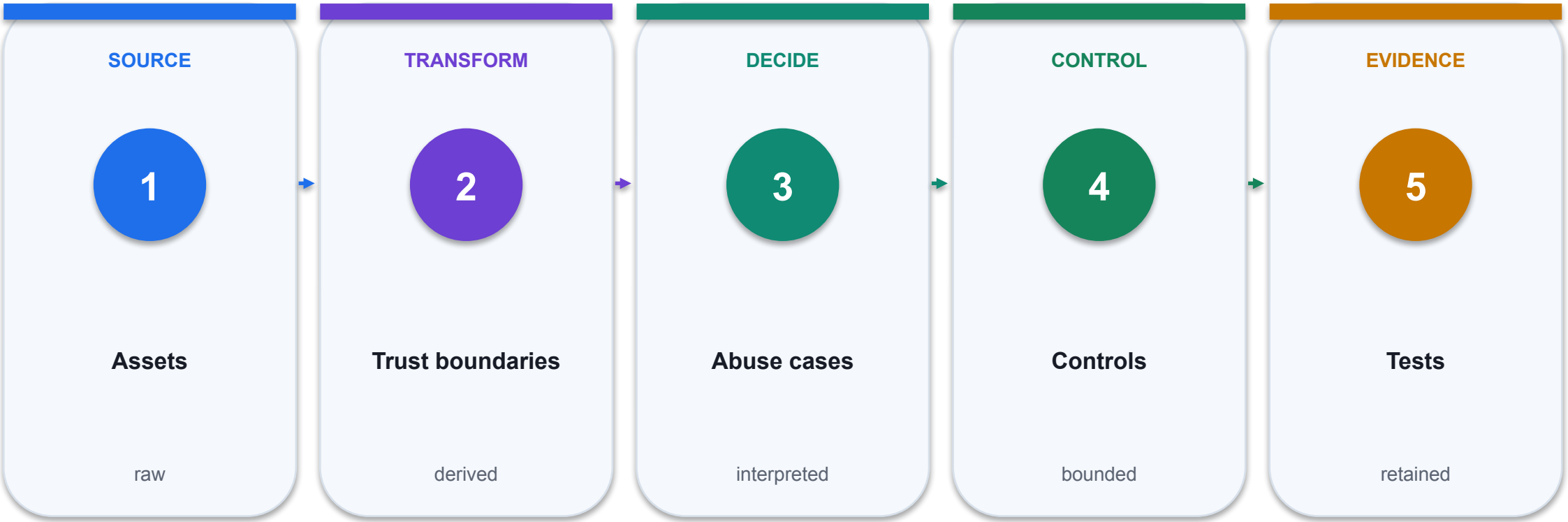
Operate

Residual risk accepted

THE DECISION RULE

Lab 8 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Threat modelling covers both AI use and the AI system: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

Threat modelling covers both AI use and the AI system: evidence artifact anatomy

ARTIFACT RECORD

01 model/data/tool identities

02 prompt/retrieval/tool boundaries

03 STRIDE + ATLAS techniques

04 security test case

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **AI can strengthen defence and create attack paths**

Retain: Abuse case mapped

FIELD 2 — **Tool permissions are a primary boundary**

Retain: Control owner

FIELD 3 — **Indirect prompt injection travels through content**

Retain: Test evidence

FIELD 4 — **Model supply chain needs provenance**

Retain: Residual risk accepted

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Threat modelling covers both AI use and the AI system: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
model/data/tool identities	AI can strengthen defence and create attack paths	Prompt injection	Abuse case mapped
prompt/retrieval/tool boundaries	Tool permissions are a primary boundary	Training-data poisoning	Control owner
STRIDE + ATLAS techniques	Indirect prompt injection travels through content	Model theft	Test evidence
security test case	Model supply chain needs provenance	Unsafe tool invocation	Residual risk accepted

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Threat modelling covers both AI use and the AI system: control test design

T1

Prompt injection

Condition: model/data/tool identities

Pass evidence: Abuse case mapped

T2

Training-data poisoning

Condition: prompt/retrieval/tool boundaries

Pass evidence: Control owner

T3

Model theft

Condition: STRIDE + ATLAS techniques

Pass evidence: Test evidence

T4

Unsafe tool invocation

Condition: security test case

Pass evidence: Residual risk accepted

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Threat modelling covers both AI use and the AI system: operating trade-offs

CHOICE 1 AI can strengthen defence and create attack paths

Trade-off: Prompt injection

Guardrail: Abuse case mapped

CHOICE 2 Tool permissions are a primary boundary

Trade-off: Training-data poisoning

rdrail: Control owner

REVIEWED OPERATING POINT

CHOICE 3 Indirect prompt injection travels through content

Trade-off: Model theft

Guardrail: Test evidence

CHOICE 4 Model supply chain needs provenance

Trade-off: Unsafe tool invocation

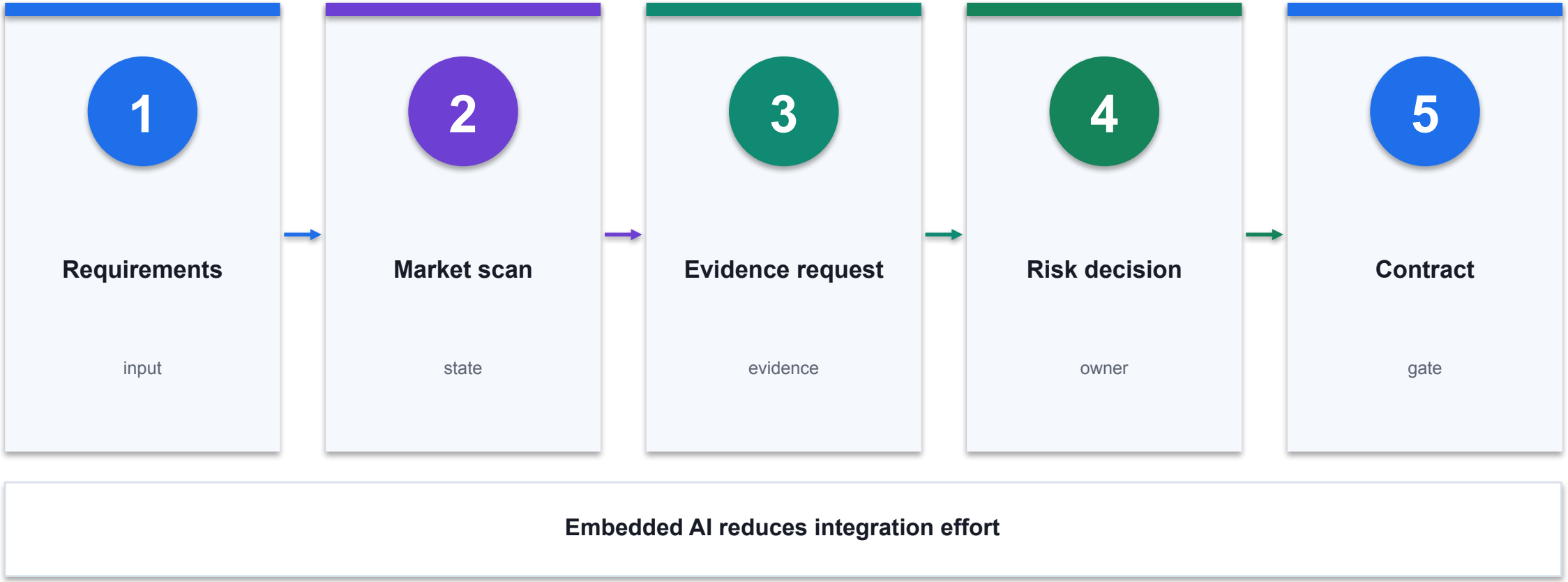
Guardrail: Residual risk accepted

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Threat modelling covers both AI use and the AI system: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
model/data/tool identities	Prompt injection	**AI can strengthen defence and create attack paths**	**Abuse case mapped**
prompt/retrieval/tool boundaries	Training-data poisoning	**Tool permissions are a primary boundary**	**Control owner**
STRIDE + ATLAS techniques	Model theft	**Indirect prompt injection travels through content**	**Test evidence**
security test case	Unsafe tool invocation	**Model supply chain needs provenance**	**Residual risk accepted**

Build-versus-buy decisions depend on control and evidence



FIELDS · FORMULAS · THRESHOLDS

Build-versus-buy decisions depend on control and evidence: concrete contract

```
CONTRACT

01   data use/retention

02   model update notice

03   tenant isolation

04   incident notification
```

1. Embedded AI reduces integration effort
2. Custom models increase ownership burden
3. Benchmarks must match local data
4. Exit plans prevent lock-in

ANALYSIS · TRADE-OFF · DECISION

Build-versus-buy decisions depend on control and evidence: decision model

Signal 1

Embedded AI reduces integration effort

Signal 2

Custom models increase ownership burden

Signal 3

Benchmarks must match local data

Signal 4

Exit plans prevent lock-in

THE DECISION RULE

Exit plans prevent lock-in

Build-versus-buy decisions depend on control and evidence: failure and control

FAILURE MODES

- ! Benchmark without dataset details
- ! No audit logs
- ! Unannounced model changes
- ! Provider dependency

CONTROL & EVIDENCE

- ✓ Proof-of-value dataset
- ✓ Security questionnaire
- ✓ Contractual controls
- ✓ Export/delete test

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Build-versus-buy decisions depend on control and evidence: verification evidence

Acceptance

Proof-of-value dataset

Trace

Security questionnaire

Review

Contractual controls

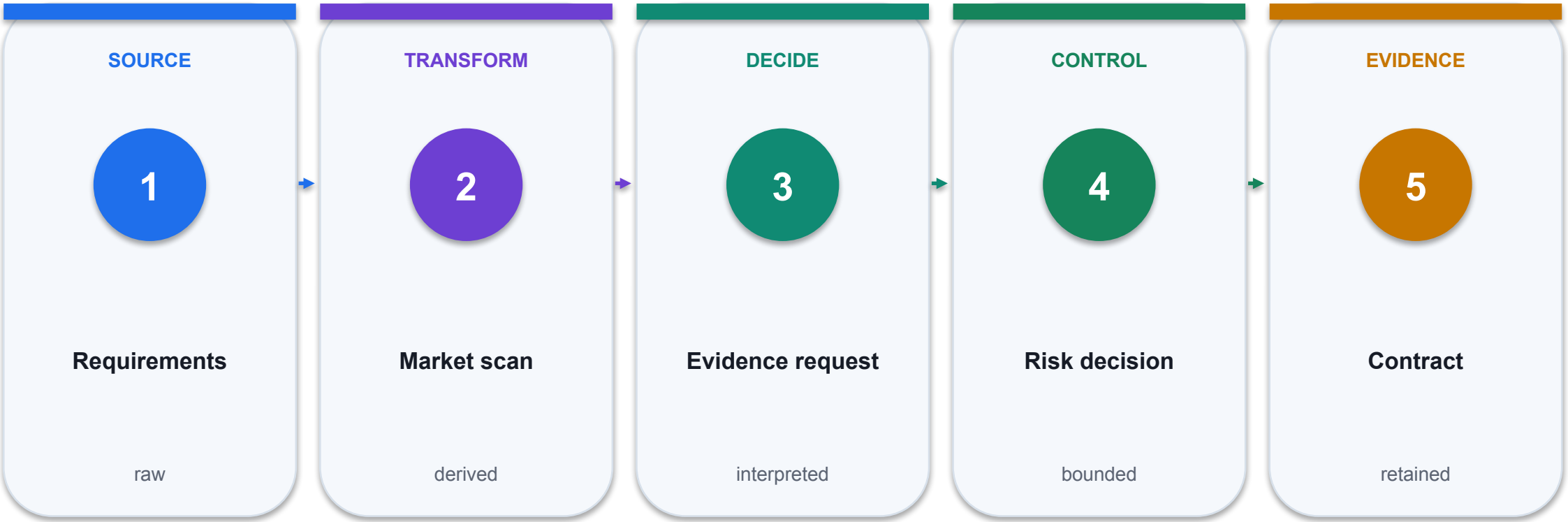
Operate

Export/delete test

THE DECISION RULE

Lab 8 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Build-versus-buy decisions depend on control and evidence: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Build-versus-buy decisions depend on control and evidence: evidence artifact anatomy

ARTIFACT RECORD

01 data use/retention

02 model update notice

03 tenant isolation

04 incident notification

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Embedded AI reduces integration effort**

Retain: Proof-of-value dataset

FIELD 2 — **Custom models increase ownership burden**

Retain: Security questionnaire

FIELD 3 — **Benchmarks must match local data**

Retain: Contractual controls

FIELD 4 — **Exit plans prevent lock-in**

Retain: Export/delete test

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Build-versus-buy decisions depend on control and evidence: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
data use/retention	Embedded AI reduces integration effort	Benchmark without dataset details	Proof-of-value dataset
model update notice	Custom models increase ownership burden	No audit logs	Security questionnaire
tenant isolation	Benchmarks must match local data	Unannounced model changes	Contractual controls
incident notification	Exit plans prevent lock-in	Provider dependency	Export/delete test

Build-versus-buy decisions depend on control and evidence: control test design

T1

Benchmark without dataset details

Condition: data use/retention

Pass evidence: Proof-of-value dataset

T2

No audit logs

Condition: model update notice

Pass evidence: Security questionnaire

T3

Unannounced model changes

Condition: tenant isolation

Pass evidence: Contractual controls

T4

Provider dependency

Condition: incident notification

Pass evidence: Export/delete test

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Build-versus-buy decisions depend on control and evidence: operating trade-offs

CHOICE 1 **Embedded AI reduces integration effort**

Trade-off: Benchmark without dataset details

Guardrail: Proof-of-value dataset

CHOICE 2 **Custom models increase ownership burden**

Trade-off: No audit logs

rdrail: Security questionnaire

REVIEWED OPERATING POINT

CHOICE 3 **Benchmarks must match local data**

Trade-off: Unannounced model changes

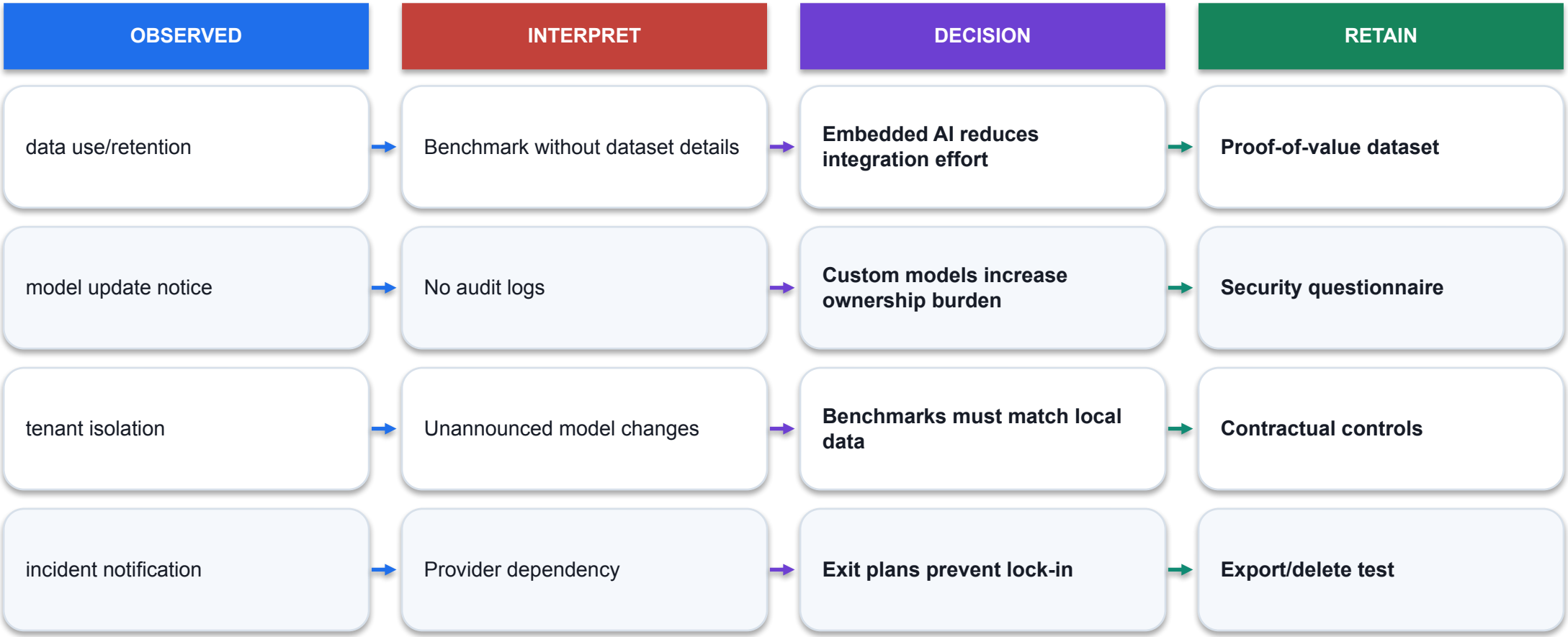
Guardrail: Contractual controls

CHOICE 4 **Exit plans prevent lock-in**

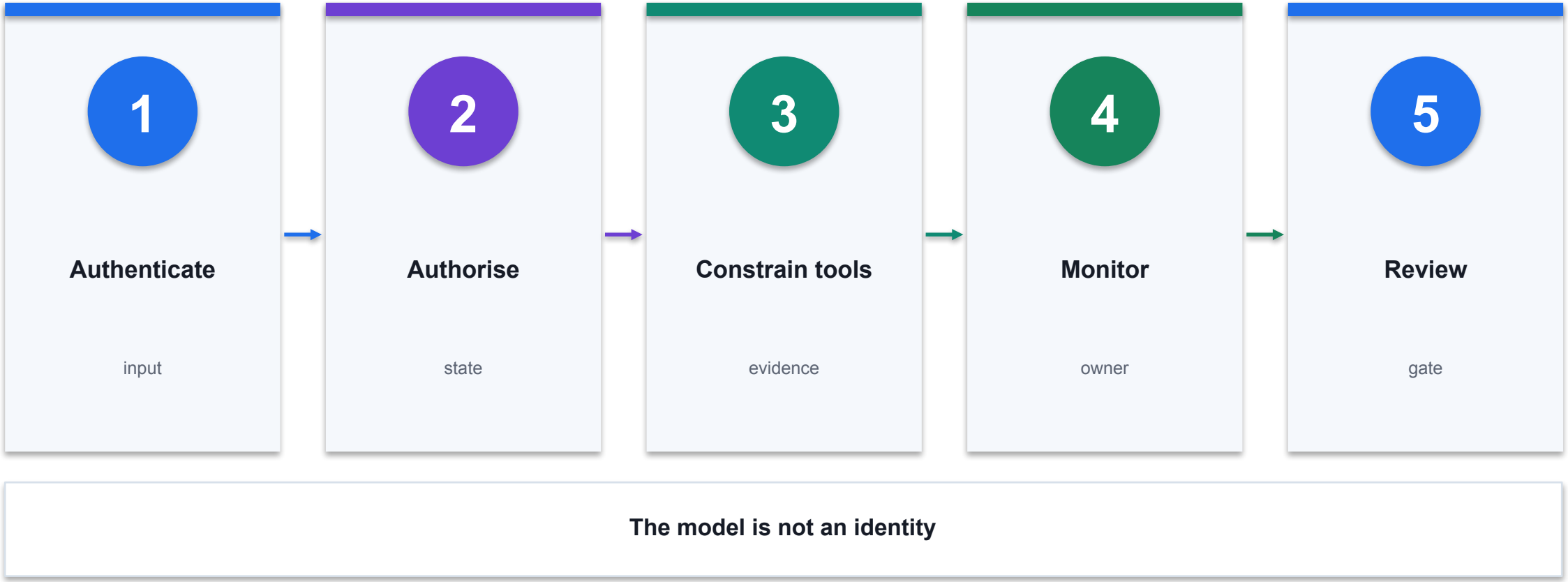
Trade-off: Provider dependency

Guardrail: Export/delete test

Build-versus-buy decisions depend on control and evidence: evidence-to-decision trace



Secure adoption applies least privilege to models, tools and people



FIELDS · FORMULAS · THRESHOLDS

Secure adoption applies least privilege to models, tools and people: concrete contract

```
CONTRACT

01   service identity

02   scoped retrieval index

03   tool allow-list

04   per-action audit event
```

1. The model is not an identity
2. Every tool call uses a governed principal
3. Retrieval permissions filter before generation
4. Logs capture inputs, decisions and actions

ANALYSIS · TRADE-OFF · DECISION

Secure adoption applies least privilege to models, tools and people: decision model

Signal 1

The model is not an identity

Signal 2

Every tool call uses a governed principal

Signal 3

Retrieval permissions filter before generation

Signal 4

Logs capture inputs, decisions and actions

THE DECISION RULE

Logs capture inputs, decisions and actions

Secure adoption applies least privilege to models, tools and people: failure and control

FAILURE MODES

- ! Shared API key
- ! Cross-tenant retrieval
- ! Over-privileged plugin
- ! Sensitive log content exposed

CONTROL & EVIDENCE

- ✓ RBAC test
- ✓ Tenant-isolation test
- ✓ Secret scan
- ✓ Access recertification

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Secure adoption applies least privilege to models, tools and people: verification evidence

Acceptance

RBAC test

Trace

Tenant-isolation test

Review

Secret scan

Operate

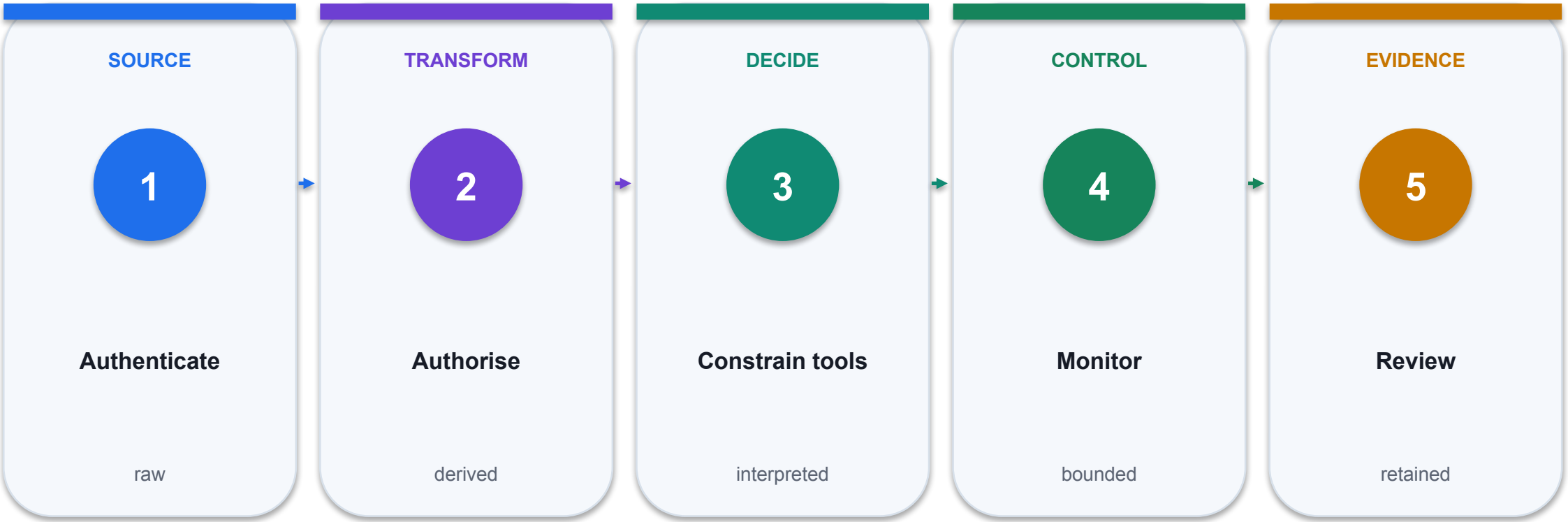
Access recertification

THE DECISION RULE

Lab 9 creates a reproducible artifact; detailed steps stay in the Learner Guide.

TRUST BOUNDARY · DATA FLOW · CONTROL OWNER

Secure adoption applies least privilege to models, tools and people: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

Secure adoption applies least privilege to models, tools and people: evidence artifact anatomy

ARTIFACT RECORD

01 service identity

02 scoped retrieval index

03 tool allow-list

04 per-action audit event

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 The model is not an identity

Retain: RBAC test

FIELD 2 Every tool call uses a governed principal

Retain: Tenant-isolation test

FIELD 3 Retrieval permissions filter before generation

Retain: Secret scan

FIELD 4 Logs capture inputs, decisions and actions

Retain: Access recertification

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Secure adoption applies least privilege to models, tools and people: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
service identity	The model is not an identity	Shared API key	RBAC test
scoped retrieval index	Every tool call uses a governed principal	Cross-tenant retrieval	Tenant-isolation test
tool allow-list	Retrieval permissions filter before generation	Over-privileged plugin	Secret scan
per-action audit event	Logs capture inputs, decisions and actions	Sensitive log content exposed	Access recertification

Secure adoption applies least privilege to models, tools and people: control test design

T1

Shared API key

Condition: service identity

Pass evidence: RBAC test

T2

Cross-tenant retrieval

Condition: scoped retrieval index

Pass evidence: Tenant-isolation test

T3

Over-privileged plugin

Condition: tool allow-list

Pass evidence: Secret scan

T4

Sensitive log content exposed

Condition: per-action audit event

Pass evidence: Access recertification

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Secure adoption applies least privilege to models, tools and people: operating trade-offs

CHOICE 1 The model is not an identity

Trade-off: Shared API key

Guardrail: RBAC test

CHOICE 2 Every tool call uses a governed principal

Trade-off: Cross-tenant retrieval

Guardrail: Tenant-isolation test

REVIEWED OPERATING POINT

CHOICE 3 Retrieval permissions filter before generation

Trade-off: Over-privileged plugin

Guardrail: Secret scan

CHOICE 4 Logs capture inputs, decisions and actions

Trade-off: Sensitive log content exposed

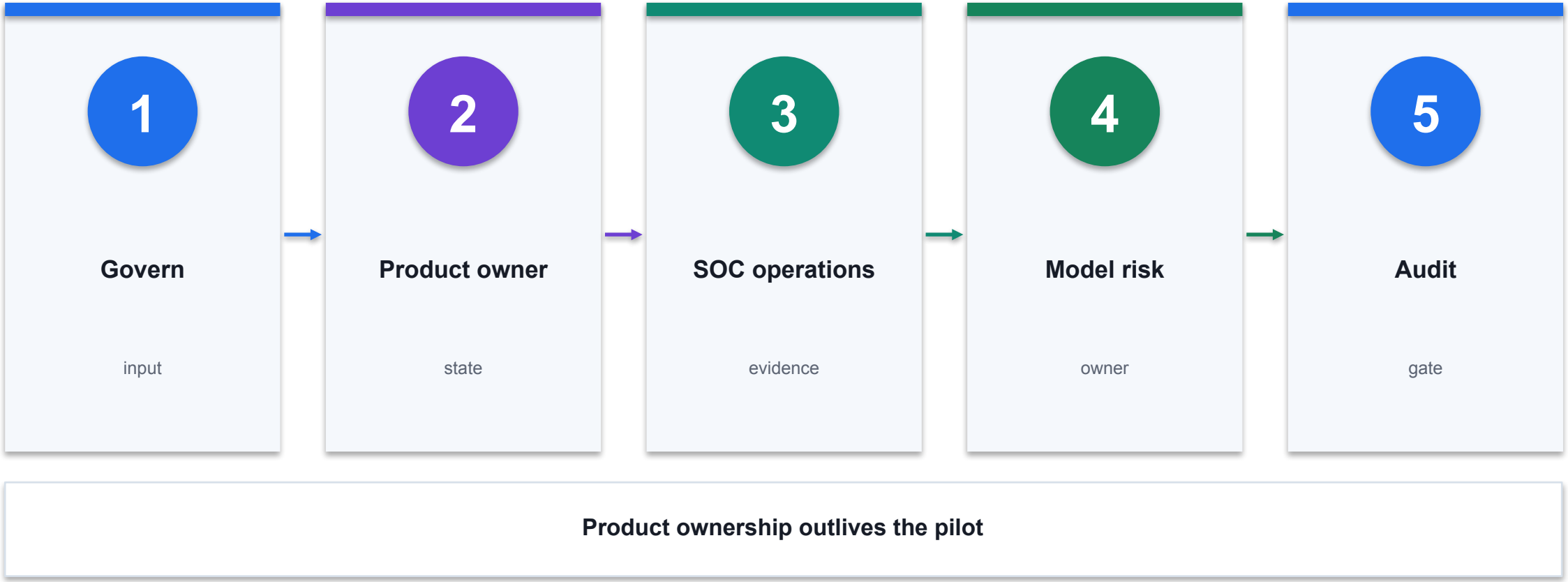
Guardrail: Access recertification

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Secure adoption applies least privilege to models, tools and people: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
service identity	Shared API key	**The model is not an identity**	**RBAC test**
scoped retrieval index	Cross-tenant retrieval	**Every tool call uses a governed principal**	**Tenant-isolation test**
tool allow-list	Over-privileged plugin	**Retrieval permissions filter before generation**	**Secret scan**
per-action audit event	Sensitive log content exposed	**Logs capture inputs, decisions and actions**	**Access recertification**

The operating model links people, process and technology



The operating model links people, process and technology: concrete contract

```
CONTRACT

01   RACI

02   change window

03   incident route

04   model card + runbook
```

1. Product ownership outlives the pilot
2. SOC owns operational disposition
3. Model risk owns validation
4. Audit needs evidence independent of the vendor

ANALYSIS · TRADE-OFF · DECISION

The operating model links people, process and technology: decision model

Signal 1

Product ownership outlives the pilot

Signal 2

SOC owns operational disposition

Signal 3

Model risk owns validation

Signal 4

Audit needs evidence independent of the vendor

THE DECISION RULE

Audit needs evidence independent of the vendor

The operating model links people, process and technology: failure and control

FAILURE MODES

- ! Nobody owns false positives
- ! Change bypasses CAB
- ! Runbook lacks fallback
- ! Audit depends on screenshots

CONTROL & EVIDENCE

- ✓ RACI approved
- ✓ On-call route tested
- ✓ Fallback exercised
- ✓ Evidence pack reproducible

EVIDENCE · ACCEPTANCE · LAB BRIDGE

The operating model links people, process and technology: verification evidence

Acceptance

RACI approved

Trace

On-call route tested

Review

Fallback exercised

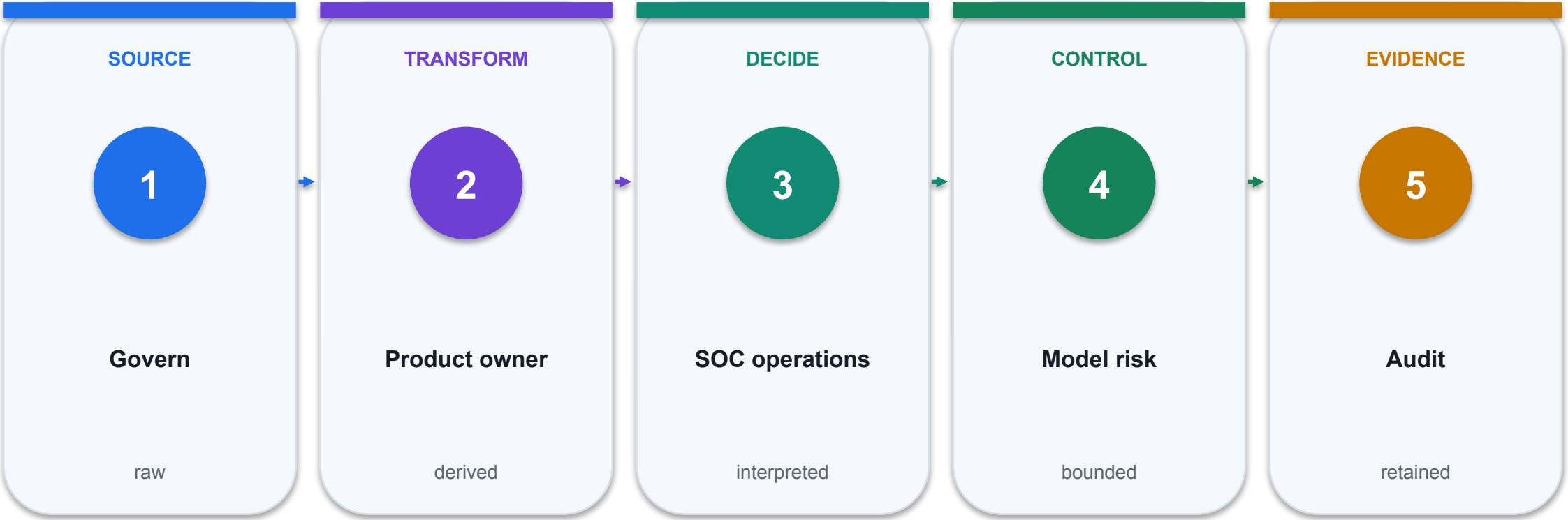
Operate

Evidence pack reproducible

THE DECISION RULE

Lab 7 creates a reproducible artifact; detailed steps stay in the Learner Guide.

The operating model links people, process and technology: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

The operating model links people, process and technology: evidence artifact anatomy

ARTIFACT RECORD

01 RACI

02 change window

03 incident route

04 model card + runbook

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Product ownership outlives the pilot**

Retain: RACI approved

FIELD 2 — **SOC owns operational disposition**

Retain: On-call route tested

FIELD 3 — **Model risk owns validation**

Retain: Fallback exercised

FIELD 4 — **Audit needs evidence independent of the vendor**

Retain: Evidence pack reproducible

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

The operating model links people, process and technology: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
RACI	Product ownership outlives the pilot	Nobody owns false positives	RACI approved
change window	SOC owns operational disposition	Change bypasses CAB	On-call route tested
incident route	Model risk owns validation	Runbook lacks fallback	Fallback exercised
model card + runbook	Audit needs evidence independent of the vendor	Audit depends on screenshots	Evidence pack reproducible

The operating model links people, process and technology: control test design

T1

Nobody owns false positives

Condition: RACI

Pass evidence: RACI approved

T2

Change bypasses CAB

Condition: change window

Pass evidence: On-call route tested

T3

Runbook lacks fallback

Condition: incident route

Pass evidence: Fallback exercised

T4

Audit depends on screenshots

Condition: model card + runbook

Pass evidence: Evidence pack reproducible

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

The operating model links people, process and technology: operating trade-offs

CHOICE 1 **Product ownership outlives the pilot**

Trade-off: Nobody owns false positives

Guardrail: RACI approved

CHOICE 2 **SOC owns operational disposition**

Trade-off: Change bypasses CAB

rdrail: On-call route tested

REVIEWED OPERATING POINT

CHOICE 3 **Model risk owns validation**

Trade-off: Runbook lacks fallback

Guardrail: Fallback exercised

CHOICE 4 **Audit needs evidence independent of the vendor**

Trade-off: Audit depends on screenshots

Guardrail: Evidence pack reproducible

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

The operating model links people, process and technology: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
RACI	Nobody owns false positives	**Product ownership outlives the pilot**	**RACI approved**
change window	Change bypasses CAB	**SOC owns operational disposition**	**On-call route tested**
incident route	Runbook lacks fallback	**Model risk owns validation**	**Fallback exercised**
model card + runbook	Audit depends on screenshots	**Audit needs evidence independent of the vendor**	**Evidence pack reproducible**

HANDS-ON · LO2

Lab 5: Select and Scope an AI Security Use Case

Score candidate use cases on value, data readiness, integration effort, operating risk and human-oversight requirements.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 5

use_case_scorecard.csv and pilot-charter.md.

Python 3 · CSV · Markdown · Cybersecurity Threat Simulation Lab · steps in Learner Guide and individual lab folder

Lab 5 verification: prove the control works

- ✓ **Selected use case has measurable baseline**
- ✓ **Decision owner named**
- ✓ **Automation ceiling explicit**
- ✓ **Stop criteria included**

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

HANDS-ON · LO2

Lab 6: Threat-Model an AI SOC Assistant

Map assets, trust boundaries and AI-specific abuse cases, then turn them into programme guardrails.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 6

threat_model.json and control_backlog.csv.

Python 3 · JSON · MITRE ATLAS/OWASP references · Hacklab: Ethical Hacking Lab Simulator · steps in Learner Guide and individual lab folder

Lab 6 verification: prove the control works

- ✓ At least four trust boundaries
- ✓ Every abuse case has a control owner
- ✓ Tool actions are allow-listed
- ✓ Residual risk is stated

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

HANDS-ON · LO2

Lab 7: Build the AI Security Programme Charter

Translate assessed control gaps into governed programme epics, metrics, owners and decision gates.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 7

programme_charter.md and RACI.csv.

Markdown · CSV · policy template · FauxBank Cybersecurity Training Simulation · steps in Learner Guide and individual lab folder

Lab 7 verification: prove the control works

- ✓ **Every epic traces to a gap**
- ✓ **Metric has baseline and target**
- ✓ **RACI has one accountable owner**
- ✓ **Retirement/exit gate exists**

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

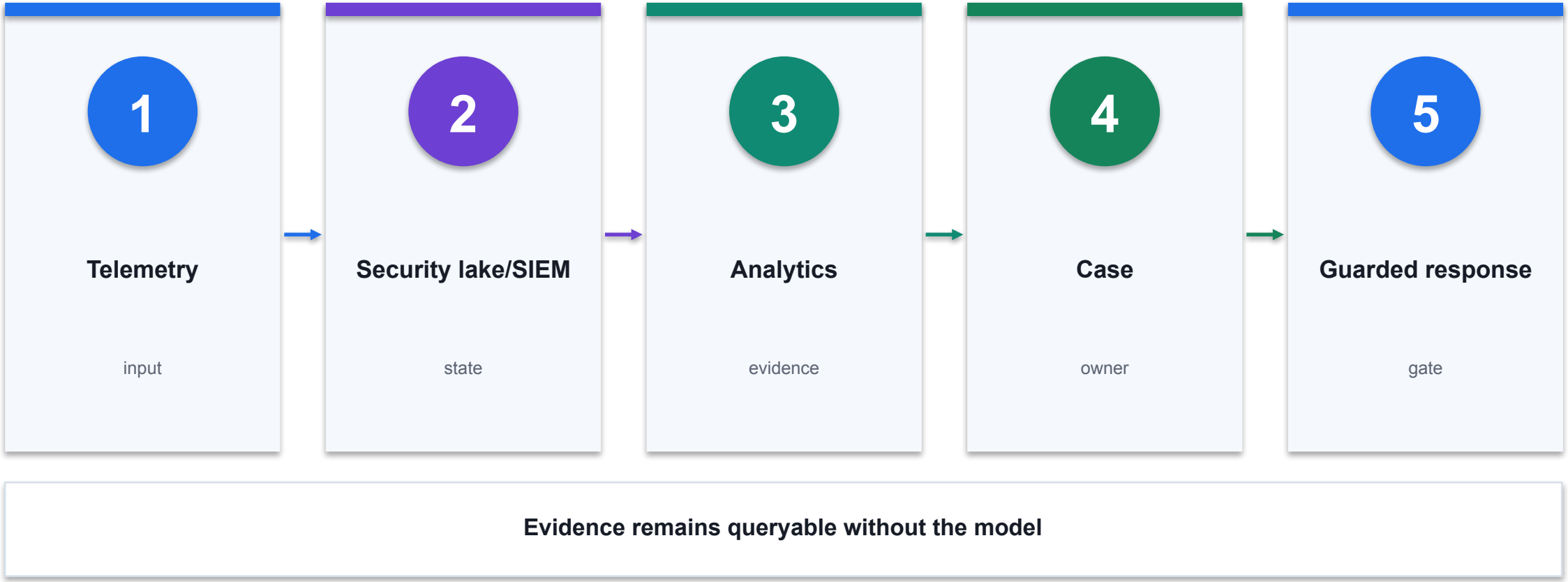
TOPIC 3 · LO3

Developing AI-Driven Security Architecture and Action Plans

SOC architecture · data pipeline · guarded automation · delivery roadmap



An AI-enhanced SOC separates evidence, inference and action



An AI-enhanced SOC separates evidence, inference and action: concrete contract

```
CONTRACT

01   immutable event store

02   feature/model service

03   case evidence bundle

04   SOAR approval gate
```

1. Evidence remains queryable without the model
2. Inference is versioned
3. Cases preserve human disposition
4. Response uses scoped service accounts

ANALYSIS · TRADE-OFF · DECISION

An AI-enhanced SOC separates evidence, inference and action: decision model

Signal 1

Evidence remains queryable without the model

Signal 2

Inference is versioned

Signal 3

Cases preserve human disposition

Signal 4

Response uses scoped service accounts

THE DECISION RULE

Response uses scoped service accounts

An AI-enhanced SOC separates evidence, inference and action: failure and control

FAILURE MODES

- ! LLM directly queries production
- ! No model version
- ! Alert overwrites raw evidence
- ! SOAR action lacks approval

CONTROL & EVIDENCE

- ✓ Replay creates same result
- ✓ Model/version logged
- ✓ Case links raw events
- ✓ Rollback tested

EVIDENCE · ACCEPTANCE · LAB BRIDGE

An AI-enhanced SOC separates evidence, inference and action: verification evidence

Acceptance

Replay creates same result

Trace

Model/version logged

Review

Case links raw events

Operate

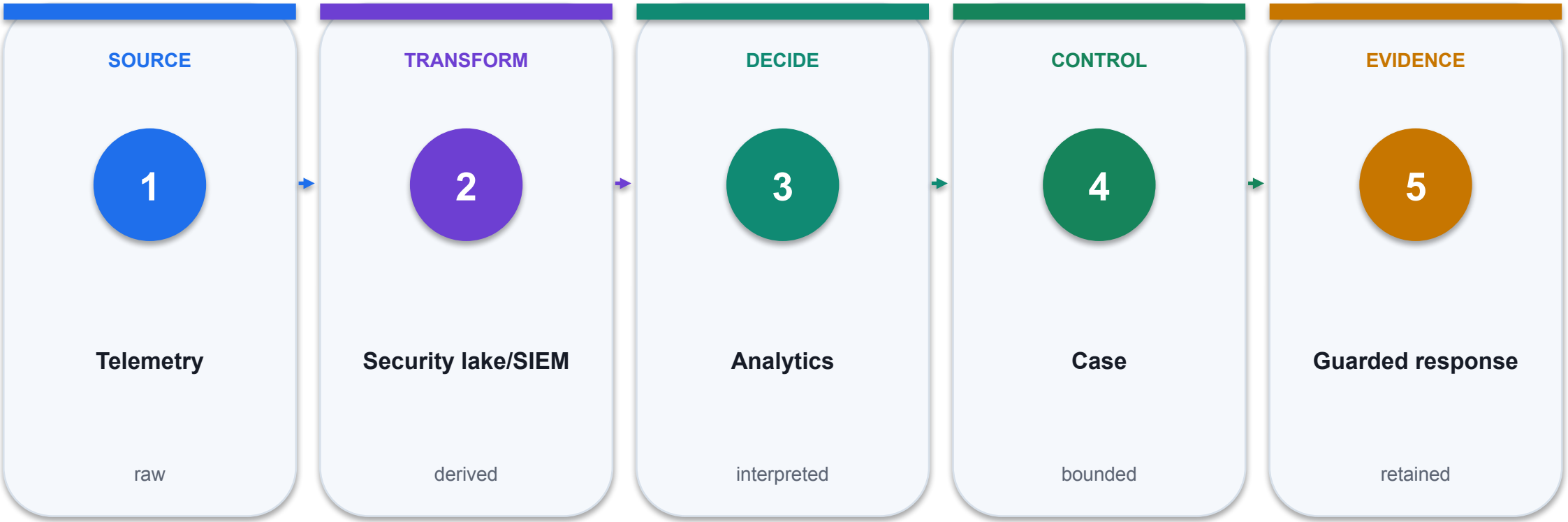
Rollback tested

THE DECISION RULE

Lab 9 creates a reproducible artifact; detailed steps stay in the Learner Guide.

TRUST BOUNDARY · DATA FLOW · CONTROL OWNER

An AI-enhanced SOC separates evidence, inference and action: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

An AI-enhanced SOC separates evidence, inference and action: evidence artifact anatomy

ARTIFACT RECORD

01 immutable event store

02 feature/model service

03 case evidence bundle

04 SOAR approval gate

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Evidence remains queryable without the model**

Retain: Replay creates same result

FIELD 2 — **Inference is versioned**

Retain: Model/version logged

FIELD 3 — **Cases preserve human disposition**

Retain: Case links raw events

FIELD 4 — **Response uses scoped service accounts**

Retain: Rollback tested

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

An AI-enhanced SOC separates evidence, inference and action: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
immutable event store	Evidence remains queryable without the model	LLM directly queries production	Replay creates same result
feature/model service	Inference is versioned	No model version	Model/version logged
case evidence bundle	Cases preserve human disposition	Alert overwrites raw evidence	Case links raw events
SOAR approval gate	Response uses scoped service accounts	SOAR action lacks approval	Rollback tested

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

An AI-enhanced SOC separates evidence, inference and action: control test design

T1

LLM directly queries production

Condition: immutable event store

Pass evidence: Replay creates same result

T2

No model version

Condition: feature/model service

Pass evidence: Model/version logged

T3

Alert overwrites raw evidence

Condition: case evidence bundle

Pass evidence: Case links raw events

T4

SOAR action lacks approval

Condition: SOAR approval gate

Pass evidence: Rollback tested

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

An AI-enhanced SOC separates evidence, inference and action: operating trade-offs

CHOICE 1 **Evidence remains queryable without the model**

Trade-off: LLM directly queries production

Guardrail: Replay creates same result

CHOICE 2 **Inference is versioned**

Trade-off: No model version

rdrail: Model/version logged

REVIEWED OPERATING POINT

CHOICE 3 **Cases preserve human disposition**

Trade-off: Alert overwrites raw evidence

Guardrail: Case links raw events

CHOICE 4 **Response uses scoped service accounts**

Trade-off: SOAR action lacks approval

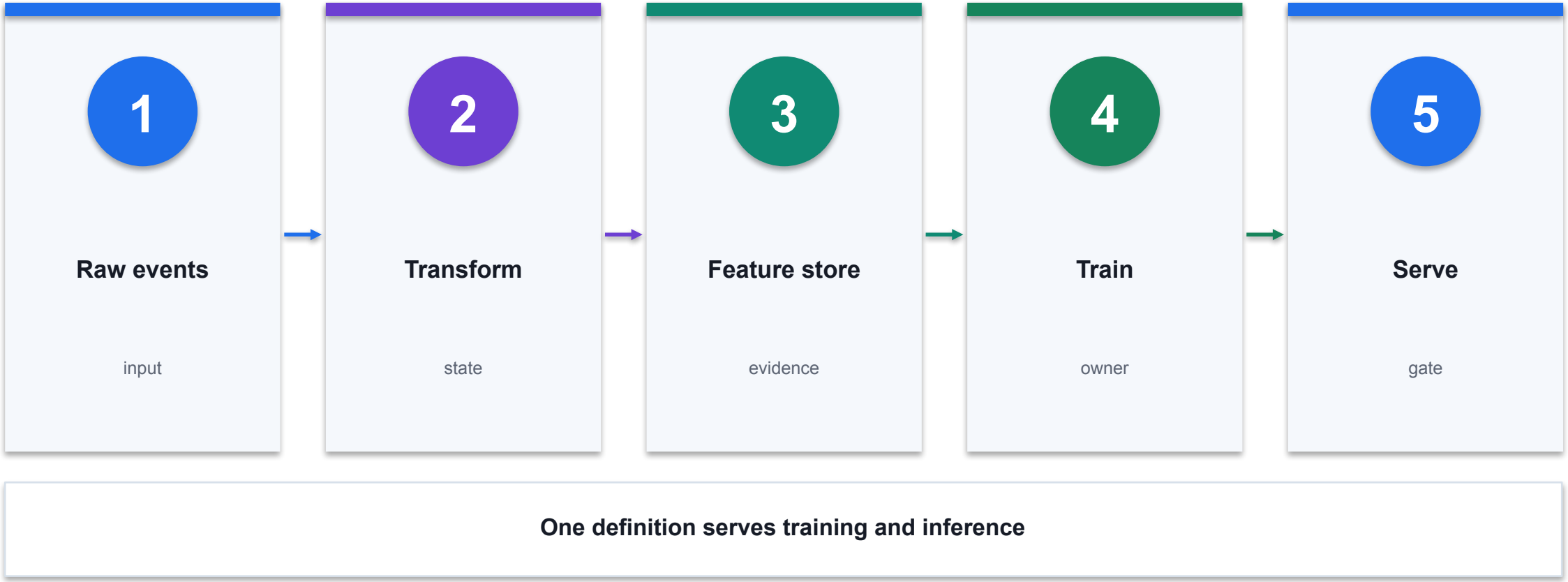
Guardrail: Rollback tested

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

An AI-enhanced SOC separates evidence, inference and action: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
immutable event store	LLM directly queries production	**Evidence remains queryable without the model**	**Replay creates same result**
feature/model service	No model version	**Inference is versioned**	**Model/version logged**
case evidence bundle	Alert overwrites raw evidence	**Cases preserve human disposition**	**Case links raw events**
SOAR approval gate	SOAR action lacks approval	**Response uses scoped service accounts**	**Rollback tested**

Feature pipelines prevent training-serving skew



FIELDS · FORMULAS · THRESHOLDS

Feature pipelines prevent training-serving skew: concrete contract

```
CONTRACT
01  feature name/type
02  window and timezone
03  default/null policy
04  owner/version
```

1. One definition serves training and inference
2. Point-in-time joins prevent leakage
3. Feature freshness is monitored
4. Backfills are versioned

ANALYSIS · TRADE-OFF · DECISION

Feature pipelines prevent training-serving skew: decision model

Signal 1

One definition serves training and inference

Signal 2

Point-in-time joins prevent leakage

Signal 3

Feature freshness is monitored

Signal 4

Backfills are versioned

THE DECISION RULE

Backfills are versioned

Feature pipelines prevent training-serving skew: failure and control

FAILURE MODES

- ! Future data leaks into training
- ! Different parser in production
- ! Null default changes
- ! Stale enrichment

CONTROL & EVIDENCE

- ✓ Offline/online parity test
- ✓ Feature freshness SLO
- ✓ Schema contract test
- ✓ Backfill audit

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Feature pipelines prevent training-serving skew: verification evidence

Acceptance

Offline/online parity test

Trace

Feature freshness SLO

Review

Schema contract test

Operate

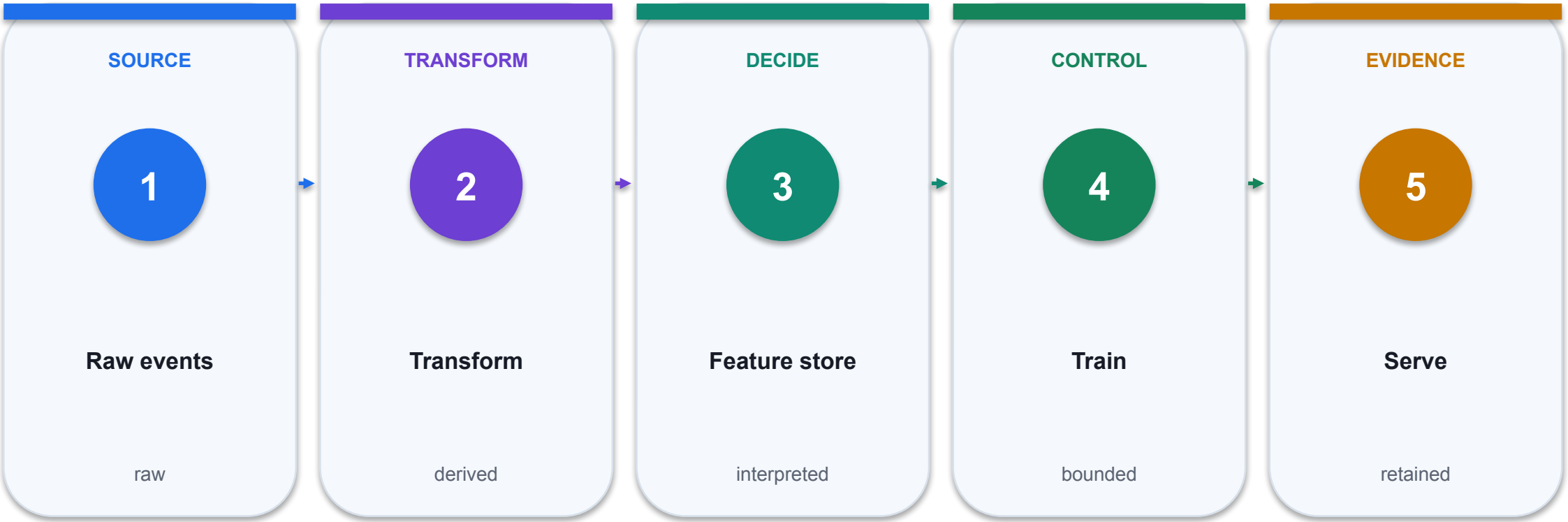
Backfill audit

THE DECISION RULE

Lab 10 creates a reproducible artifact; detailed steps stay in the Learner Guide.

TRUST BOUNDARY · DATA FLOW · CONTROL OWNER

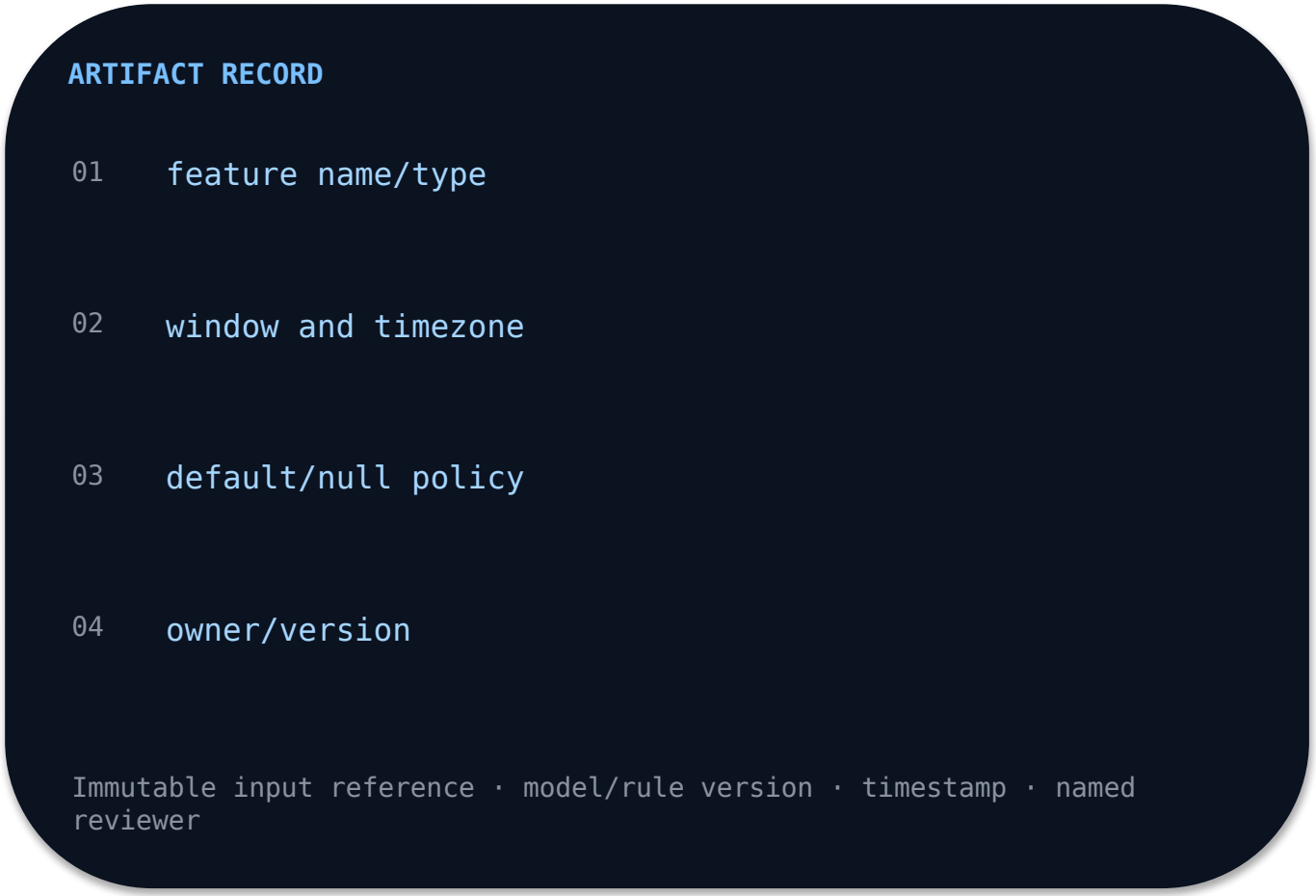
Feature pipelines prevent training-serving skew: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Feature pipelines prevent training-serving skew: evidence artifact anatomy



FIELD 1 — **One definition serves training and inference**

Retain: Offline/online parity test

FIELD 2 — **Point-in-time joins prevent leakage**

Retain: Feature freshness SLO

FIELD 3 — **Feature freshness is monitored**

Retain: Schema contract test

FIELD 4 — **Backfills are versioned**

Retain: Backfill audit

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Feature pipelines prevent training-serving skew: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
feature name/type	One definition serves training and inference	Future data leaks into training	Offline/online parity test
window and timezone	Point-in-time joins prevent leakage	Different parser in production	Feature freshness SLO
default/null policy	Feature freshness is monitored	Null default changes	Schema contract test
owner/version	Backfills are versioned	Stale enrichment	Backfill audit

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Feature pipelines prevent training-serving skew: control test design

T1

Future data leaks into training

Condition: feature name/type

Pass evidence: Offline/online parity test

T2

Different parser in production

Condition: window and timezone

Pass evidence: Feature freshness SLO

T3

Null default changes

Condition: default/null policy

Pass evidence: Schema contract test

T4

Stale enrichment

Condition: owner/version

Pass evidence: Backfill audit

Feature pipelines prevent training-serving skew: operating trade-offs

CHOICE 1 One definition serves training and inference

Trade-off: Future data leaks into training

Guardrail: Offline/online parity test

CHOICE 2 Point-in-time joins prevent leakage

Trade-off: Different parser in production

Guardrail: Feature freshness SLO

REVIEWED OPERATING POINT

CHOICE 3 Feature freshness is monitored

Trade-off: Null default changes

Guardrail: Schema contract test

CHOICE 4 Backfills are versioned

Trade-off: Stale enrichment

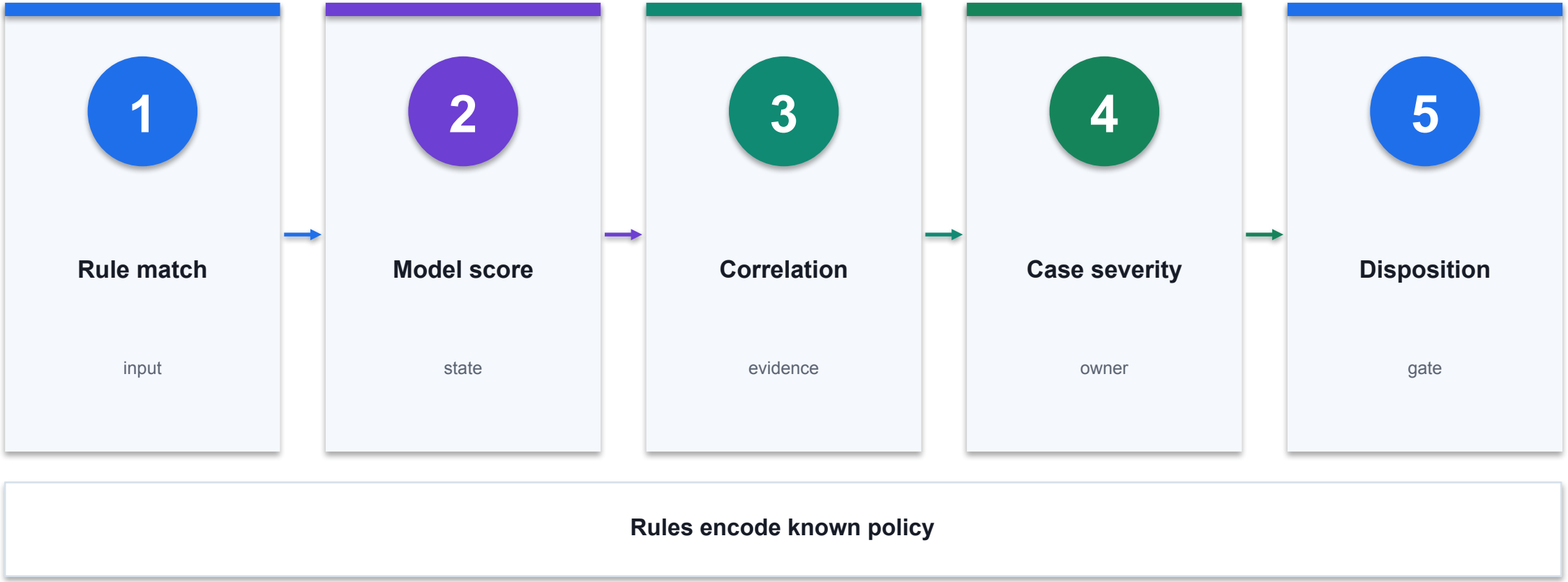
Guardrail: Backfill audit

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Feature pipelines prevent training-serving skew: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
feature name/type	Future data leaks into training	**One definition serves training and inference**	**Offline/online parity test**
window and timezone	Different parser in production	**Point-in-time joins prevent leakage**	**Feature freshness SLO**
default/null policy	Null default changes	**Feature freshness is monitored**	**Schema contract test**
owner/version	Stale enrichment	**Backfills are versioned**	**Backfill audit**

SIEM plus ML uses rules and models as complementary detectors



FIELDS · FORMULAS · THRESHOLDS

SIEM plus ML uses rules and models as complementary detectors: concrete contract

```
CONTRACT

01   rule_id + version

02   model_id + threshold

03   entity graph

04   reason codes
```

1. Rules encode known policy
2. Models surface weak novel patterns
3. Correlation reduces isolated noise
4. Disposition feeds both tuning loops

ANALYSIS · TRADE-OFF · DECISION

SIEM plus ML uses rules and models as complementary detectors: decision model

Signal 1

Rules encode known policy

Signal 2

Models surface weak novel patterns

Signal 3

Correlation reduces isolated noise

Signal 4

Disposition feeds both tuning loops

THE DECISION RULE

Disposition feeds both tuning loops

SIEM plus ML uses rules and models as complementary detectors: failure and control

FAILURE MODES

- ! Model replaces high-confidence rule
- ! Duplicate alerts
- ! Correlation window too wide
- ! Feedback label leakage

CONTROL & EVIDENCE

- ✓ Detection-as-code test
- ✓ Duplicate suppression
- ✓ Latency SLO
- ✓ Tuning change record

SIEM plus ML uses rules and models as complementary detectors: verification evidence

Acceptance

Detection-as-code test

Trace

Duplicate suppression

Review

Latency SLO

Operate

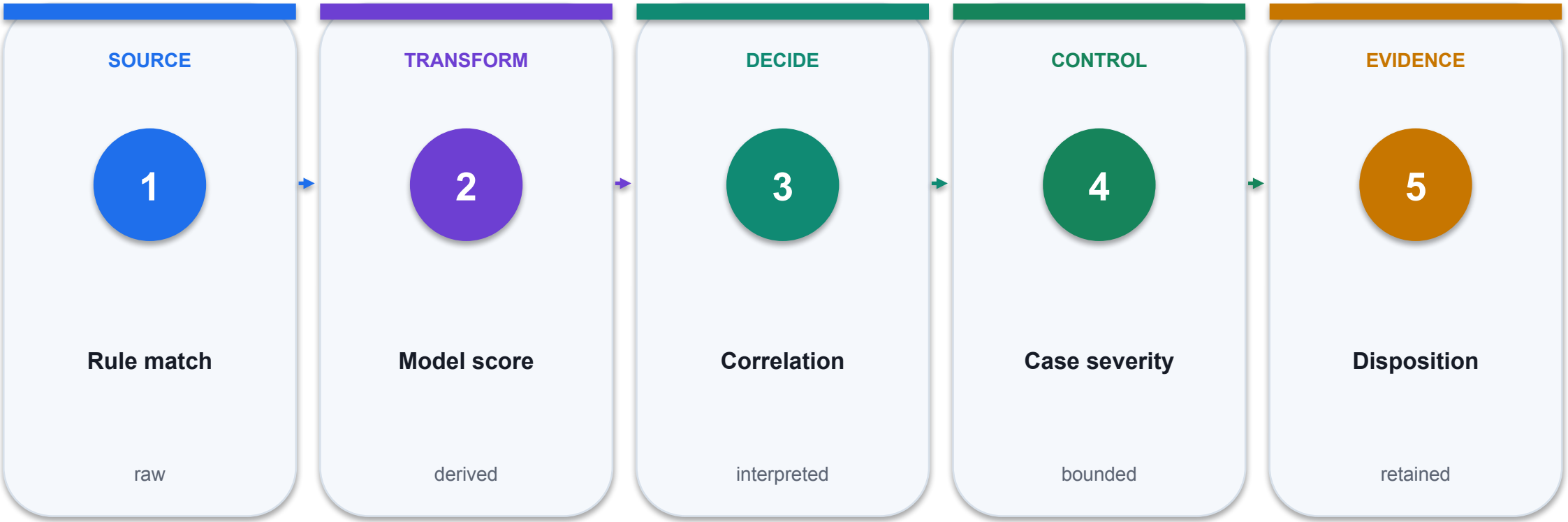
Tuning change record

THE DECISION RULE

Lab 10 creates a reproducible artifact; detailed steps stay in the Learner Guide.

TRUST BOUNDARY · DATA FLOW · CONTROL OWNER

SIEM plus ML uses rules and models as complementary detectors: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

SIEM plus ML uses rules and models as complementary detectors: evidence artifact anatomy

```
ARTIFACT RECORD

01    rule_id + version

02    model_id + threshold

03    entity graph

04    reason codes

Immutable input reference · model/rule version · timestamp · named
reviewer
```

FIELD 1 — **Rules encode known policy**

Retain: Detection-as-code test

FIELD 2 — **Models surface weak novel patterns**

Retain: Duplicate suppression

FIELD 3 — **Correlation reduces isolated noise**

Retain: Latency SLO

FIELD 4 — **Disposition feeds both tuning loops**

Retain: Tuning change record

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

SIEM plus ML uses rules and models as complementary detectors: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
rule_id + version	Rules encode known policy	Model replaces high-confidence rule	Detection-as-code test
model_id + threshold	Models surface weak novel patterns	Duplicate alerts	Duplicate suppression
entity graph	Correlation reduces isolated noise	Correlation window too wide	Latency SLO
reason codes	Disposition feeds both tuning loops	Feedback label leakage	Tuning change record

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

SIEM plus ML uses rules and models as complementary detectors: control test design

T1

Model replaces high-confidence rule

Condition: rule_id + version

Pass evidence: Detection-as-code test

T2

Duplicate alerts

Condition: model_id + threshold

Pass evidence: Duplicate suppression

T3

Correlation window too wide

Condition: entity graph

Pass evidence: Latency SLO

T4

Feedback label leakage

Condition: reason codes

Pass evidence: Tuning change record

SIEM plus ML uses rules and models as complementary detectors: operating trade-offs

CHOICE 1 Rules encode known policy

Trade-off: Model replaces high-confidence rule

Guardrail: Detection-as-code test

CHOICE 2 Models surface weak novel patterns

Trade-off: Duplicate alerts

Guardrail: Duplicate suppression

REVIEWED OPERATING POINT

CHOICE 3 Correlation reduces isolated noise

Trade-off: Correlation window too wide

Guardrail: Latency SLO

CHOICE 4 Disposition feeds both tuning loops

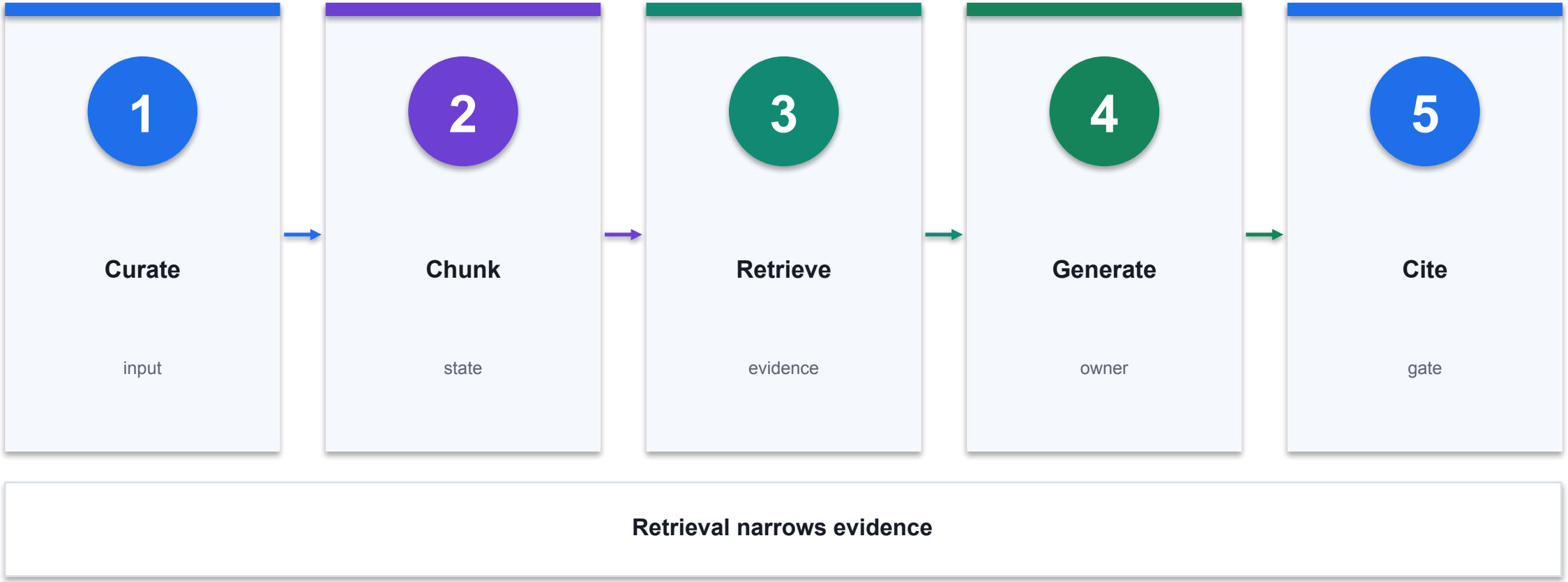
Trade-off: Feedback label leakage

Guardrail: Tuning change record

SIEM plus ML uses rules and models as complementary detectors: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
rule_id + version	Model replaces high-confidence rule	**Rules encode known policy**	**Detection-as-code test**
model_id + threshold	Duplicate alerts	**Models surface weak novel patterns**	**Duplicate suppression**
entity graph	Correlation window too wide	**Correlation reduces isolated noise**	**Latency SLO**
reason codes	Feedback label leakage	**Disposition feeds both tuning loops**	**Tuning change record**

RAG grounds an analyst assistant in approved evidence



RAG grounds an analyst assistant in approved evidence: concrete contract

```
CONTRACT

01  document_id/version

02  chunk + ACL

03  top_k + similarity

04  answer + citations
```

1. Retrieval narrows evidence
2. ACL filtering precedes generation
3. Citations enable verification
4. Abstention is a valid output

ANALYSIS · TRADE-OFF · DECISION

RAG grounds an analyst assistant in approved evidence: decision model

Signal 1

Retrieval narrows evidence

Signal 2

ACL filtering precedes generation

Signal 3

Citations enable verification

Signal 4

Abstention is a valid output

THE DECISION RULE

Abstention is a valid output

RAG grounds an analyst assistant in approved evidence: failure and control

FAILURE MODES

- ! Indirect prompt injection
- ! Stale runbook
- ! Cross-case retrieval
- ! Confident uncited answer

CONTROL & EVIDENCE

- ✓ Citation precision
- ✓ Forbidden-document test
- ✓ Freshness check
- ✓ Abstention threshold

EVIDENCE · ACCEPTANCE · LAB BRIDGE

RAG grounds an analyst assistant in approved evidence: verification evidence

Acceptance

Citation precision

Trace

Forbidden-document test

Review

Freshness check

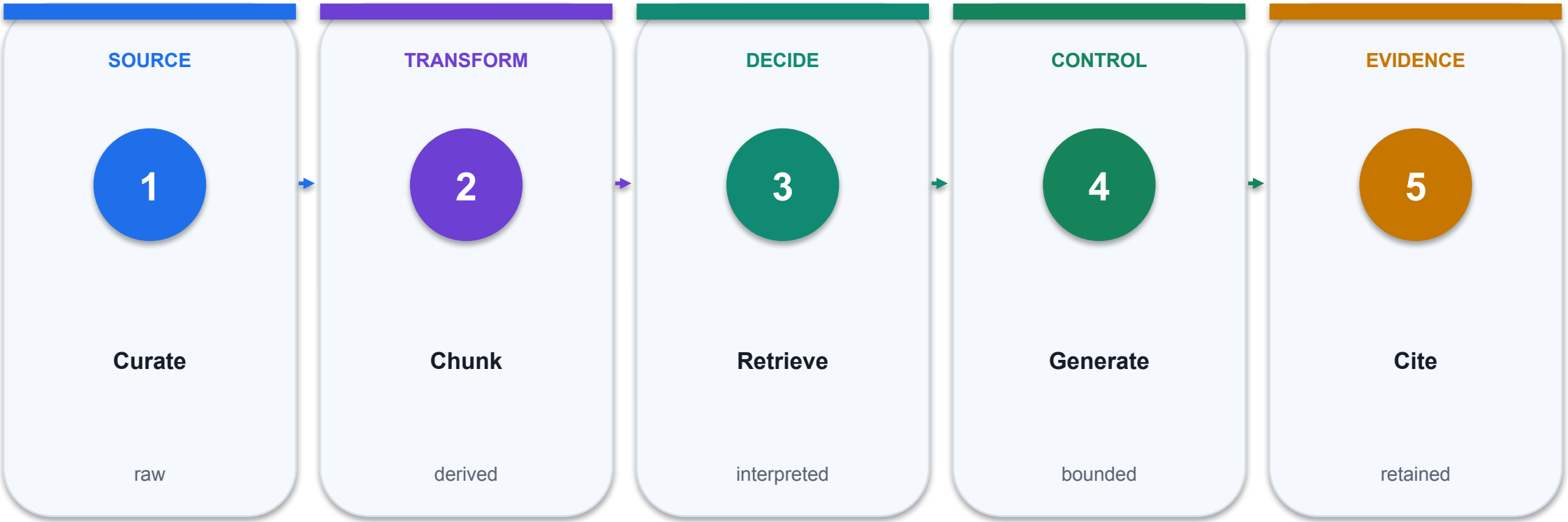
Operate

Abstention threshold

THE DECISION RULE

Lab 10 creates a reproducible artifact; detailed steps stay in the Learner Guide.

RAG grounds an analyst assistant in approved evidence: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

RAG grounds an analyst assistant in approved evidence: evidence artifact anatomy

ARTIFACT RECORD

01 document_id/version

02 chunk + ACL

03 top_k + similarity

04 answer + citations

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Retrieval narrows evidence**

Retain: Citation precision

FIELD 2 — **ACL filtering precedes generation**

Retain: Forbidden-document test

FIELD 3 — **Citations enable verification**

Retain: Freshness check

FIELD 4 — **Abstention is a valid output**

Retain: Abstention threshold

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

RAG grounds an analyst assistant in approved evidence: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
document_id/version	Retrieval narrows evidence	Indirect prompt injection	Citation precision
chunk + ACL	ACL filtering precedes generation	Stale runbook	Forbidden-document test
top_k + similarity	Citations enable verification	Cross-case retrieval	Freshness check
answer + citations	Abstention is a valid output	Confident uncited answer	Abstention threshold

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

RAG grounds an analyst assistant in approved evidence: control test design

T1

Indirect prompt injection

Condition: document_id/version

Pass evidence: Citation precision

T2

Stale runbook

Condition: chunk + ACL

Pass evidence: Forbidden-document test

T3

Cross-case retrieval

Condition: top_k + similarity

Pass evidence: Freshness check

T4

Confident uncited answer

Condition: answer + citations

Pass evidence: Abstention threshold

RAG grounds an analyst assistant in approved evidence: operating trade-offs

CHOICE 1 **Retrieval narrows evidence**

Trade-off: Indirect prompt injection

Guardrail: Citation precision

CHOICE 2 **ACL filtering precedes generation**

Trade-off: Stale runbook

Guardrail: Forbidden-document test

REVIEWED OPERATING POINT

CHOICE 3 **Citations enable verification**

Trade-off: Cross-case retrieval

Guardrail: Freshness check

CHOICE 4 **Abstention is a valid output**

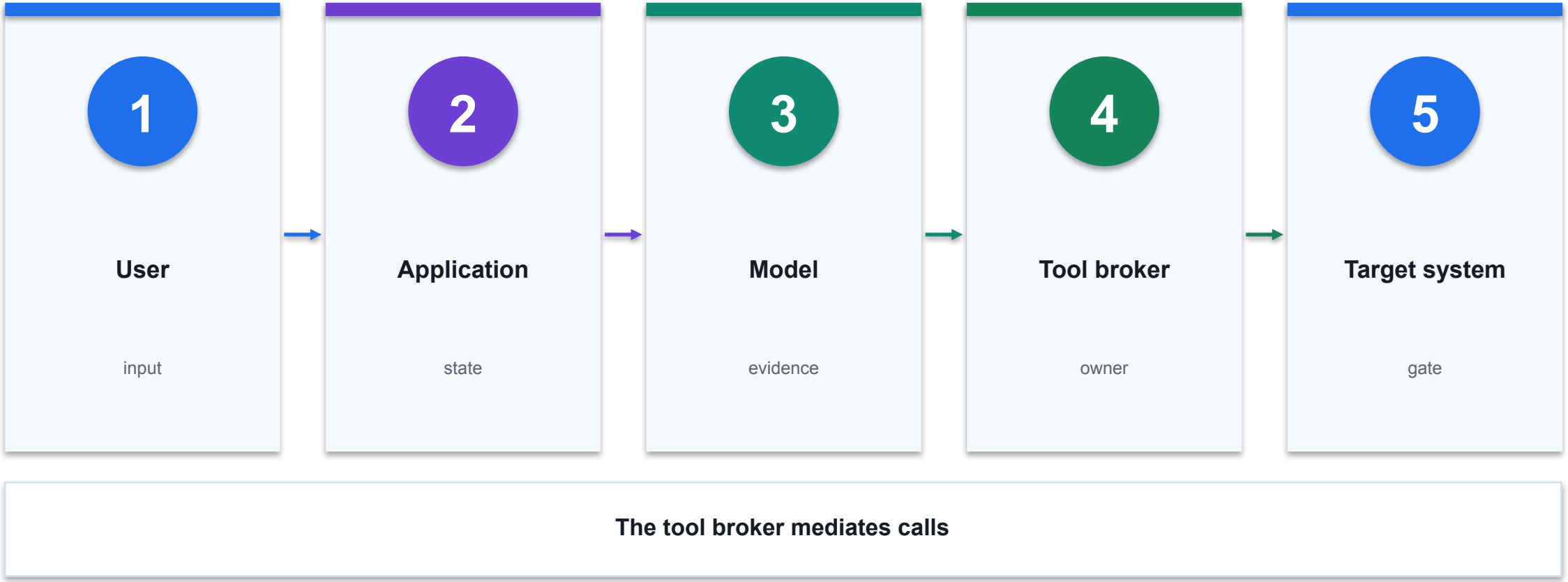
Trade-off: Confident uncited answer

Guardrail: Abstention threshold

RAG grounds an analyst assistant in approved evidence: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
document_id/version	Indirect prompt injection	**Retrieval narrows evidence**	**Citation precision**
chunk + ACL	Stale runbook	**ACL filtering precedes generation**	**Forbidden-document test**
top_k + similarity	Cross-case retrieval	**Citations enable verification**	**Freshness check**
answer + citations	Confident uncited answer	**Abstention is a valid output**	**Abstention threshold**

Identity boundaries control every AI-to-tool transition



Identity boundaries control every AI-to-tool transition: concrete contract

```
CONTRACT

01   user/session claims

02   workload identity

03   delegated scope

04   policy decision + audit
```

1. The tool broker mediates calls
2. Delegation cannot exceed the user
3. Secrets stay outside prompts
4. Break-glass is separate

ANALYSIS · TRADE-OFF · DECISION

Identity boundaries control every AI-to-tool transition: decision model

Signal 1

The tool broker mediates calls

Signal 2

Delegation cannot exceed the user

Signal 3

Secrets stay outside prompts

Signal 4

Break-glass is separate

THE DECISION RULE

Break-glass is separate

Identity boundaries control every AI-to-tool transition: failure and control

FAILURE MODES

- ! Model holds admin token
- ! Confused deputy
- ! Long-lived secret
- ! Unlogged break-glass

CONTROL & EVIDENCE

- ✓ Token scope test
- ✓ Denied-action test
- ✓ Secret rotation
- ✓ Break-glass review

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Identity boundaries control every AI-to-tool transition: verification evidence

Acceptance

Token scope test

Trace

Denied-action test

Review

Secret rotation

Operate

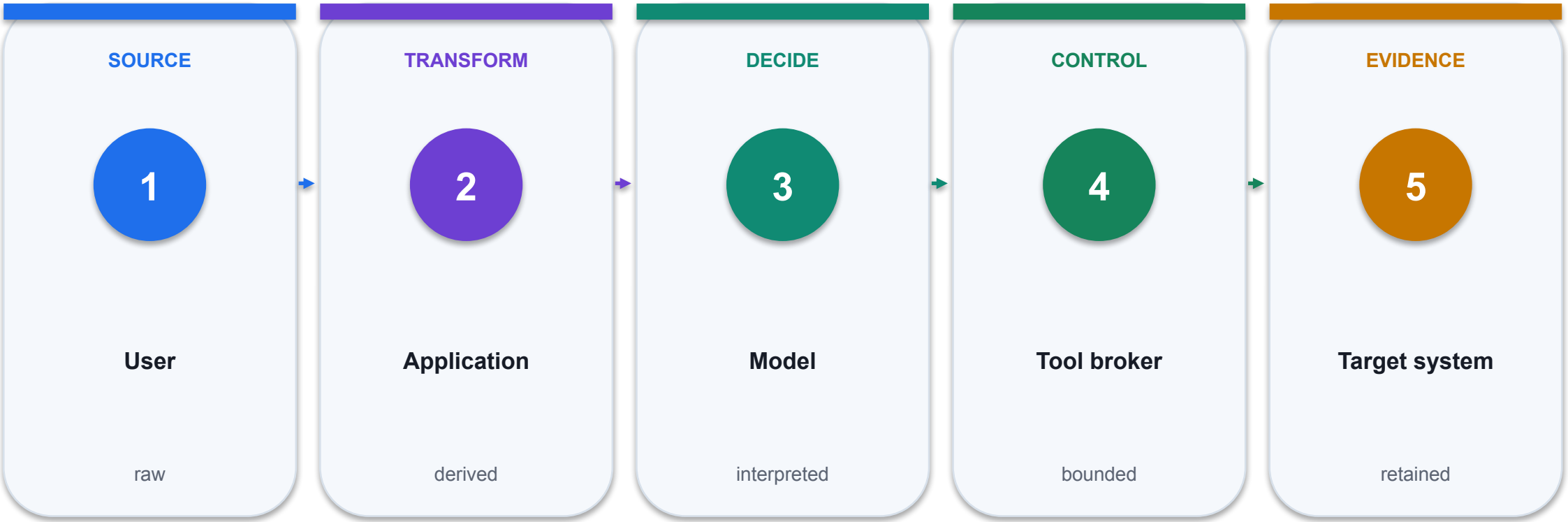
Break-glass review

THE DECISION RULE

Lab 9 creates a reproducible artifact; detailed steps stay in the Learner Guide.

TRUST BOUNDARY · DATA FLOW · CONTROL OWNER

Identity boundaries control every AI-to-tool transition: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

Identity boundaries control every AI-to-tool transition: evidence artifact anatomy

ARTIFACT RECORD

01 user/session claims

02 workload identity

03 delegated scope

04 policy decision + audit

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **The tool broker mediates calls**

Retain: Token scope test

FIELD 2 — **Delegation cannot exceed the user**

Retain: Denied-action test

FIELD 3 — **Secrets stay outside prompts**

Retain: Secret rotation

FIELD 4 — **Break-glass is separate**

Retain: Break-glass review

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Identity boundaries control every AI-to-tool transition: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
user/session claims	The tool broker mediates calls	Model holds admin token	Token scope test
workload identity	Delegation cannot exceed the user	Confused deputy	Denied-action test
delegated scope	Secrets stay outside prompts	Long-lived secret	Secret rotation
policy decision + audit	Break-glass is separate	Unlogged break-glass	Break-glass review

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Identity boundaries control every AI-to-tool transition: control test design

T1

Model holds admin token

Condition: user/session claims

Pass evidence: Token scope test

T2

Confused deputy

Condition: workload identity

Pass evidence: Denied-action test

T3

Long-lived secret

Condition: delegated scope

Pass evidence: Secret rotation

T4

Unlogged break-glass

Condition: policy decision + audit

Pass evidence: Break-glass review

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Identity boundaries control every AI-to-tool transition: operating trade-offs

CHOICE 1 The tool broker mediates calls

Trade-off: Model holds admin token

Guardrail: Token scope test

CHOICE 2 Delegation cannot exceed the user

Trade-off: Confused deputy

Guardrail: Denied-action test

REVIEWED OPERATING POINT

CHOICE 3 Secrets stay outside prompts

Trade-off: Long-lived secret

Guardrail: Secret rotation

CHOICE 4 Break-glass is separate

Trade-off: Unlogged break-glass

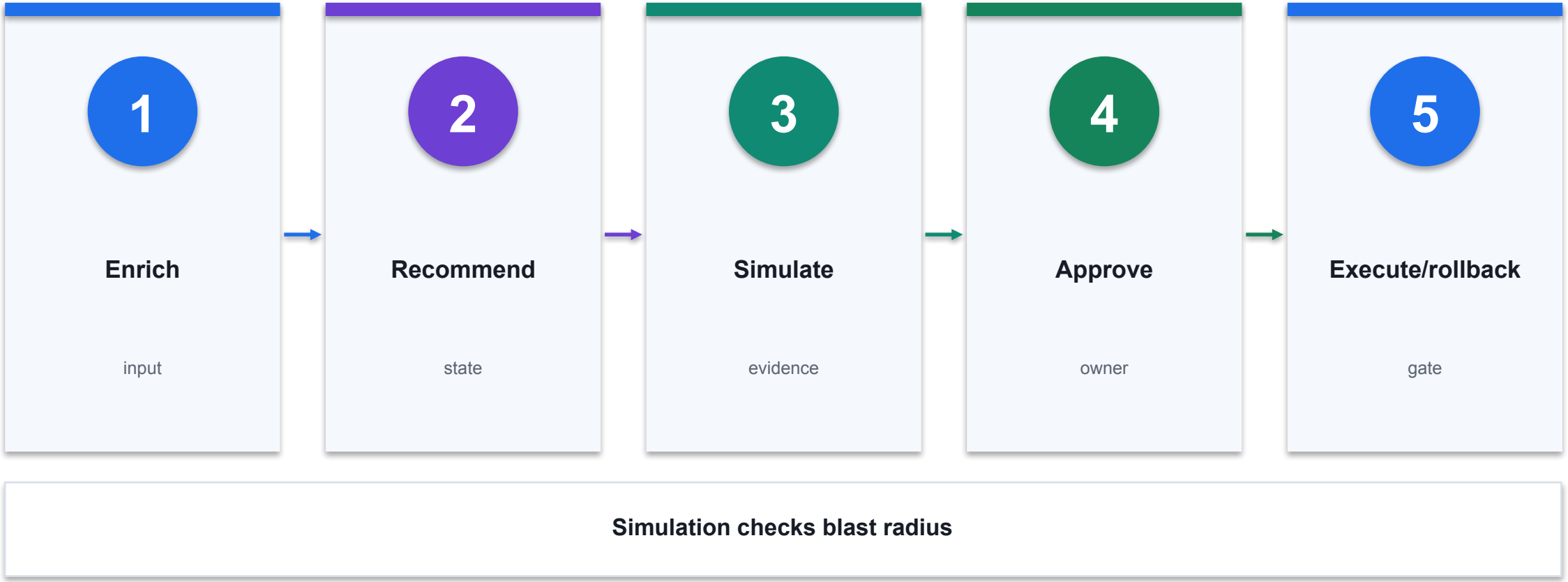
Guardrail: Break-glass review

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Identity boundaries control every AI-to-tool transition: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
user/session claims	Model holds admin token	**The tool broker mediates calls**	**Token scope test**
workload identity	Confused deputy	**Delegation cannot exceed the user**	**Denied-action test**
delegated scope	Long-lived secret	**Secrets stay outside prompts**	**Secret rotation**
policy decision + audit	Unlogged break-glass	**Break-glass is separate**	**Break-glass review**

Guarded SOAR uses policy gates and reversible actions



Guarded SOAR uses policy gates and reversible actions: concrete contract

```
CONTRACT
01  action type
02  target scope
03  precondition
04  approval
05  rollback
```

1. Simulation checks blast radius
2. Preconditions prevent stale actions
3. Approval follows impact tier
4. Rollback is part of the playbook

ANALYSIS · TRADE-OFF · DECISION

Guarded SOAR uses policy gates and reversible actions: decision model

Signal 1

Simulation checks blast radius

Signal 2

Preconditions prevent stale actions

Signal 3

Approval follows impact tier

Signal 4

Rollback is part of the playbook

THE DECISION RULE

Rollback is part of the playbook

Guarded SOAR uses policy gates and reversible actions: failure and control

FAILURE MODES

- ! Race condition
- ! Wrong entity
- ! Partial execution
- ! Rollback dependency unavailable

CONTROL & EVIDENCE

- ✓ Dry-run output
- ✓ Approval record
- ✓ Post-action verification
- ✓ Rollback exercise

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Guarded SOAR uses policy gates and reversible actions: verification evidence

Acceptance

Dry-run output

Trace

Approval record

Review

Post-action verification

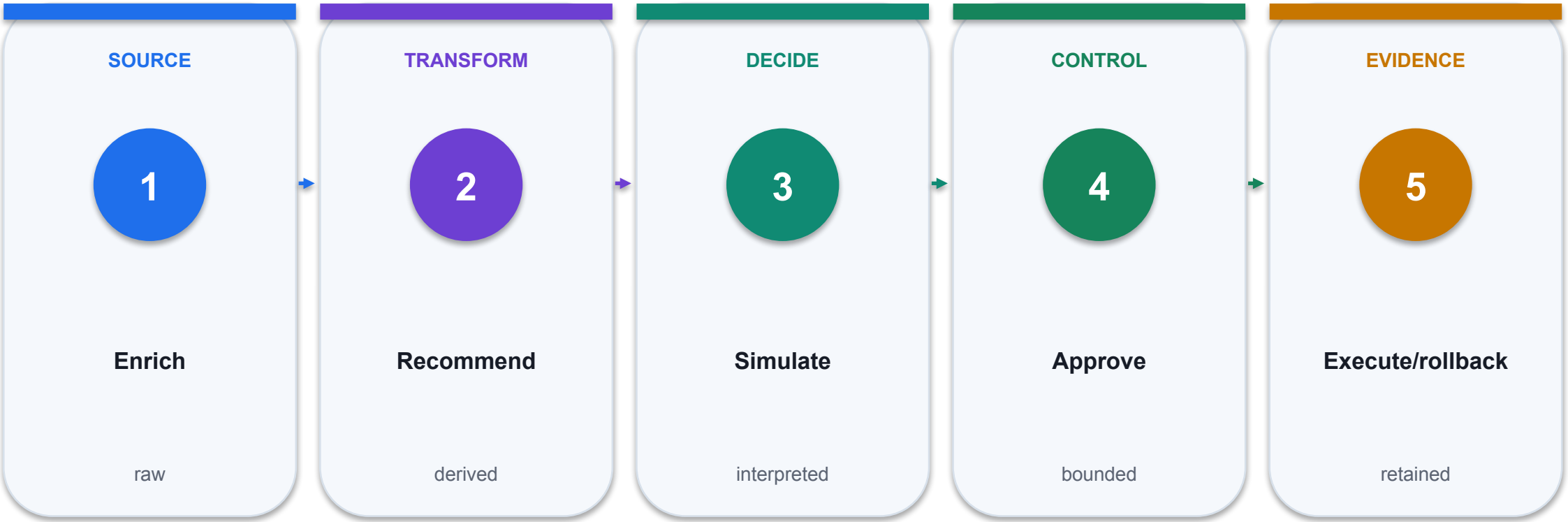
Operate

Rollback exercise

THE DECISION RULE

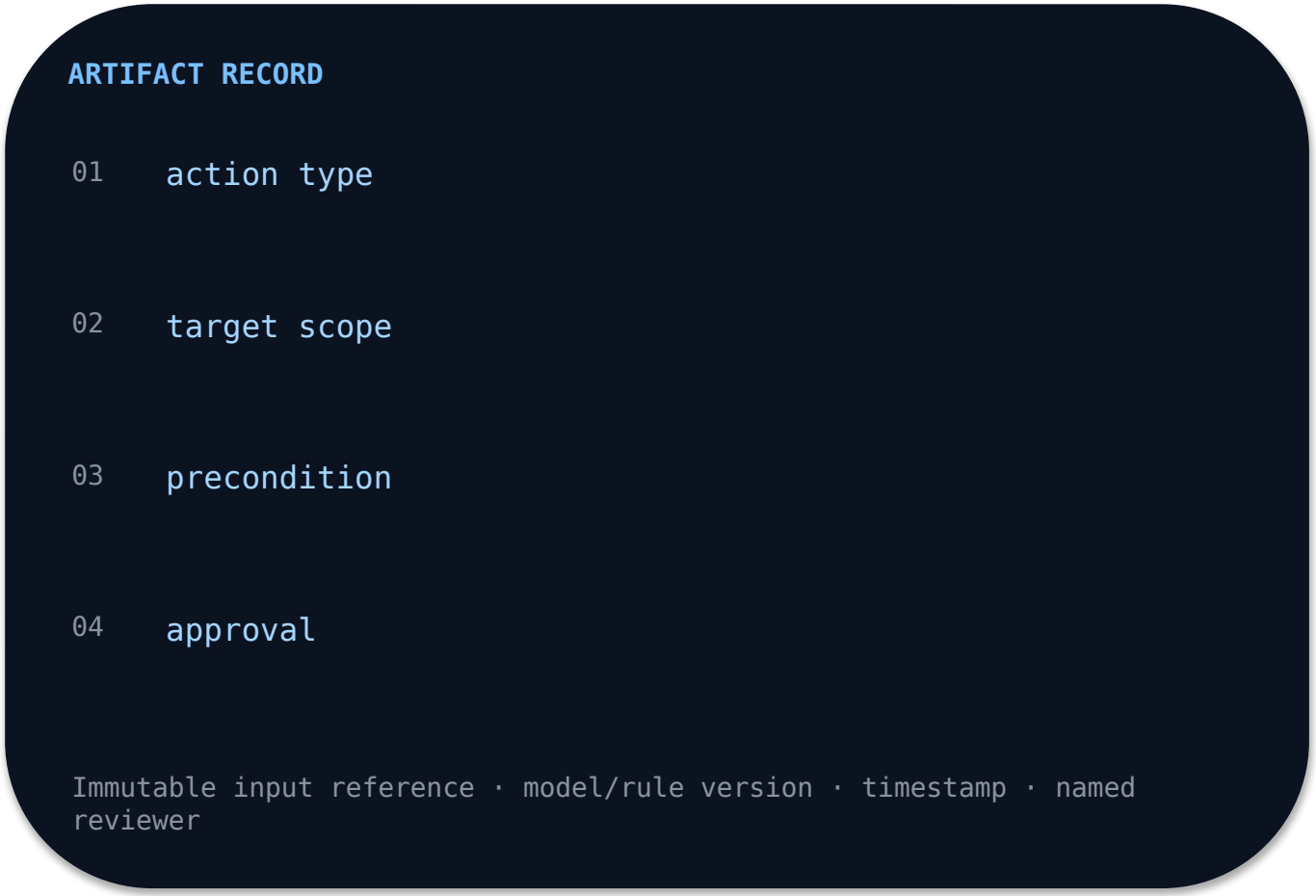
Lab 11 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Guarded SOAR uses policy gates and reversible actions: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

Guarded SOAR uses policy gates and reversible actions: evidence artifact anatomy



FIELD 1 — **Simulation checks blast radius**

Retain: Dry-run output

FIELD 2 — **Preconditions prevent stale actions**

Retain: Approval record

FIELD 3 — **Approval follows impact tier**

Retain: Post-action verification

FIELD 4 — **Rollback is part of the playbook**

Retain: Rollback exercise

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Guarded SOAR uses policy gates and reversible actions: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
action type	Simulation checks blast radius	Race condition	Dry-run output
target scope	Preconditions prevent stale actions	Wrong entity	Approval record
precondition	Approval follows impact tier	Partial execution	Post-action verification
approval	Rollback is part of the playbook	Rollback dependency unavailable	Rollback exercise

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Guarded SOAR uses policy gates and reversible actions: control test design

T1

Race condition

Condition: action type

Pass evidence: Dry-run output

T2

Wrong entity

Condition: target scope

Pass evidence: Approval record

T3

Partial execution

Condition: precondition

Pass evidence: Post-action verification

T4

Rollback dependency unavailable

Condition: approval

Pass evidence: Rollback exercise

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Guarded SOAR uses policy gates and reversible actions: operating trade-offs

CHOICE 1 **Simulation checks blast radius**

Trade-off: Race condition

Guardrail: Dry-run output

CHOICE 2 **Preconditions prevent stale actions**

Trade-off: Wrong entity

Guardrail: Approval record

REVIEWED OPERATING POINT

CHOICE 3 **Approval follows impact tier**

Trade-off: Partial execution

Guardrail: Post-action verification

CHOICE 4 **Rollback is part of the playbook**

Trade-off: Rollback dependency unavailable

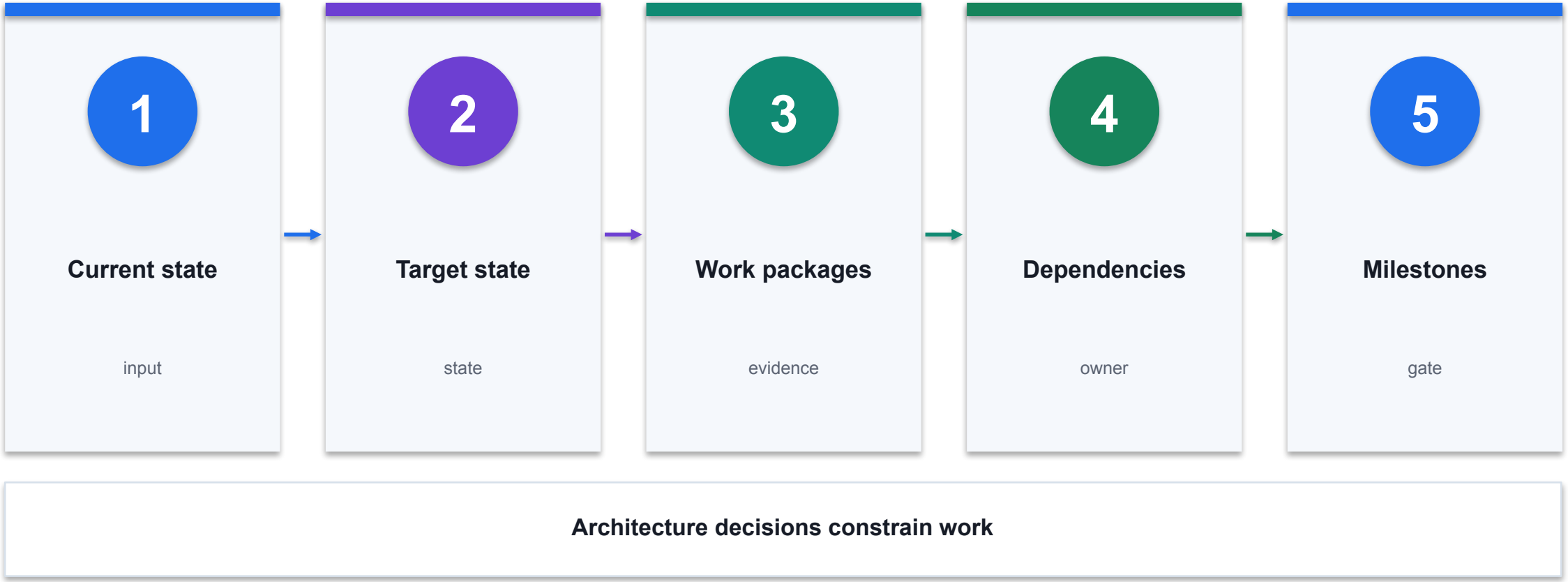
Guardrail: Rollback exercise

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Guarded SOAR uses policy gates and reversible actions: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
action type	Race condition	**Simulation checks blast radius**	**Dry-run output**
target scope	Wrong entity	**Preconditions prevent stale actions**	**Approval record**
precondition	Partial execution	**Approval follows impact tier**	**Post-action verification**
approval	Rollback dependency unavailable	**Rollback is part of the playbook**	**Rollback exercise**

An action plan converts architecture into sequenced delivery



An action plan converts architecture into sequenced delivery: concrete contract

```
CONTRACT
01  epic/control
02  owner
03  start/end
04  dependency
05  acceptance evidence
```

1. Architecture decisions constrain work
2. Critical path exposes sequencing
3. Pilot and production have different gates
4. Regulatory changes trigger backlog review

ANALYSIS · TRADE-OFF · DECISION

An action plan converts architecture into sequenced delivery: decision model

Signal 1

Architecture decisions constrain work

Signal 2

Critical path exposes sequencing

Signal 3

Pilot and production have different gates

Signal 4

Regulatory changes trigger backlog review

THE DECISION RULE

Regulatory changes trigger backlog review

An action plan converts architecture into sequenced delivery: failure and control

FAILURE MODES

- ! Roadmap has dates but no dependencies
- ! Control evidence deferred
- ! No decommission task
- ! Owner changes silently

CONTROL & EVIDENCE

- ✓ Dependency review
- ✓ Milestone evidence
- ✓ Risk burn-down
- ✓ Change log

EVIDENCE · ACCEPTANCE · LAB BRIDGE

An action plan converts architecture into sequenced delivery: verification evidence

Acceptance

Dependency review

Trace

Milestone evidence

Review

Risk burn-down

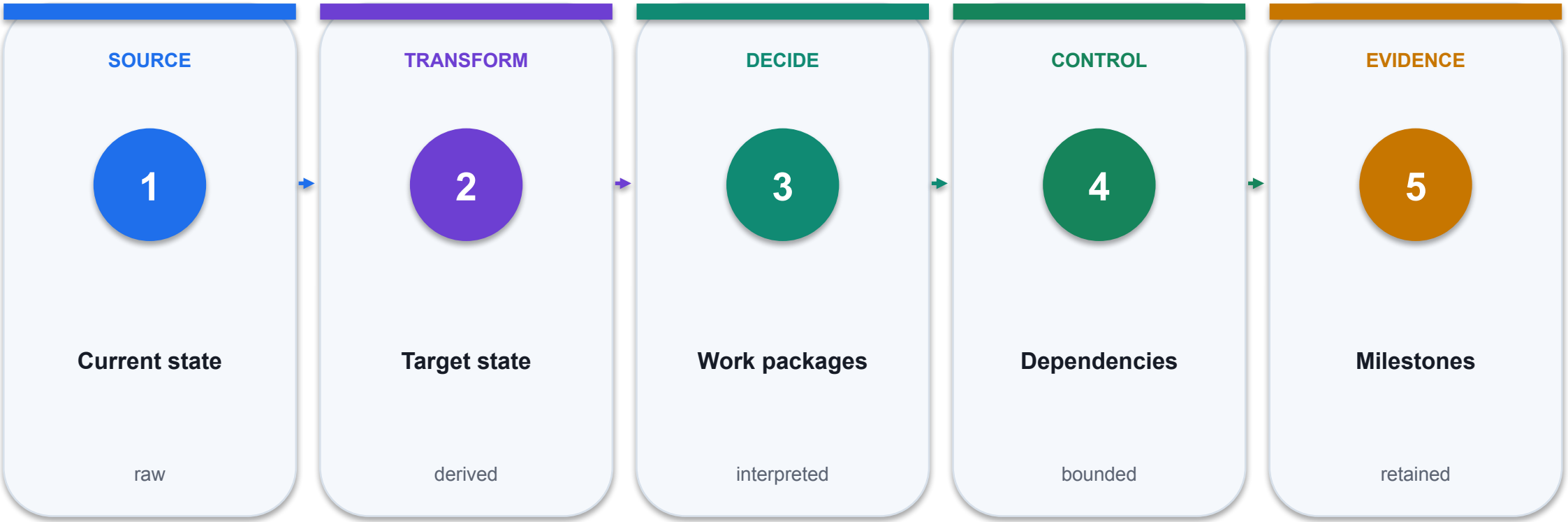
Operate

Change log

THE DECISION RULE

Lab 11 creates a reproducible artifact; detailed steps stay in the Learner Guide.

An action plan converts architecture into sequenced delivery: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

An action plan converts architecture into sequenced delivery: evidence artifact anatomy

ARTIFACT RECORD

01 epic/control

02 owner

03 start/end

04 dependency

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Architecture decisions constrain work**

Retain: Dependency review

FIELD 2 — **Critical path exposes sequencing**

Retain: Milestone evidence

FIELD 3 — **Pilot and production have different gates**

Retain: Risk burn-down

FIELD 4 — **Regulatory changes trigger backlog review**

Retain: Change log

An action plan converts architecture into sequenced delivery: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
epic/control	Architecture decisions constrain work	Roadmap has dates but no dependencies	Dependency review
owner	Critical path exposes sequencing	Control evidence deferred	Milestone evidence
start/end	Pilot and production have different gates	No decommission task	Risk burn-down
dependency	Regulatory changes trigger backlog review	Owner changes silently	Change log

An action plan converts architecture into sequenced delivery: control test design

T1

Roadmap has dates but no dependencies

Condition: epic/control

Pass evidence: Dependency review

T2

Control evidence deferred

Condition: owner

Pass evidence: Milestone evidence

T3

No decommission task

Condition: start/end

Pass evidence: Risk burn-down

T4

Owner changes silently

Condition: dependency

Pass evidence: Change log

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

An action plan converts architecture into sequenced delivery: operating trade-offs

CHOICE 1 **Architecture decisions constrain work**

Trade-off: Roadmap has dates but no dependencies

Guardrail: Dependency review

CHOICE 2 **Critical path exposes sequencing**

Trade-off: Control evidence deferred

Guardrail: Milestone evidence

REVIEWED OPERATING POINT

CHOICE 3 **Pilot and production have different gates**

Trade-off: No decommission task

Guardrail: Risk burn-down

CHOICE 4 **Regulatory changes trigger backlog review**

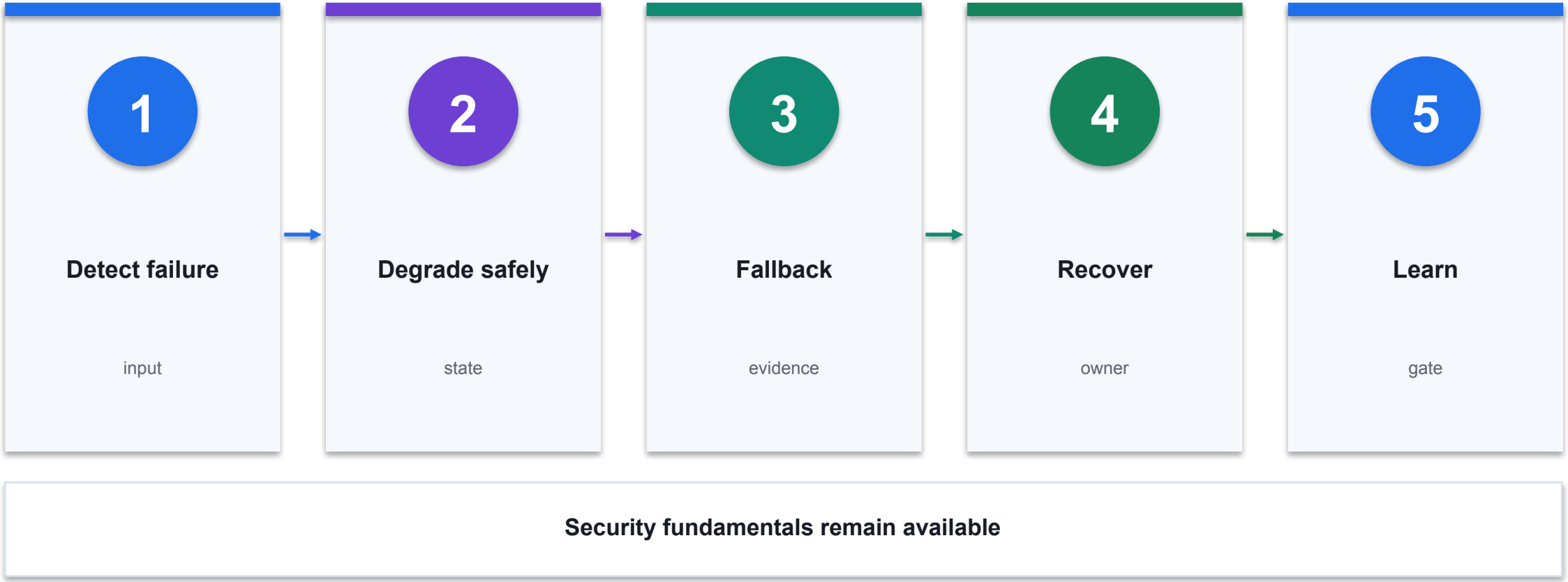
Trade-off: Owner changes silently

Guardrail: Change log

An action plan converts architecture into sequenced delivery: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
epic/control	Roadmap has dates but no dependencies	**Architecture decisions constrain work**	**Dependency review**
owner	Control evidence deferred	**Critical path exposes sequencing**	**Milestone evidence**
start/end	No decommission task	**Pilot and production have different gates**	**Risk burn-down**
dependency	Owner changes silently	**Regulatory changes trigger backlog review**	**Change log**

Resilience assumes models and providers can fail



Resilience assumes models and providers can fail: concrete contract

```
CONTRACT

01  availability/latency SLO

02  manual/rule fallback

03  backup configuration

04  recovery objective
```

1. Security fundamentals remain available
2. Fail-closed is not always safe
3. Fallback needs equivalent audit
4. Recovery includes model and index versions

ANALYSIS · TRADE-OFF · DECISION

Resilience assumes models and providers can fail: decision model

Signal 1

Security fundamentals remain available

Signal 2

Fail-closed is not always safe

Signal 3

Fallback needs equivalent audit

Signal 4

Recovery includes model and index versions

THE DECISION RULE

Recovery includes model and index versions

Resilience assumes models and providers can fail: failure and control

FAILURE MODES

- ! Provider outage
- ! Corrupt vector index
- ! Rate-limit spike
- ! Bad model rollout

CONTROL & EVIDENCE

- ✓ Game-day exercise
- ✓ Manual queue works
- ✓ Restore checksum
- ✓ Post-incident action

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Resilience assumes models and providers can fail: verification evidence

Acceptance

Game-day exercise

Trace

Manual queue works

Review

Restore checksum

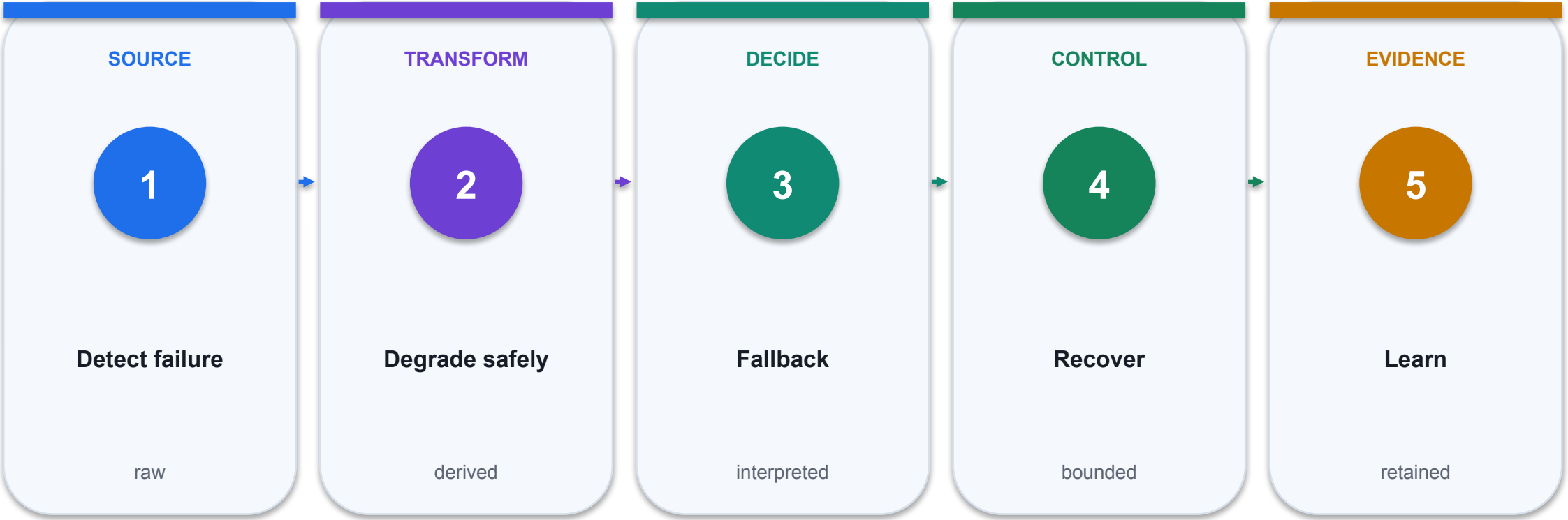
Operate

Post-incident action

THE DECISION RULE

Lab 11 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Resilience assumes models and providers can fail: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Resilience assumes models and providers can fail: evidence artifact anatomy

ARTIFACT RECORD

01 availability/latency SLO

02 manual/rule fallback

03 backup configuration

04 recovery objective

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Security fundamentals remain available**

Retain: Game-day exercise

FIELD 2 — **Fail-closed is not always safe**

Retain: Manual queue works

FIELD 3 — **Fallback needs equivalent audit**

Retain: Restore checksum

FIELD 4 — **Recovery includes model and index versions**

Retain: Post-incident action

Resilience assumes models and providers can fail: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
availability/latency SLO	Security fundamentals remain available	Provider outage	Game-day exercise
manual/rule fallback	Fail-closed is not always safe	Corrupt vector index	Manual queue works
backup configuration	Fallback needs equivalent audit	Rate-limit spike	Restore checksum
recovery objective	Recovery includes model and index versions	Bad model rollout	Post-incident action

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Resilience assumes models and providers can fail: control test design

T1

Provider outage

Condition: availability/latency SLO

Pass evidence: Game-day exercise

T2

Corrupt vector index

Condition: manual/rule fallback

Pass evidence: Manual queue works

T3

Rate-limit spike

Condition: backup configuration

Pass evidence: Restore checksum

T4

Bad model rollout

Condition: recovery objective

Pass evidence: Post-incident action

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Resilience assumes models and providers can fail: operating trade-offs

CHOICE 1 **Security fundamentals remain available**

Trade-off: Provider outage

Guardrail: Game-day exercise

CHOICE 2 **Fail-closed is not always safe**

Trade-off: Corrupt vector index

Guardrail: Manual queue works

REVIEWED OPERATING POINT

CHOICE 3 **Fallback needs equivalent audit**

Trade-off: Rate-limit spike

Guardrail: Restore checksum

CHOICE 4 **Recovery includes model and index versions**

Trade-off: Bad model rollout

Guardrail: Post-incident action

Resilience assumes models and providers can fail: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
availability/latency SLO	Provider outage	**Security fundamentals remain available**	**Game-day exercise**
manual/rule fallback	Corrupt vector index	**Fail-closed is not always safe**	**Manual queue works**
backup configuration	Rate-limit spike	**Fallback needs equivalent audit**	**Restore checksum**
recovery objective	Bad model rollout	**Recovery includes model and index versions**	**Post-incident action**

HANDS-ON · LO3

Lab 8: Design an AI-Enhanced SOC Architecture

Design a layered architecture that separates evidence, inference, case management and guarded action.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 8

soc_architecture.json and ADR-001.md.

JSON · architecture template · Cryptography Toolkit · steps in Learner Guide and individual lab folder

Lab 8 verification: prove the control works

- ✓ **Raw evidence is immutable**
- ✓ **Model and prompt versions logged**
- ✓ **Tool actions use scoped identity**
- ✓ **Manual fallback documented**

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

HANDS-ON · LO3

Lab 9: Build a Grounded Threat-Intelligence Assistant

Retrieve from approved threat bulletins and produce cited, abstaining summaries without external APIs.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 9

retrieval_results.json and cited-analyst-brief.md.

Python 3 · TF-IDF · local documents · Hacklab: Ethical Hacking Lab Simulator · steps in Learner Guide and individual lab folder

Lab 9 verification: prove the control works

- ✓ **Every claim has document citation**
- ✓ **ACL filtering occurs before retrieval**
- ✓ **Unknown query abstains**
- ✓ **Embedded instructions are treated as data**

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

HANDS-ON · LO3

Lab 10: Design a Guarded SOAR Playbook

Build a reversible, approval-gated response playbook for suspicious account activity.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 10

playbook.json and dry_run_report.json.

Python 3 · JSON · FauxBank Cybersecurity Training Simulation · steps in Learner Guide and individual lab folder

Lab 10 verification: prove the control works

- ✓ **Default mode is dry-run**
- ✓ **Target identity is verified**
- ✓ **Approval recorded**
- ✓ **Rollback and post-check exist**

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

HANDS-ON · LO3

Lab 11: Create a 90-Day AI Security Action Plan

Sequence architecture work packages, dependencies, acceptance evidence and regulatory review triggers.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 11

action_plan.csv and roadmap.md.

Python 3 · CSV · Hacklab: Ethical Hacking Lab Simulator · steps in Learner Guide and individual lab folder

Lab 11 verification: prove the control works

- ✓ **No dependency cycles**
- ✓ **Every work package has evidence**
- ✓ **Critical path identified**
- ✓ **Change triggers recorded**

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

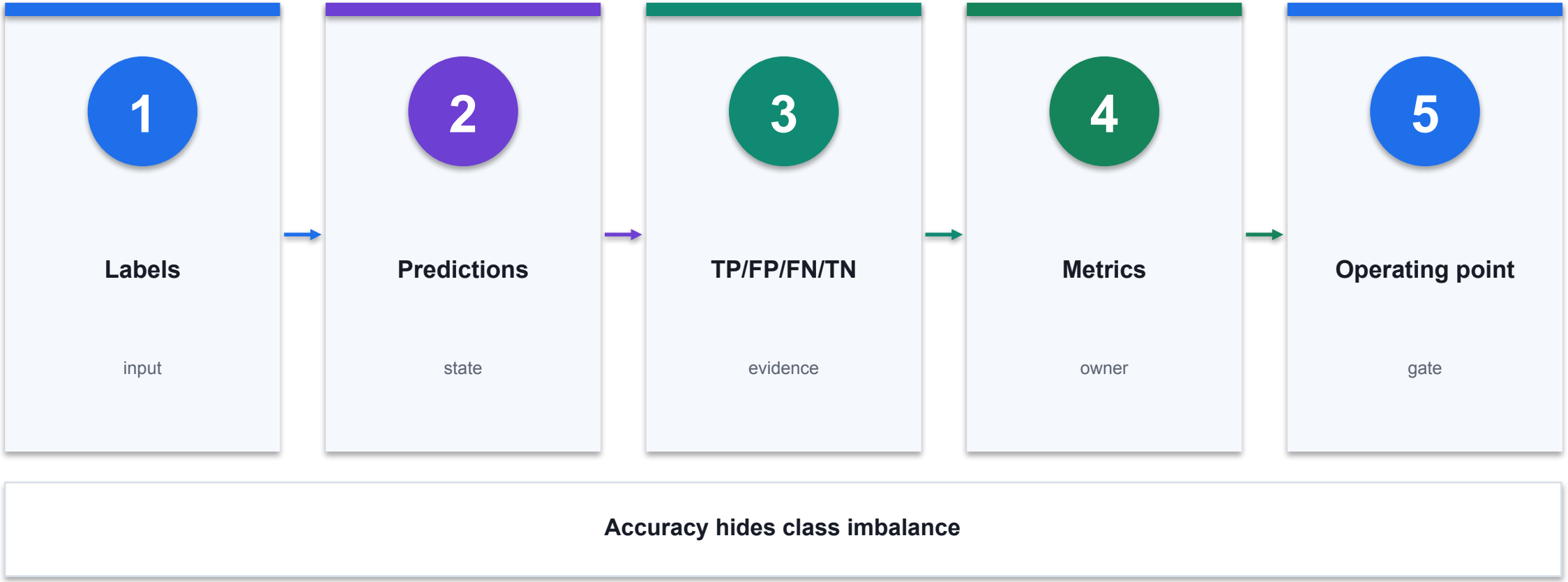
TOPIC 4 · LO4

Monitoring, Evaluating and Governing AI Security Solutions

Metrics · drift · adversarial testing · standards · advisory reporting



Confusion-matrix metrics connect detection to operations



FIELDS · FORMULAS · THRESHOLDS

Confusion-matrix metrics connect detection to operations: concrete contract

```
CONTRACT

01  precision=TP/(TP+FP)

02  recall=TP/(TP+FN)

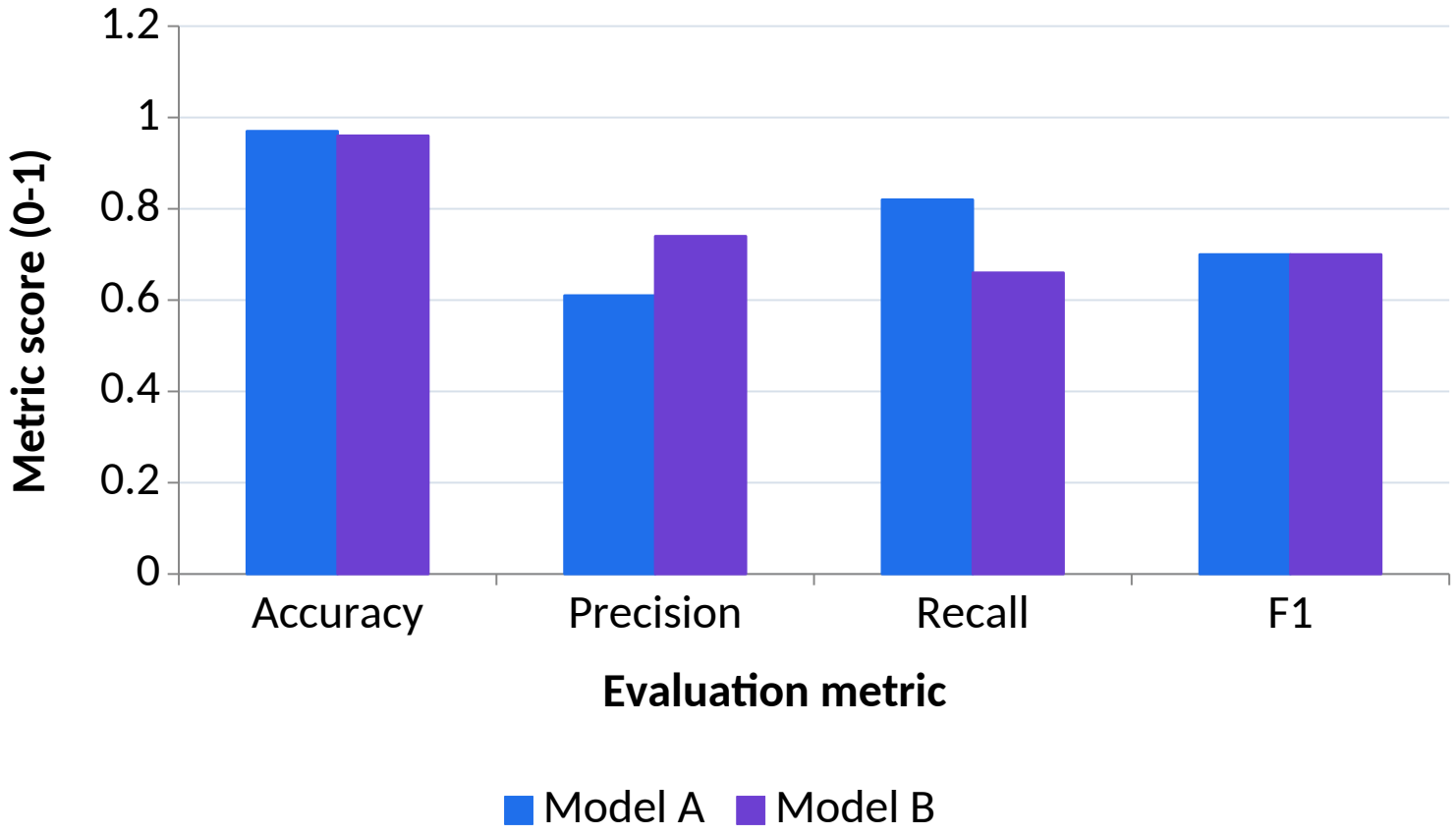
03  FPR=FP/(FP+TN)

04  cost = FP*c_fp + FN*c_fn
```

1. Accuracy hides class imbalance
2. Precision measures alert usefulness
3. Recall measures missed-threat exposure
4. Cost weights business consequence

EDITABLE POWERPOINT CHART · INDICATIVE DATA

Confusion-matrix metrics connect detection to operations: evidence chart



WHAT THE DATA SHOWS

The same F1 can hide different operational trade-offs; choose by miss cost and analyst capacity.

Indicative figures - validate on local data.

Confusion-matrix metrics connect detection to operations: failure and control

FAILURE MODES

- ! Evaluation set not representative
- ! Labels from same detector
- ! Metric without confidence interval
- ! Threshold changed without review

CONTROL & EVIDENCE

- ✓ Frozen test set
- ✓ Class prevalence reported
- ✓ Operating threshold approved
- ✓ Metric tied to workload

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Confusion-matrix metrics connect detection to operations: verification evidence

Acceptance

Frozen test set

Trace

Class prevalence reported

Review

Operating threshold approved

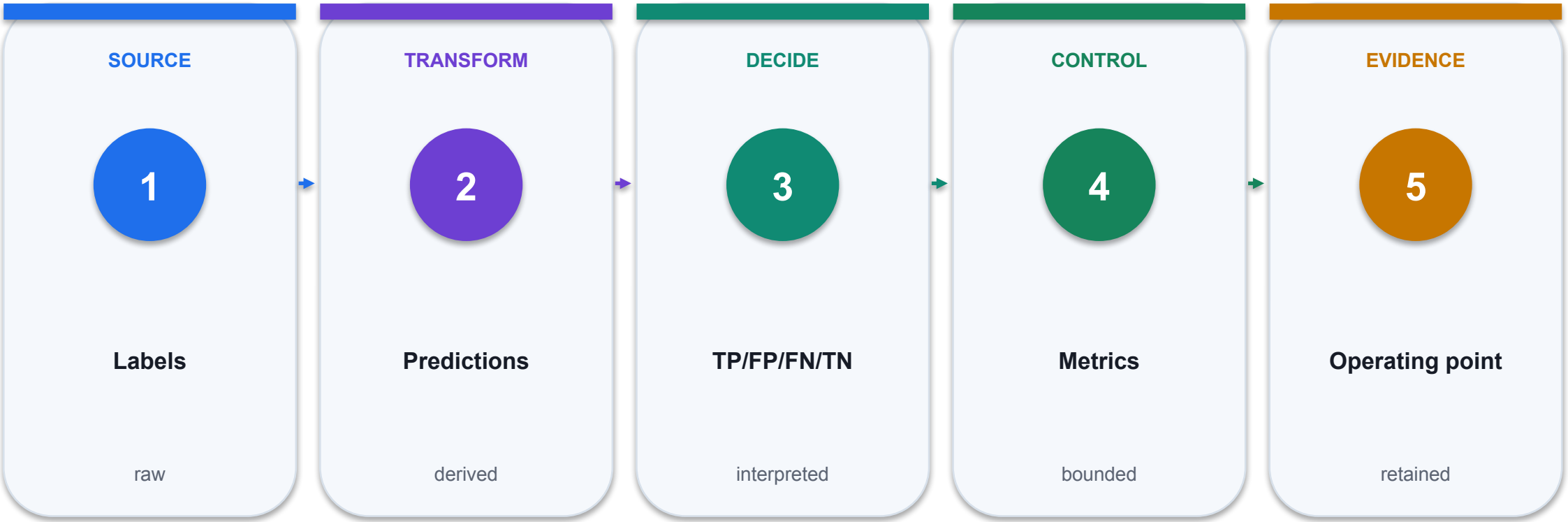
Operate

Metric tied to workload

THE DECISION RULE

Lab 12 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Confusion-matrix metrics connect detection to operations: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

Confusion-matrix metrics connect detection to operations: evidence artifact anatomy

ARTIFACT RECORD

```
01    precision=TP/(TP+FP)

02    recall=TP/(TP+FN)

03    FPR=FP/(FP+TN)

04    cost = FP*c_fp + FN*c_fn
```

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Accuracy hides class imbalance**

Retain: Frozen test set

FIELD 2 — **Precision measures alert usefulness**

Retain: Class prevalence reported

FIELD 3 — **Recall measures missed-threat exposure**

Retain: Operating threshold approved

FIELD 4 — **Cost weights business consequence**

Retain: Metric tied to workload

Confusion-matrix metrics connect detection to operations: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
precision=TP/(TP+FP)	Accuracy hides class imbalance	Evaluation set not representative	Frozen test set
recall=TP/(TP+FN)	Precision measures alert usefulness	Labels from same detector	Class prevalence reported
FPR=FP/(FP+TN)	Recall measures missed-threat exposure	Metric without confidence interval	Operating threshold approved
cost = FP*c_fp + FN*c_fn	Cost weights business consequence	Threshold changed without review	Metric tied to workload

Confusion-matrix metrics connect detection to operations: control test design

T1

Evaluation set not representative

Condition: precision=TP/(TP+FP)

Pass evidence: Frozen test set

T2

Labels from same detector

Condition: recall=TP/(TP+FN)

Pass evidence: Class prevalence reported

T3

Metric without confidence interval

Condition: FPR=FP/(FP+TN)

Pass evidence: Operating threshold approved

T4

Threshold changed without review

Condition: cost = FP*c_fp + FN*c_fn

Pass evidence: Metric tied to workload

Confusion-matrix metrics connect detection to operations: operating trade-offs

CHOICE 1 **Accuracy hides class imbalance**

Trade-off: Evaluation set not representative

Guardrail: Frozen test set

CHOICE 2 **Precision measures alert usefulness**

Trade-off: Labels from same detector

rdrail: Class prevalence reported

REVIEWED OPERATING POINT

CHOICE 3 **Recall measures missed-threat exposure**

Trade-off: Metric without confidence interval

Guardrail: Operating threshold approved

CHOICE 4 **Cost weights business consequence**

Trade-off: Threshold changed without review

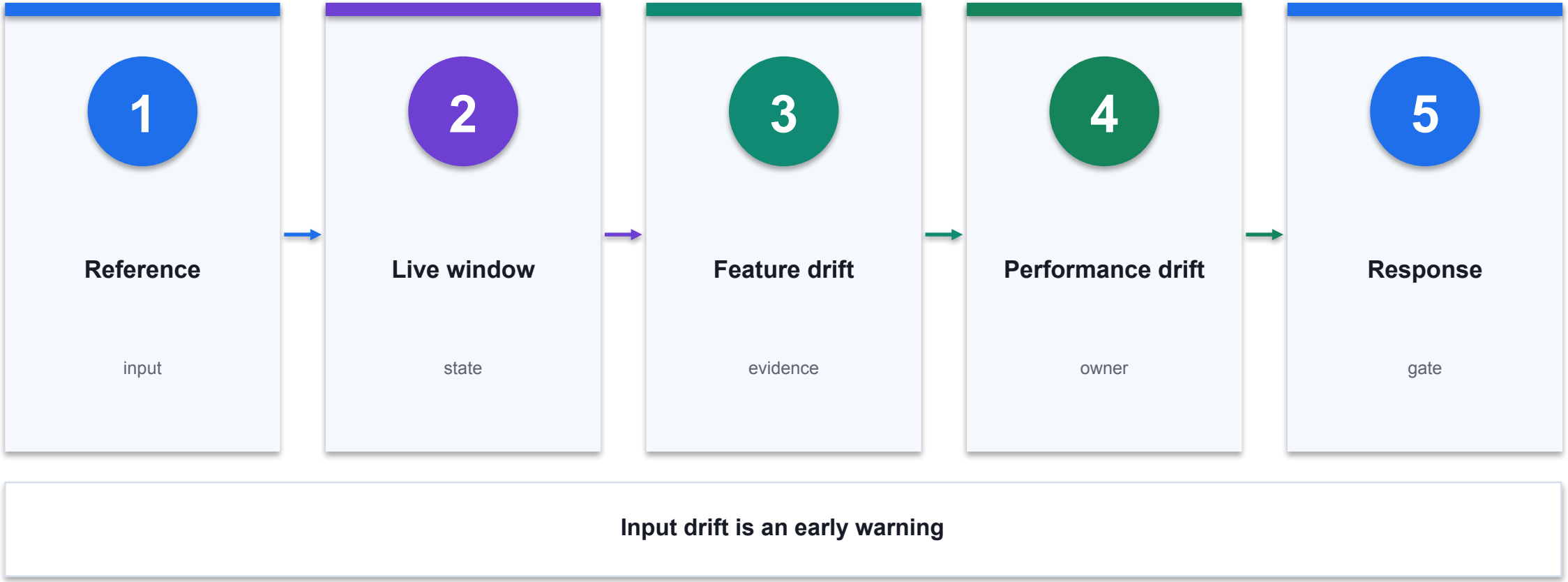
Guardrail: Metric tied to workload

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Confusion-matrix metrics connect detection to operations: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
precision=TP/(TP+FP)	Evaluation set not representative	**Accuracy hides class imbalance**	**Frozen test set**
recall=TP/(TP+FN)	Labels from same detector	**Precision measures alert usefulness**	**Class prevalence reported**
FPR=FP/(FP+TN)	Metric without confidence interval	**Recall measures missed-threat exposure**	**Operating threshold approved**
cost = FP*c_fp + FN*c_fn	Threshold changed without review	**Cost weights business consequence**	**Metric tied to workload**

Drift monitoring compares live distributions and outcomes



FIELDS · FORMULAS · THRESHOLDS

Drift monitoring compares live distributions and outcomes: concrete contract

```
CONTRACT

01   PSI = Σ(actual-expected) ln(actual/expected)

02   feature null rate

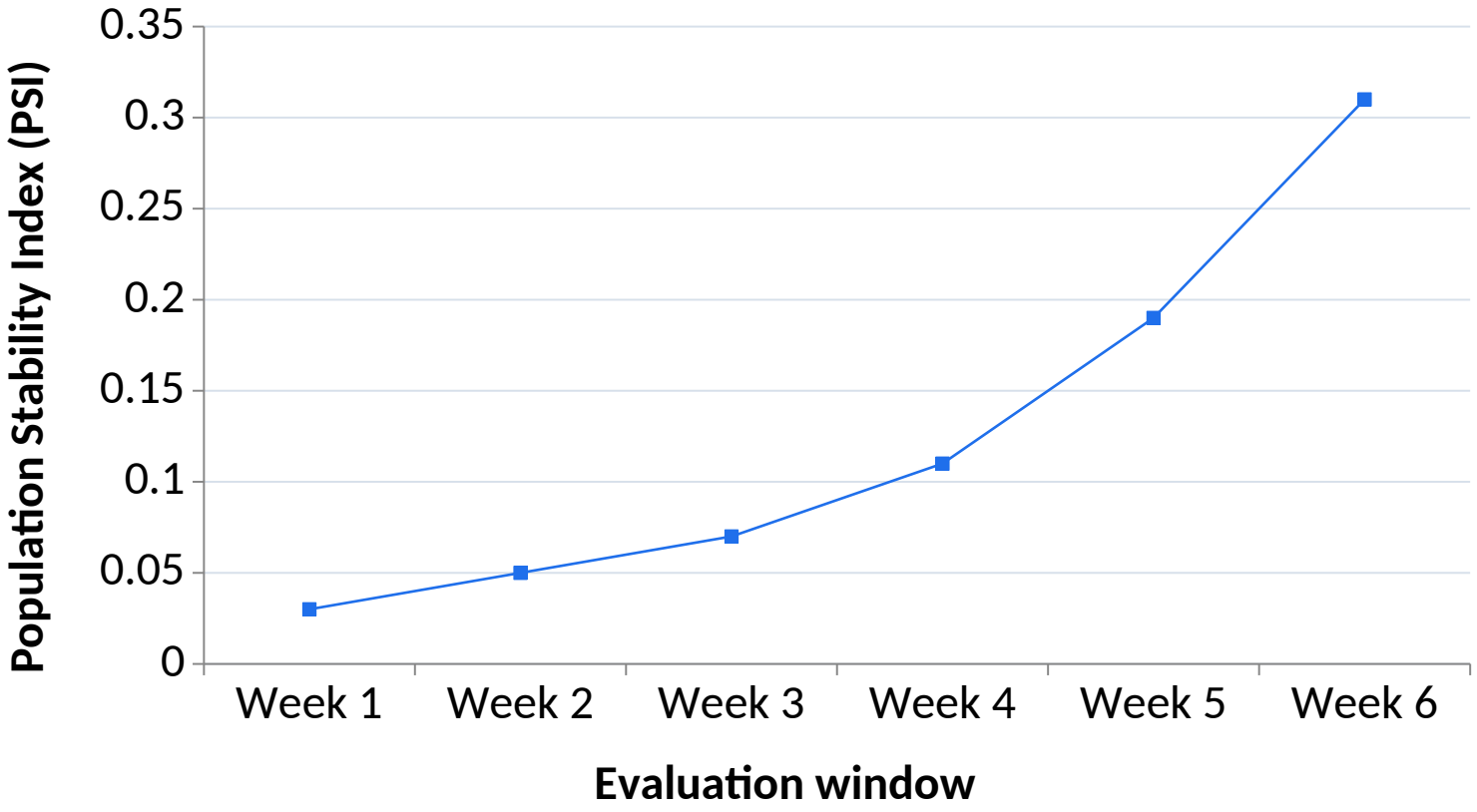
03   score distribution

04   confirmed precision
```

1. Input drift is an early warning
2. Performance needs delayed labels
3. Seasonality needs matched baselines
4. Retraining is not the only response

EDITABLE POWERPOINT CHART · INDICATIVE DATA

Drift monitoring compares live distributions and outcomes: evidence chart



WHAT THE DATA SHOWS

A rising PSI is a diagnostic trigger; it does not by itself prove the detector is wrong.

Indicative figures - validate on local data.

Drift monitoring compares live distributions and outcomes: failure and control

FAILURE MODES

- ! Alert fatigue from noisy drift
- ! Silent schema change
- ! Poisoned feedback
- ! Automatic retraining on attacks

CONTROL & EVIDENCE

- ✓ Drift thresholds
- ✓ Schema-change alert
- ✓ Label quality sample
- ✓ Rollback/recalibrate decision

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Drift monitoring compares live distributions and outcomes: verification evidence

Acceptance

Drift thresholds

Trace

Schema-change alert

Review

Label quality sample

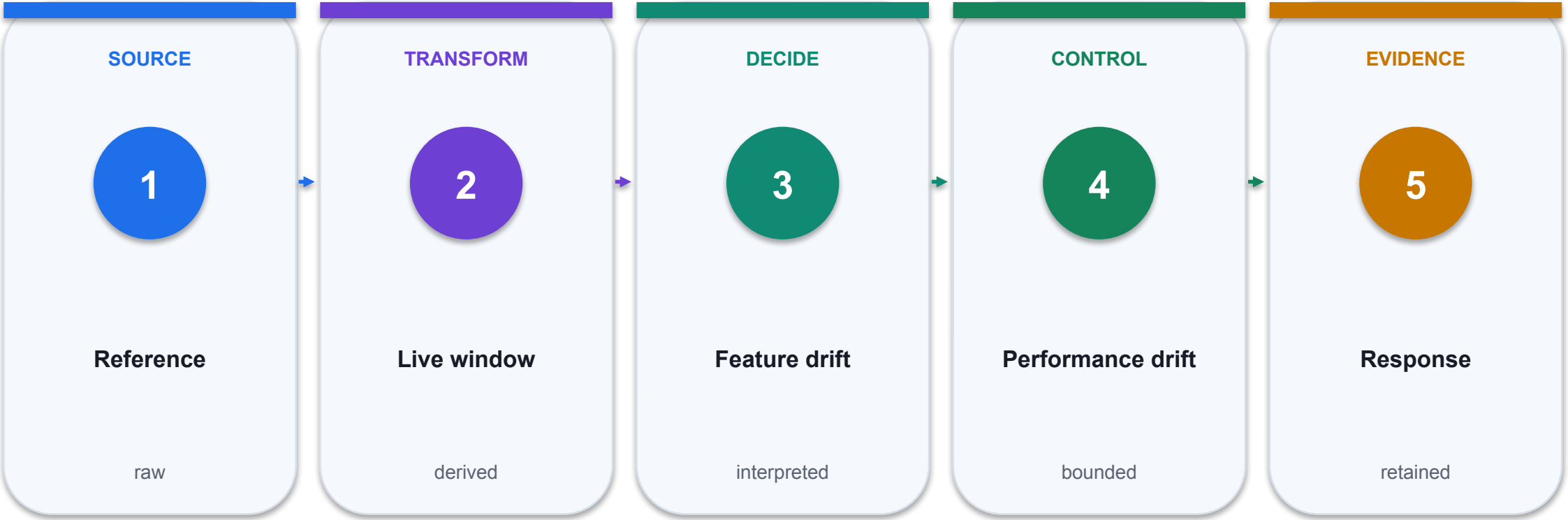
Operate

Rollback/recalibrate decision

THE DECISION RULE

Lab 12 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Drift monitoring compares live distributions and outcomes: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Drift monitoring compares live distributions and outcomes: evidence artifact anatomy

ARTIFACT RECORD

01 PSI = Σ(actual-expected) ln(actual/expected)

02 feature null rate

03 score distribution

04 confirmed precision

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 **Input drift is an early warning**

Retain: Drift thresholds

FIELD 2 **Performance needs delayed labels**

Retain: Schema-change alert

FIELD 3 **Seasonality needs matched baselines**

Retain: Label quality sample

FIELD 4 **Retraining is not the only response**

Retain: Rollback/recalibrate decision

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Drift monitoring compares live distributions and outcomes: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
PSI = Σ(actual-expected) ln(actual/expected)	Input drift is an early warning	Alert fatigue from noisy drift	Drift thresholds
feature null rate	Performance needs delayed labels	Silent schema change	Schema-change alert
score distribution	Seasonality needs matched baselines	Poisoned feedback	Label quality sample
confirmed precision	Retraining is not the only response	Automatic retraining on attacks	Rollback/recalibrate decision

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Drift monitoring compares live distributions and outcomes: control test design

T1

Alert fatigue from noisy drift

Condition: PSI = Σ(actual-expected) ln(actual/expected)

Pass evidence: Drift thresholds

T2

Silent schema change

Condition: feature null rate

Pass evidence: Schema-change alert

T3

Poisoned feedback

Condition: score distribution

Pass evidence: Label quality sample

T4

Automatic retraining on attacks

Condition: confirmed precision

Pass evidence: Rollback/recalibrate decision

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Drift monitoring compares live distributions and outcomes: operating trade-offs

CHOICE 1 **Input drift is an early warning**

Trade-off: Alert fatigue from noisy drift

Guardrail: Drift thresholds

CHOICE 2 **Performance needs delayed labels**

Trade-off: Silent schema change

Guardrail: Schema-change alert

REVIEWED OPERATING POINT

CHOICE 3 **Seasonality needs matched baselines**

Trade-off: Poisoned feedback

Guardrail: Label quality sample

CHOICE 4 **Retraining is not the only response**

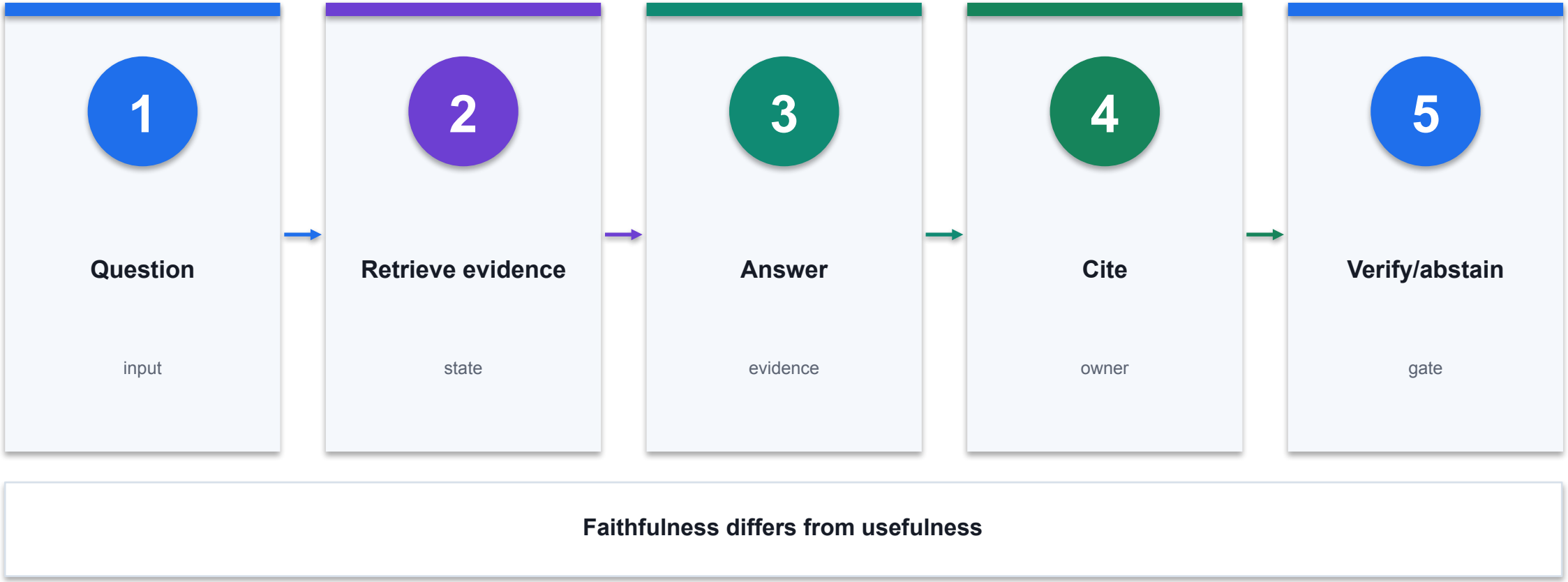
Trade-off: Automatic retraining on attacks

Guardrail: Rollback/recalibrate decision

Drift monitoring compares live distributions and outcomes: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
PSI = Σ(actual-expected) ln(actual/expected)	Alert fatigue from noisy drift	**Input drift is an early warning**	**Drift thresholds**
feature null rate	Silent schema change	**Performance needs delayed labels**	**Schema-change alert**
score distribution	Poisoned feedback	**Seasonality needs matched baselines**	**Label quality sample**
confirmed precision	Automatic retraining on attacks	**Retraining is not the only response**	**Rollback/recalibrate decision**

Grounding and citation tests manage hallucination risk



Grounding and citation tests manage hallucination risk: concrete contract

```
CONTRACT

01   claim span

02   source document/version

03   entailment result

04   abstention reason
```

1. Faithfulness differs from usefulness
2. Citation presence is not citation correctness
3. Unsupported claims can be blocked
4. High-impact advice requires review

ANALYSIS · TRADE-OFF · DECISION

Grounding and citation tests manage hallucination risk: decision model

Signal 1

Faithfulness differs from usefulness

Signal 2

Citation presence is not citation correctness

Signal 3

Unsupported claims can be blocked

Signal 4

High-impact advice requires review

THE DECISION RULE

High-impact advice requires review

Grounding and citation tests manage hallucination risk: failure and control

FAILURE MODES

- ! Fabricated IOC
- ! Citation points to irrelevant paragraph
- ! Stale policy
- ! Answer exceeds source

CONTROL & EVIDENCE

- ✓ Claim-level citation test
- ✓ Freshness SLO
- ✓ Known-unanswerable set
- ✓ Analyst sign-off

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Grounding and citation tests manage hallucination risk: verification evidence

Acceptance

Claim-level citation test

Trace

Freshness SLO

Review

Known-unanswerable set

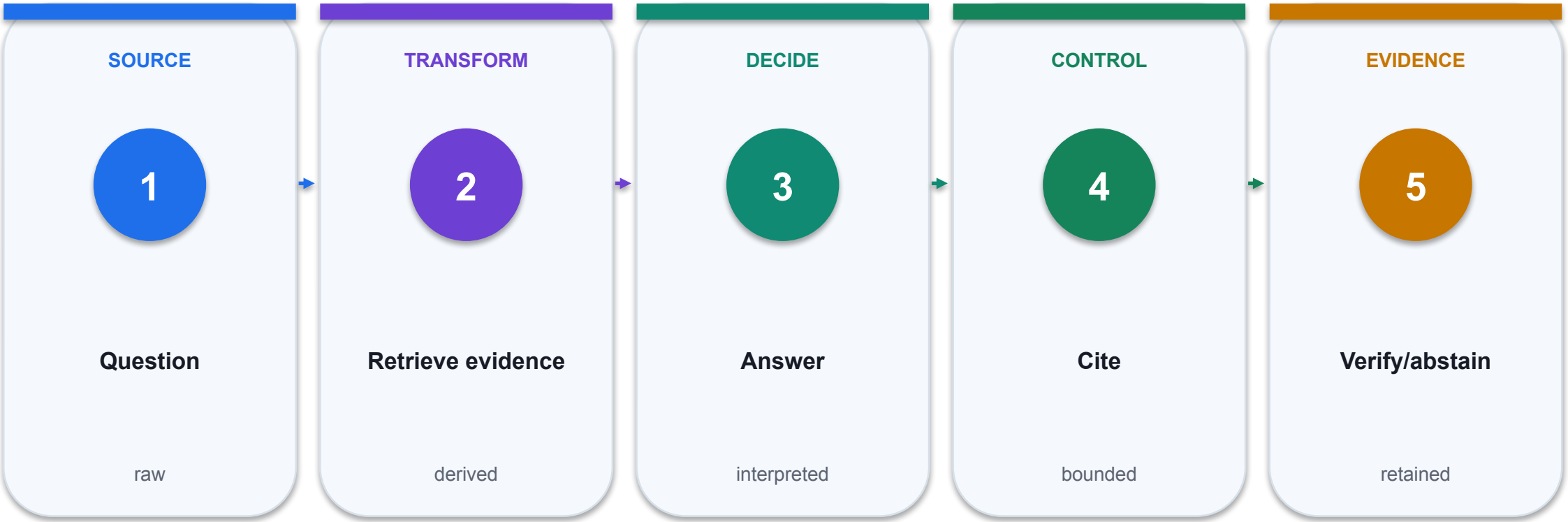
Operate

Analyst sign-off

THE DECISION RULE

Lab 10 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Grounding and citation tests manage hallucination risk: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

Grounding and citation tests manage hallucination risk: evidence artifact anatomy

ARTIFACT RECORD

01 claim span

02 source document/version

03 entailment result

04 abstention reason

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Faithfulness differs from usefulness**

Retain: Claim-level citation test

FIELD 2 — **Citation presence is not citation correctness**

Retain: Freshness SLO

FIELD 3 — **Unsupported claims can be blocked**

Retain: Known-unanswerable set

FIELD 4 — **High-impact advice requires review**

Retain: Analyst sign-off

Grounding and citation tests manage hallucination risk: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
claim span	Faithfulness differs from usefulness	Fabricated IOC	Claim-level citation test
source document/version	Citation presence is not citation correctness	Citation points to irrelevant paragraph	Freshness SLO
entailment result	Unsupported claims can be blocked	Stale policy	Known-unanswerable set
abstention reason	High-impact advice requires review	Answer exceeds source	Analyst sign-off

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Grounding and citation tests manage hallucination risk: control test design

T1

Fabricated IOC

Condition: claim span

Pass evidence: Claim-level citation test

T2

Citation points to irrelevant paragraph

Condition: source document/version

Pass evidence: Freshness SLO

T3

Stale policy

Condition: entailment result

Pass evidence: Known-unanswerable set

T4

Answer exceeds source

Condition: abstention reason

Pass evidence: Analyst sign-off

Grounding and citation tests manage hallucination risk: operating trade-offs

CHOICE 1 **Faithfulness differs from usefulness**

Trade-off: Fabricated IOC

Guardrail: Claim-level citation test

CHOICE 2 **Citation presence is not citation correctness**

Trade-off: Citation points to irrelevant paragraph

Guardrail: Freshness SLO

REVIEWED OPERATING POINT

CHOICE 3 **Unsupported claims can be blocked**

Trade-off: Stale policy

Guardrail: Known-unanswerable set

CHOICE 4 **High-impact advice requires review**

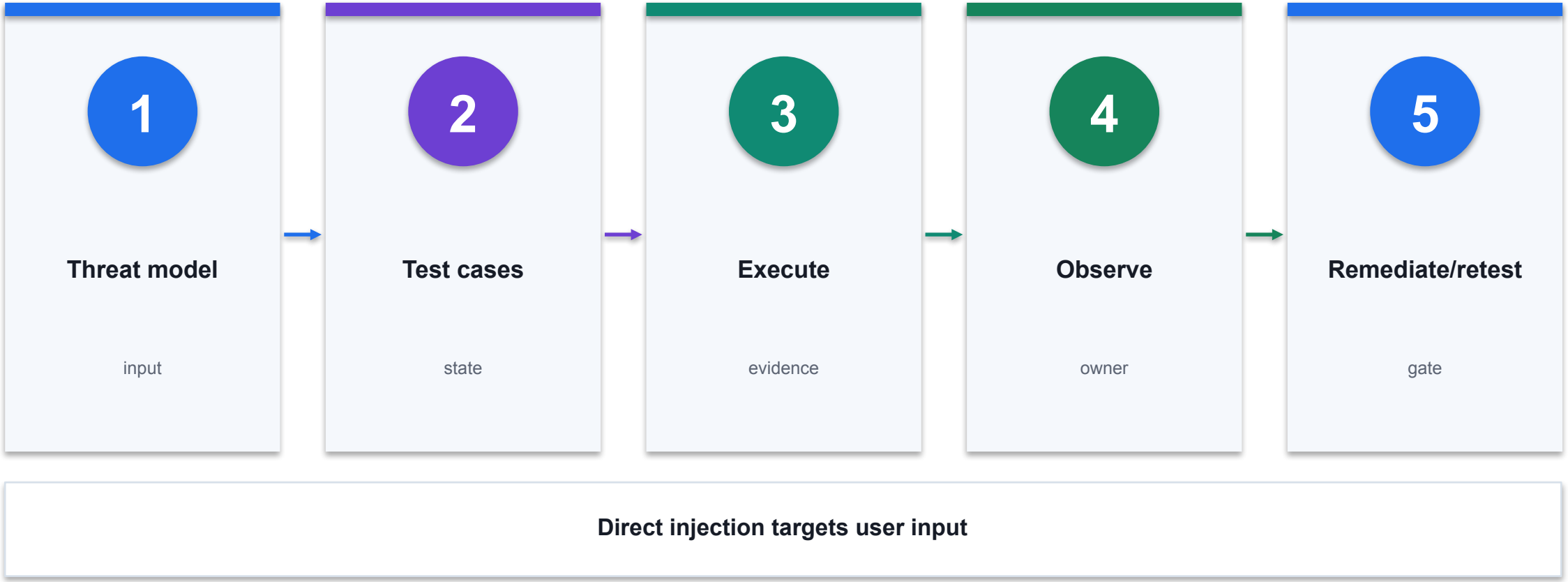
Trade-off: Answer exceeds source

Guardrail: Analyst sign-off

Grounding and citation tests manage hallucination risk: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
claim span	Fabricated IOC	**Faithfulness differs from usefulness**	**Claim-level citation test**
source document/version	Citation points to irrelevant paragraph	**Citation presence is not citation correctness**	**Freshness SLO**
entailment result	Stale policy	**Unsupported claims can be blocked**	**Known-unanswerable set**
abstention reason	Answer exceeds source	**High-impact advice requires review**	**Analyst sign-off**

Adversarial testing follows attacker goals and trust boundaries



Adversarial testing follows attacker goals and trust boundaries: concrete contract

```
CONTRACT

01  ATLAS technique

02  precondition

03  payload/source

04  expected control

05  evidence
```

1. Direct injection targets user input
2. Indirect injection arrives via retrieved content
3. Evasion perturbs model features
4. Poisoning targets training/feedback

ANALYSIS · TRADE-OFF · DECISION

Adversarial testing follows attacker goals and trust boundaries: decision model

Signal 1

Direct injection targets user input

Signal 2

Indirect injection arrives via retrieved content

Signal 3

Evasion perturbs model features

Signal 4

Poisoning targets training/feedback

THE DECISION RULE

Poisoning targets training/feedback

Adversarial testing follows attacker goals and trust boundaries: failure and control

FAILURE MODES

- ! Testing production destructively
- ! No data exfiltration canary
- ! Tool-call side effect
- ! Payloads retained in logs

CONTROL & EVIDENCE

- ✓ Isolated test tenant
- ✓ Canary secret
- ✓ Tool dry-run
- ✓ Retest closes finding

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Adversarial testing follows attacker goals and trust boundaries: verification evidence

Acceptance

Isolated test tenant

Trace

Canary secret

Review

Tool dry-run

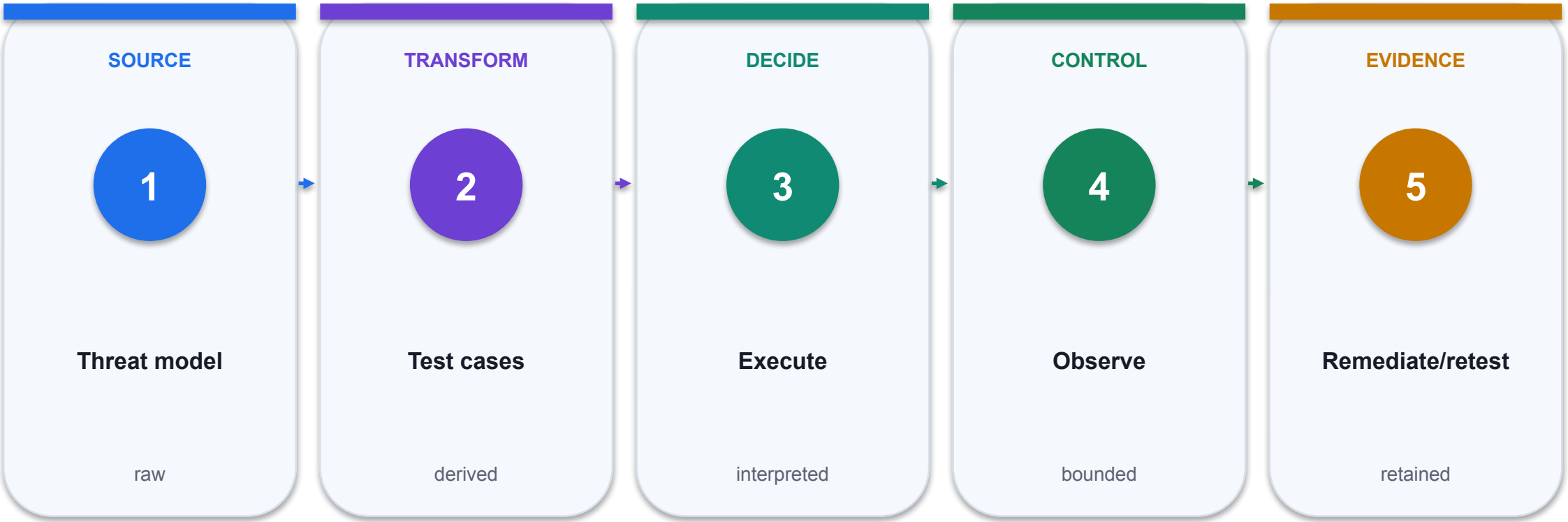
Operate

Retest closes finding

THE DECISION RULE

Lab 12 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Adversarial testing follows attacker goals and trust boundaries: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

Adversarial testing follows attacker goals and trust boundaries: evidence artifact anatomy

ARTIFACT RECORD

01 ATLAS technique

02 precondition

03 payload/source

04 expected control

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Direct injection targets user input**

Retain: Isolated test tenant

FIELD 2 — **Indirect injection arrives via retrieved content**

Retain: Canary secret

FIELD 3 — **Evasion perturbs model features**

Retain: Tool dry-run

FIELD 4 — **Poisoning targets training/feedback**

Retain: Retest closes finding

Adversarial testing follows attacker goals and trust boundaries: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
ATLAS technique	Direct injection targets user input	Testing production destructively	Isolated test tenant
precondition	Indirect injection arrives via retrieved content	No data exfiltration canary	Canary secret
payload/source	Evasion perturbs model features	Tool-call side effect	Tool dry-run
expected control	Poisoning targets training/feedback	Payloads retained in logs	Retest closes finding

Adversarial testing follows attacker goals and trust boundaries: control test design

T1

Testing production destructively

Condition: ATLAS technique

Pass evidence: Isolated test tenant

T2

No data exfiltration canary

Condition: precondition

Pass evidence: Canary secret

T3

Tool-call side effect

Condition: payload/source

Pass evidence: Tool dry-run

T4

Payloads retained in logs

Condition: expected control

Pass evidence: Retest closes finding

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Adversarial testing follows attacker goals and trust boundaries: operating trade-offs

CHOICE 1 **Direct injection targets user input**

Trade-off: Testing production destructively

Guardrail: Isolated test tenant

CHOICE 2 **Indirect injection arrives via retrieved content**

Trade-off: No data exfiltration canary

rdrail: Canary secret

REVIEWED OPERATING POINT

CHOICE 3 **Evasion perturbs model features**

Trade-off: Tool-call side effect

Guardrail: Tool dry-run

CHOICE 4 **Poisoning targets training/feedback**

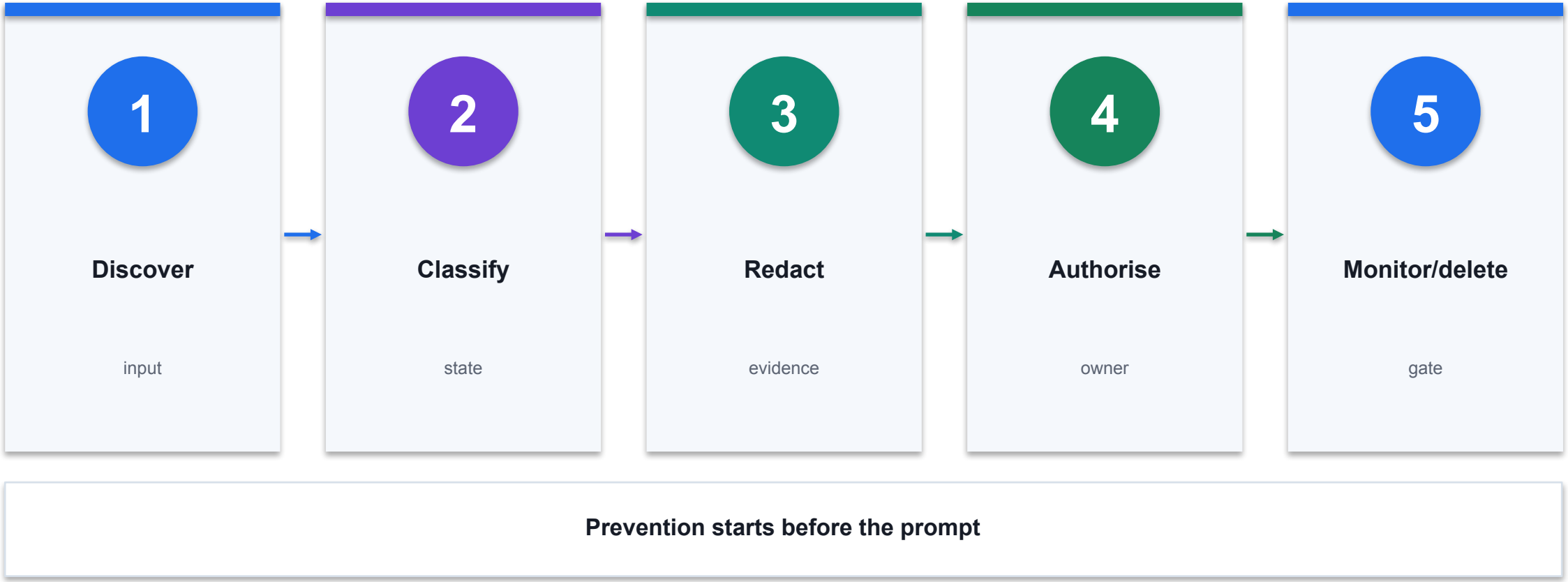
Trade-off: Payloads retained in logs

Guardrail: Retest closes finding

Adversarial testing follows attacker goals and trust boundaries: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
ATLAS technique	Testing production destructively	**Direct injection targets user input**	**Isolated test tenant**
precondition	No data exfiltration canary	**Indirect injection arrives via retrieved content**	**Canary secret**
payload/source	Tool-call side effect	**Evasion perturbs model features**	**Tool dry-run**
expected control	Payloads retained in logs	**Poisoning targets training/feedback**	**Retest closes finding**

Privacy and data-loss controls apply before, during and after inference



Privacy and data-loss controls apply before, during and after inference: concrete contract

```
CONTRACT

01   secret/PII detectors

02   token-level redaction

03   purpose + consent

04   retention/deletion receipt
```

1. Prevention starts before the prompt
2. Outputs can reconstruct inputs
3. Logs may be more sensitive than prompts
4. Deletion spans provider and local stores

ANALYSIS · TRADE-OFF · DECISION

Privacy and data-loss controls apply before, during and after inference: decision model

Signal 1

Prevention starts before the prompt

Signal 2

Outputs can reconstruct inputs

Signal 3

Logs may be more sensitive than prompts

Signal 4

Deletion spans provider and local stores

THE DECISION RULE

Deletion spans provider and local stores

Privacy and data-loss controls apply before, during and after inference: failure and control

FAILURE MODES

- ! Prompt contains API key
- ! Model memorisation
- ! Sensitive output
- ! Debug log leakage

CONTROL & EVIDENCE

- ✓ Secret canary blocked
- ✓ Output DLP test
- ✓ Log access review
- ✓ Deletion proof

Privacy and data-loss controls apply before, during and after inference: verification evidence

Acceptance

Secret canary blocked

Trace

Output DLP test

Review

Log access review

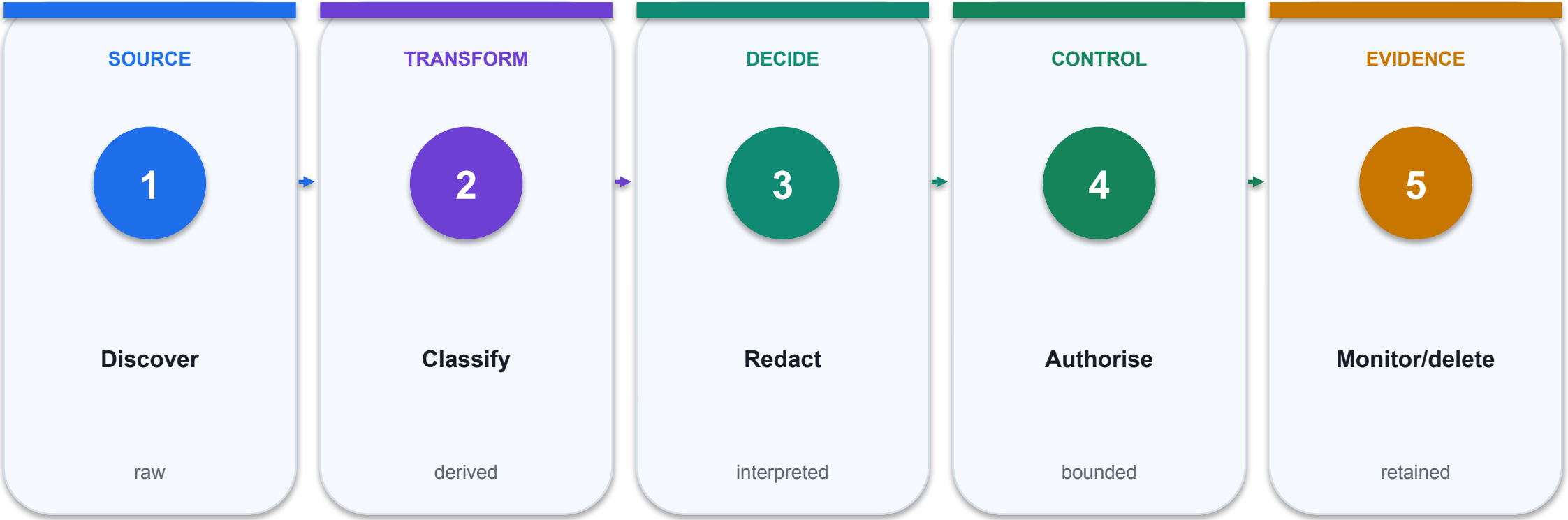
Operate

Deletion proof

THE DECISION RULE

Lab 8 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Privacy and data-loss controls apply before, during and after inference: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

Privacy and data-loss controls apply before, during and after inference: evidence artifact anatomy

ARTIFACT RECORD

01 secret/PII detectors

02 token-level redaction

03 purpose + consent

04 retention/deletion receipt

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Prevention starts before the prompt**

Retain: Secret canary blocked

FIELD 2 — **Outputs can reconstruct inputs**

Retain: Output DLP test

FIELD 3 — **Logs may be more sensitive than prompts**

Retain: Log access review

FIELD 4 — **Deletion spans provider and local stores**

Retain: Deletion proof

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Privacy and data-loss controls apply before, during and after inference: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
secret/PII detectors	Prevention starts before the prompt	Prompt contains API key	Secret canary blocked
token-level redaction	Outputs can reconstruct inputs	Model memorisation	Output DLP test
purpose + consent	Logs may be more sensitive than prompts	Sensitive output	Log access review
retention/deletion receipt	Deletion spans provider and local stores	Debug log leakage	Deletion proof

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Privacy and data-loss controls apply before, during and after inference: control test design

T1

Prompt contains API key

Condition: secret/PII detectors

Pass evidence: Secret canary blocked

T2

Model memorisation

Condition: token-level redaction

Pass evidence: Output DLP test

T3

Sensitive output

Condition: purpose + consent

Pass evidence: Log access review

T4

Debug log leakage

Condition: retention/deletion receipt

Pass evidence: Deletion proof

Privacy and data-loss controls apply before, during and after inference: operating trade-offs

CHOICE 1 **Prevention starts before the prompt**

Trade-off: Prompt contains API key

Guardrail: Secret canary blocked

CHOICE 2 **Outputs can reconstruct inputs**

Trade-off: Model memorisation

rdrail: Output DLP test

REVIEWED OPERATING POINT

CHOICE 3 **Logs may be more sensitive than prompts**

Trade-off: Sensitive output

Guardrail: Log access review

CHOICE 4 **Deletion spans provider and local stores**

Trade-off: Debug log leakage

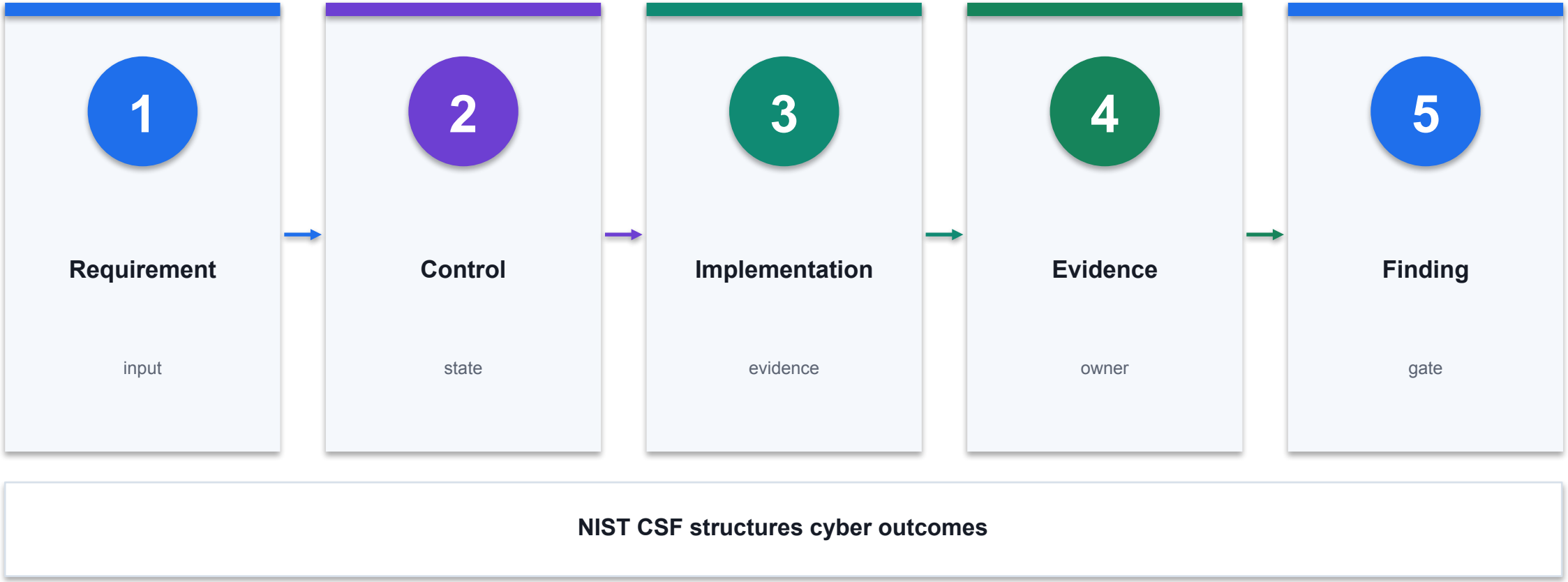
Guardrail: Deletion proof

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Privacy and data-loss controls apply before, during and after inference: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
secret/PII detectors	Prompt contains API key	**Prevention starts before the prompt**	**Secret canary blocked**
token-level redaction	Model memorisation	**Outputs can reconstruct inputs**	**Output DLP test**
purpose + consent	Sensitive output	**Logs may be more sensitive than prompts**	**Log access review**
retention/deletion receipt	Debug log leakage	**Deletion spans provider and local stores**	**Deletion proof**

Standards mapping turns principles into evidence



Standards mapping turns principles into evidence: concrete contract

```
CONTRACT

01   framework/function/category

02   control owner

03   test frequency

04   evidence location
```

1. NIST CSF structures cyber outcomes
2. AI RMF covers AI-specific governance
3. ISO-style controls support assurance
4. Mapping avoids duplicate evidence

ANALYSIS · TRADE-OFF · DECISION

Standards mapping turns principles into evidence: decision model

Signal 1

NIST CSF structures cyber outcomes

Signal 2

AI RMF covers AI-specific governance

Signal 3

ISO-style controls support assurance

Signal 4

Mapping avoids duplicate evidence

THE DECISION RULE

Mapping avoids duplicate evidence

Standards mapping turns principles into evidence: failure and control

FAILURE MODES

- ! Checkbox mapping
- ! No test frequency
- ! Vendor assertion only
- ! Conflicting control owners

CONTROL & EVIDENCE

- ✓ Sample evidence
- ✓ Independent test
- ✓ Exception record
- ✓ Management review

Standards mapping turns principles into evidence: verification evidence

Acceptance

Sample evidence

Trace

Independent test

Review

Exception record

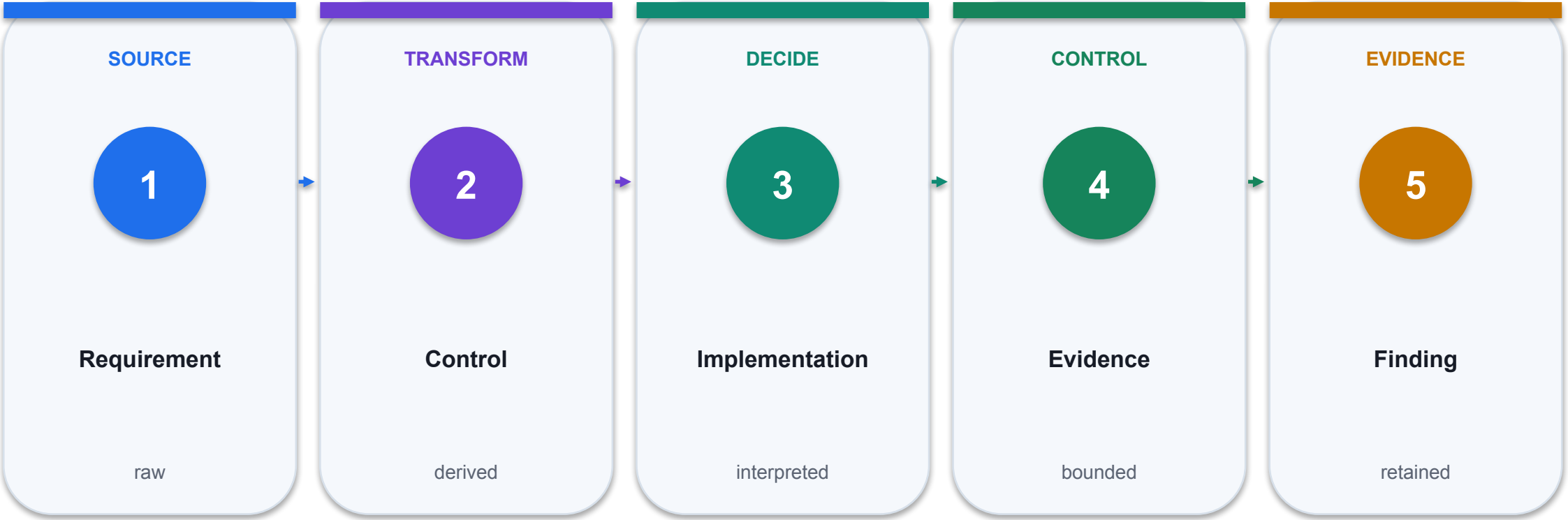
Operate

Management review

THE DECISION RULE

Lab 12 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Standards mapping turns principles into evidence: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Standards mapping turns principles into evidence: evidence artifact anatomy

ARTIFACT RECORD

01 framework/function/category

02 control owner

03 test frequency

04 evidence location

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **NIST CSF structures cyber outcomes**

Retain: Sample evidence

FIELD 2 — **AI RMF covers AI-specific governance**

Retain: Independent test

FIELD 3 — **ISO-style controls support assurance**

Retain: Exception record

FIELD 4 — **Mapping avoids duplicate evidence**

Retain: Management review

Standards mapping turns principles into evidence: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
framework/function/category	NIST CSF structures cyber outcomes	Checkbox mapping	Sample evidence
control owner	AI RMF covers AI-specific governance	No test frequency	Independent test
test frequency	ISO-style controls support assurance	Vendor assertion only	Exception record
evidence location	Mapping avoids duplicate evidence	Conflicting control owners	Management review

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Standards mapping turns principles into evidence: control test design

T1

Checkbox mapping

Condition: framework/function/category

Pass evidence: Sample evidence

T2

No test frequency

Condition: control owner

Pass evidence: Independent test

T3

Vendor assertion only

Condition: test frequency

Pass evidence: Exception record

T4

Conflicting control owners

Condition: evidence location

Pass evidence: Management review

Standards mapping turns principles into evidence: operating trade-offs

CHOICE 1 **NIST CSF structures cyber outcomes**

Trade-off: Checkbox mapping

Guardrail: Sample evidence

CHOICE 2 **AI RMF covers AI-specific governance**

Trade-off: No test frequency

rdrail: Independent test

REVIEWED OPERATING POINT

CHOICE 3 **ISO-style controls support assurance**

Trade-off: Vendor assertion only

Guardrail: Exception record

CHOICE 4 **Mapping avoids duplicate evidence**

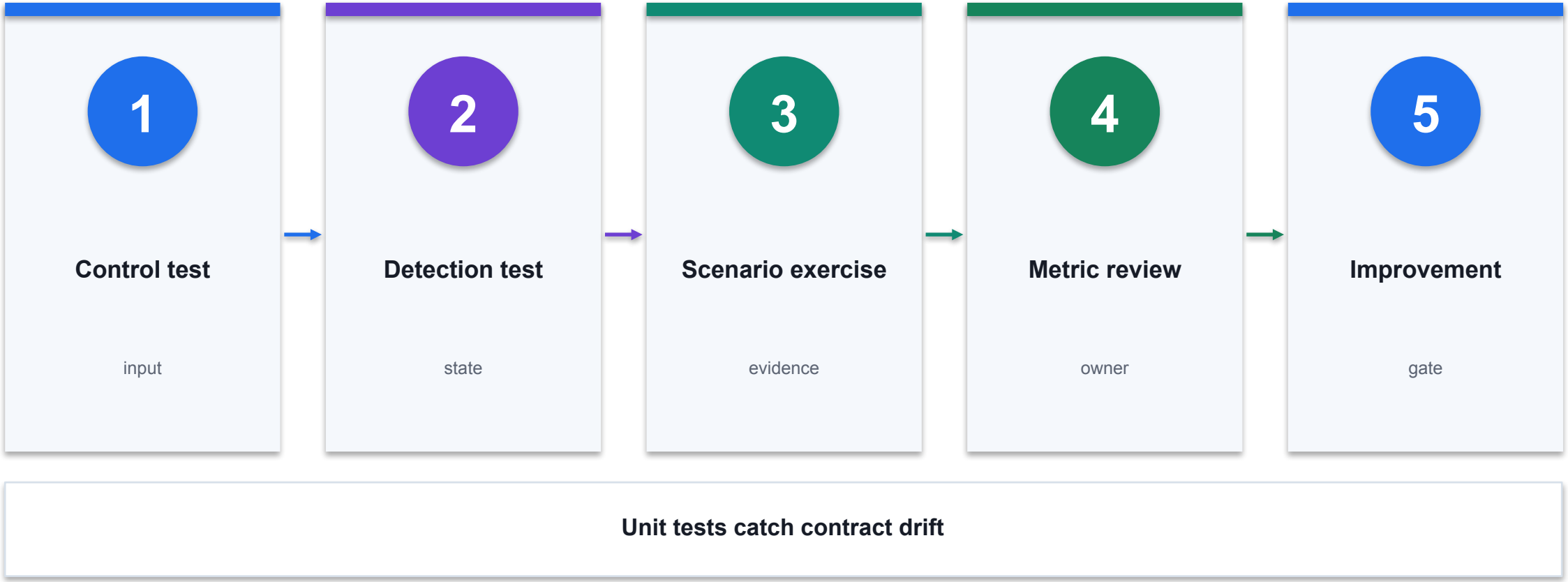
Trade-off: Conflicting control owners

Guardrail: Management review

Standards mapping turns principles into evidence: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
framework/function/category	Checkbox mapping	**NIST CSF structures cyber outcomes**	**Sample evidence**
control owner	No test frequency	**AI RMF covers AI-specific governance**	**Independent test**
test frequency	Vendor assertion only	**ISO-style controls support assurance**	**Exception record**
evidence location	Conflicting control owners	**Mapping avoids duplicate evidence**	**Management review**

Continuous assurance combines technical tests and operational review



FIELDS · FORMULAS · THRESHOLDS

Continuous assurance combines technical tests and operational review: concrete contract

```
CONTRACT

01   test id/version

02   expected result

03   observed evidence

04   owner/due date
```

1. Unit tests catch contract drift
2. Purple-team tests validate detections
3. Tabletops validate decisions
4. Metrics expose operating degradation

ANALYSIS · TRADE-OFF · DECISION

Continuous assurance combines technical tests and operational review: decision model

Signal 1

Unit tests catch contract drift

Signal 2

Purple-team tests validate detections

Signal 3

Tabletops validate decisions

Signal 4

Metrics expose operating degradation

THE DECISION RULE

Metrics expose operating degradation

Continuous assurance combines technical tests and operational review: failure and control

FAILURE MODES

- ! Tests never fail
- ! Synthetic scenario unlike production
- ! Finding closed without evidence
- ! No retest

CONTROL & EVIDENCE

- ✓ Failure injection
- ✓ Independent review
- ✓ Retest evidence
- ✓ Backlog trend

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Continuous assurance combines technical tests and operational review: verification evidence

Acceptance

Failure injection

Trace

Independent review

Review

Retest evidence

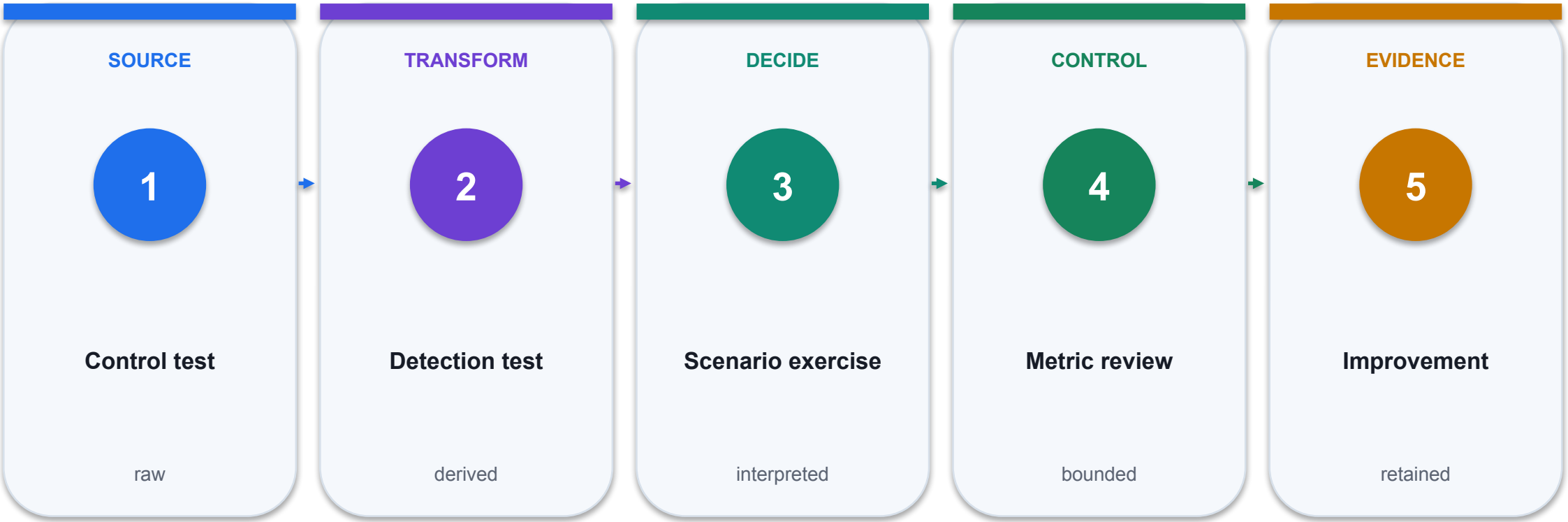
Operate

Backlog trend

THE DECISION RULE

Lab 12 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Continuous assurance combines technical tests and operational review: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Continuous assurance combines technical tests and operational review: evidence artifact anatomy

ARTIFACT RECORD

01 test id/version

02 expected result

03 observed evidence

04 owner/due date

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Unit tests catch contract drift**

Retain: Failure injection

FIELD 2 — **Purple-team tests validate detections**

Retain: Independent review

FIELD 3 — **Tabletops validate decisions**

Retain: Retest evidence

FIELD 4 — **Metrics expose operating degradation**

Retain: Backlog trend

SIGNAL · DECISION EFFECT · FAILURE · EVIDENCE

Continuous assurance combines technical tests and operational review: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
test id/version	Unit tests catch contract drift	Tests never fail	Failure injection
expected result	Purple-team tests validate detections	Synthetic scenario unlike production	Independent review
observed evidence	Tabletops validate decisions	Finding closed without evidence	Retest evidence
owner/due date	Metrics expose operating degradation	No retest	Backlog trend

Continuous assurance combines technical tests and operational review: control test design

T1

Tests never fail

Condition: test id/version

Pass evidence: Failure injection

T2

Synthetic scenario unlike production

Condition: expected result

Pass evidence: Independent review

T3

Finding closed without evidence

Condition: observed evidence

Pass evidence: Retest evidence

T4

No retest

Condition: owner/due date

Pass evidence: Backlog trend

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Continuous assurance combines technical tests and operational review: operating trade-offs

CHOICE 1 **Unit tests catch contract drift**

Trade-off: Tests never fail

Guardrail: Failure injection

CHOICE 2 **Purple-team tests validate detections**

Trade-off: Synthetic scenario unlike production

rdrail: Independent review

REVIEWED OPERATING POINT

CHOICE 3 **Tabletops validate decisions**

Trade-off: Finding closed without evidence

Guardrail: Retest evidence

CHOICE 4 **Metrics expose operating degradation**

Trade-off: No retest

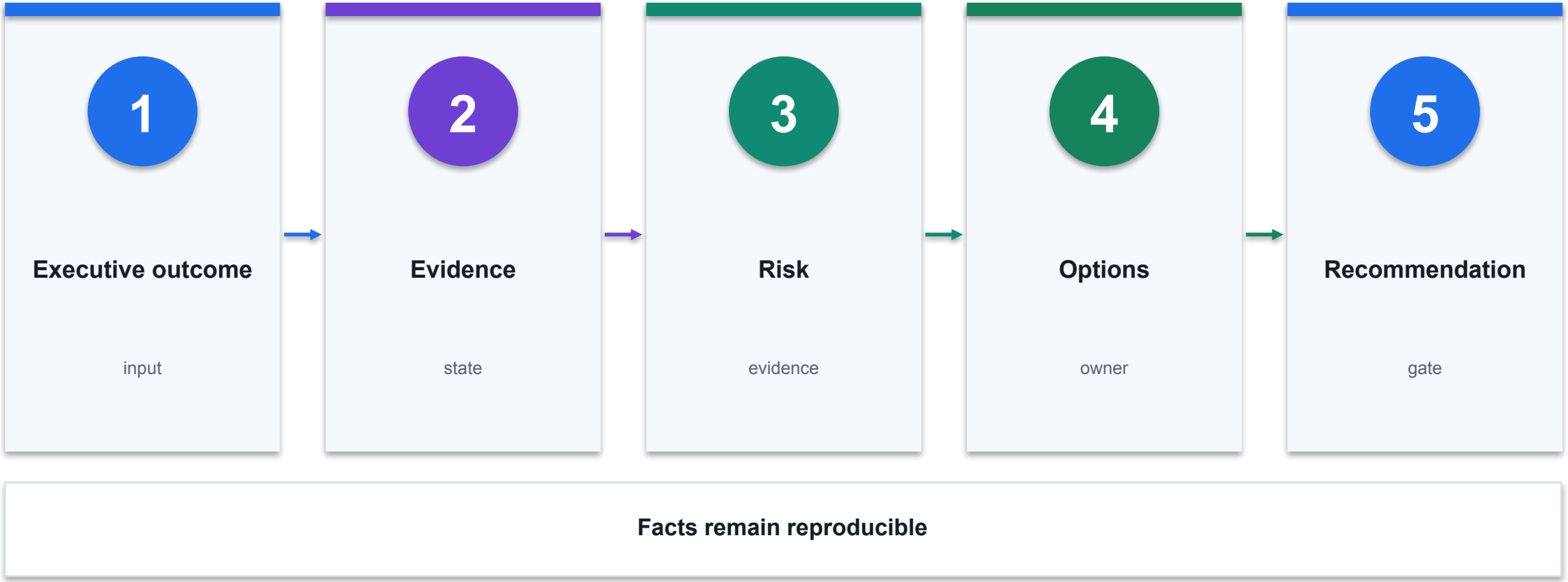
Guardrail: Backlog trend

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Continuous assurance combines technical tests and operational review: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
test id/version	Tests never fail	**Unit tests catch contract drift**	**Failure injection**
expected result	Synthetic scenario unlike production	**Purple-team tests validate detections**	**Independent review**
observed evidence	Finding closed without evidence	**Tabletops validate decisions**	**Retest evidence**
owner/due date	No retest	**Metrics expose operating degradation**	**Backlog trend**

Advisory reporting separates facts, inference and recommendations



Advisory reporting separates facts, inference and recommendations: concrete contract

```
CONTRACT

01  finding + source

02  confidence/limitations

03  decision owner

04  action/measure/date
```

1. Facts remain reproducible
2. Inference is labelled
3. Options expose trade-offs
4. Recommendation has owner and metric

ANALYSIS · TRADE-OFF · DECISION

Advisory reporting separates facts, inference and recommendations: decision model

Signal 1

Facts remain reproducible

Signal 2

Inference is labelled

Signal 3

Options expose trade-offs

Signal 4

Recommendation has owner and metric

THE DECISION RULE

Recommendation has owner and metric

Advisory reporting separates facts, inference and recommendations: failure and control

FAILURE MODES

- ! AI-generated certainty
- ! No limitation statement
- ! Recommendation without cost
- ! No follow-up measure

CONTROL & EVIDENCE

- ✓ Source appendix
- ✓ Assumption register
- ✓ Management decision
- ✓ 30/60/90-day readback

EVIDENCE · ACCEPTANCE · LAB BRIDGE

Advisory reporting separates facts, inference and recommendations: verification evidence

Acceptance

Source appendix

Trace

Assumption register

Review

Management decision

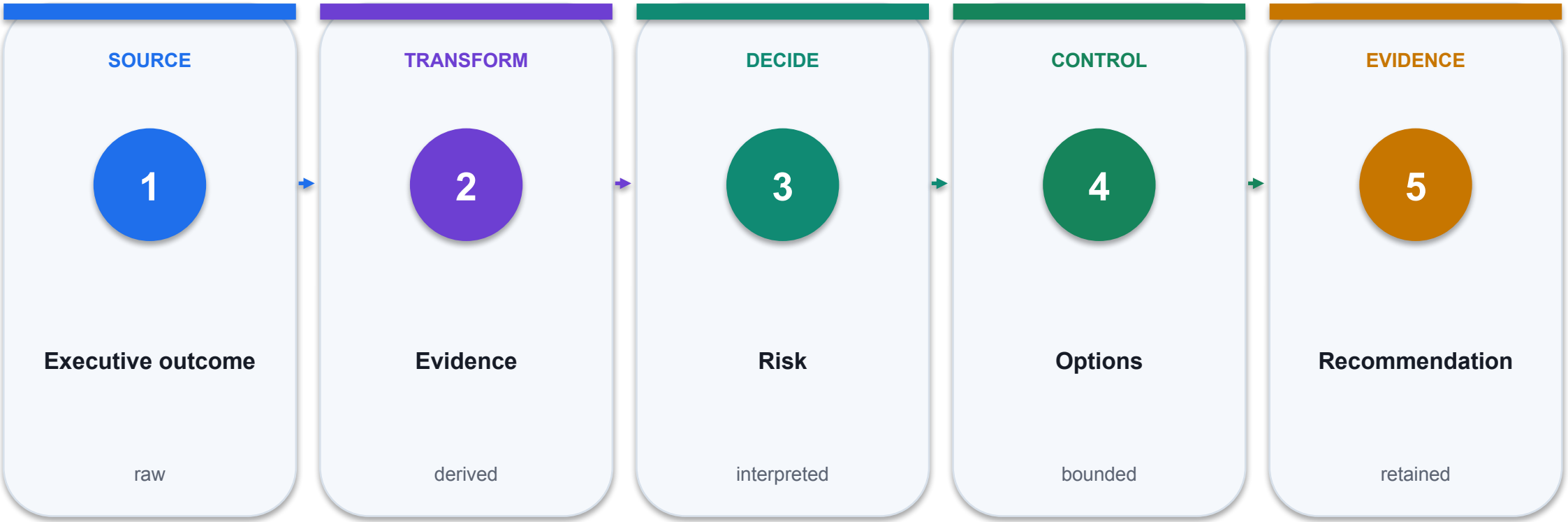
Operate

30/60/90-day readback

THE DECISION RULE

Lab 12 creates a reproducible artifact; detailed steps stay in the Learner Guide.

Advisory reporting separates facts, inference and recommendations: architecture boundaries



Boundary rule: preserve provenance across every hand-off and bind approval authority to the control gate.

SCHEMA · PROVENANCE · INTERPRETATION

Advisory reporting separates facts, inference and recommendations: evidence artifact anatomy

ARTIFACT RECORD

01 finding + source

02 confidence/limitations

03 decision owner

04 action/measure/date

Immutable input reference · model/rule version · timestamp · named reviewer

FIELD 1 — **Facts remain reproducible**

Retain: Source appendix

FIELD 2 — **Inference is labelled**

Retain: Assumption register

FIELD 3 — **Options expose trade-offs**

Retain: Management decision

FIELD 4 — **Recommendation has owner and metric**

Retain: 30/60/90-day readback

Advisory reporting separates facts, inference and recommendations: decision matrix

OBSERVED SIGNAL	DECISION EFFECT	IF MISREAD	REQUIRED EVIDENCE
finding + source	Facts remain reproducible	AI-generated certainty	Source appendix
confidence/limitations	Inference is labelled	No limitation statement	Assumption register
decision owner	Options expose trade-offs	Recommendation without cost	Management decision
action/measure/date	Recommendation has owner and metric	No follow-up measure	30/60/90-day readback

TEST CONDITION · EXPECTED CONTROL · PASS EVIDENCE

Advisory reporting separates facts, inference and recommendations: control test design

T1

AI-generated certainty

Condition: finding + source

Pass evidence: Source appendix

T2

No limitation statement

Condition: confidence/limitations

Pass evidence: Assumption register

T3

Recommendation without cost

Condition: decision owner

Pass evidence: Management decision

T4

No follow-up measure

Condition: action/measure/date

Pass evidence: 30/60/90-day readback

VALUE · RISK · OPERABILITY · HUMAN ACCOUNTABILITY

Advisory reporting separates facts, inference and recommendations: operating trade-offs

CHOICE 1 **Facts remain reproducible**

Trade-off: AI-generated certainty

Guardrail: Source appendix

CHOICE 2 **Inference is labelled**

Trade-off: No limitation statement

rdrail: Assumption register

REVIEWED OPERATING POINT

CHOICE 3 **Options expose trade-offs**

Trade-off: Recommendation without cost

Guardrail: Management decision

CHOICE 4 **Recommendation has owner and metric**

Trade-off: No follow-up measure

Guardrail: 30/60/90-day readback

OBSERVATION → INTERPRETATION → DECISION → RETAINED PROOF

Advisory reporting separates facts, inference and recommendations: evidence-to-decision trace

OBSERVED	INTERPRET	DECISION	RETAIN
finding + source	AI-generated certainty	**Facts remain reproducible**	**Source appendix**
confidence/limitations	No limitation statement	**Inference is labelled**	**Assumption register**
decision owner	Recommendation without cost	**Options expose trade-offs**	**Management decision**
action/measure/date	No follow-up measure	**Recommendation has owner and metric**	**30/60/90-day readback**

HANDS-ON · LO4

Lab 12: Monitor Model Effectiveness and Produce Advice

Measure detection quality, identify drift and control failures, then issue evidence-backed adoption advice.

1. **Inspect evidence**
2. **Build mechanism**
3. **Test boundary**
4. **Explain result**

LAB 12

monitoring_report.json and advisory_report.md.

Python 3 · pandas · scikit-learn metrics · Cryptography Toolkit · steps in Learner Guide and individual lab folder

Lab 12 verification: prove the control works

- ✓ **Metrics include class prevalence**
- ✓ **Drift is diagnostic, not automatic retraining**
- ✓ **Advice separates fact/inference/recommendation**
- ✓ **Each action has owner and measure**

Capture configuration, output, evidence reference and analyst decision - not screenshots alone.

COURSE SYNTHESIS

From AI output to defensible security decisions

Evidence · human accountability · guarded automation · continuous assurance



PRIMARY AND AUTHORITATIVE REFERENCES

Selected Sources (1/3)

ACSC et al. (2026)

Opportunities for AI in cyber defence

NIST (2024)

Cybersecurity Framework 2.0

NIST (2023)

AI Risk Management Framework 1.0

NIST (2025)

Adversarial Machine Learning Taxonomy and Terminology

THE DECISION RULE

Full URLs, document titles and retrieval date are listed in the Learner Guide.

PRIMARY AND AUTHORITATIVE REFERENCES

Selected Sources (2/3)

OWASP

Top 10 for Large Language Model Applications

CISA

Secure by Design

Google Cloud

AI for Security

IBM

AI cybersecurity solutions

THE DECISION RULE

Full URLs, document titles and retrieval date are listed in the Learner Guide.

PRIMARY AND AUTHORITATIVE REFERENCES

Selected Sources (3/3)

Alfred Ang

Cybersecurity Threat Simulation Lab

Alfred Ang

Hacklab: Ethical Hacking Lab Simulator

Tertiary Infotech Academy

FauxBank Cybersecurity Training Simulation

Alfred Ang

Cryptography Toolkit

THE DECISION RULE

Full URLs, document titles and retrieval date are listed in the Learner Guide.

Course Feedback

Content

Rate the topics, slides and examples.

Labs

Tell us which labs worked and which need more time.

Pacing

Comment on the two-day pacing and delivery.

Improve

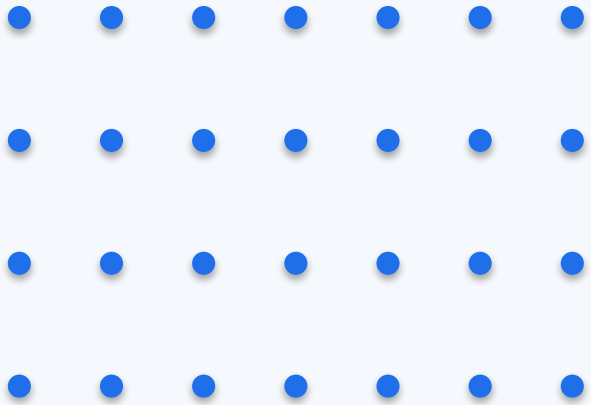
Suggest one change for the next run.

THE DECISION RULE

Use the feedback link or QR code shared by your trainer.

THANK YOU

Secure decisions need evidence, boundaries and accountable people



enquiry@tertiaryinfotech.com · +65 6100 0613 ·
www.tertiarycourses.com.sg